
FIELD PACKAGE

K-12 Google Workspace Anti-Phishing Hardening Package

A complete, setting-by-setting hardening package for a public school district on Google Workspace for Education — console paths, per-OU values, rollout order, and incident procedures.

11

control documents

7

incident playbooks

15

audit scripts

86

cited sources

Contents

00	Executive summary
01	Threat landscape
02	Gmail
03	Calendar
04	Drive & Docs
05	Groups
06	Other services
07	Accounts, MFA & admins
08	OAuth & app control
09	Monitoring & response
10	SPF, DKIM & DMARC
11	Rollout phases
12	Playbooks
13	Playbook 01 · Compromised staff account
14	Playbook 02 · Compromised student account
15	Playbook 03 · Post-delivery phish purge
16	Playbook 04 · Payroll diversion
17	Playbook 05 · Vendor invoice fraud
18	Playbook 06 · Mass calendar spam
19	Playbook 07 · Lookalike domain

20	GAM audit scripts
21	GAM remediation scripts
22	Communication templates
23	District profile
24	Assumptions

Email Security: What We're Changing and Why

For: Superintendent and Cabinet · From: Technology Department · Date: 2026-08-20

The situation

Criminals target school districts because we are large, public, and predictable. Our leadership names, titles, and email addresses are published on our own website. That is all someone needs to start.

Four things are happening to districts like ours right now:

Someone pretends to be a district leader. An email arrives with the superintendent's or a principal's name on it, asking a staff member to buy gift cards, approve a payment, or "handle something quickly and quietly." AI writing tools have removed the spelling mistakes that used to give these away.

Someone redirects a paycheck. A staff member is tricked into giving up their password. A few days later their direct deposit is quietly changed to a criminal's account. Nobody finds out until payday.

Someone poses as a vendor we already work with. A real vendor's email account is broken into. The criminal replies inside a real invoice conversation and changes the payment details. Everything looks legitimate because almost all of it is. **This is the most expensive category in K-12 — losses typically run into six figures.**

Someone steals a password even though we use a security code. New attack tools sit invisibly between the user and the real sign-in page. The user enters their password, enters their code, and everything works normally — but the criminal captures the session and walks in behind them.

Nationally, **82% of reporting school districts experienced a cyber incident** over an 18-month period. In the first half of this year alone there were **34 ransomware attacks** against American schools and colleges. Nearly all of it starts with email.

What we're doing about it

Stronger filtering on incoming mail. Messages impersonating a district leader are held for review rather than delivered. Risky attachments are opened in an isolated environment first. This is the single most effective change we're making, and staff will barely notice it.

Locking down our mass email lists. Today, one message can reach every employee at once. We're limiting who can send to district-wide lists, so a fake message from "the superintendent" reaches a handful of people instead of everyone.

A second step at sign-in for all staff. A password alone will no longer be enough.

Physical security keys for about thirty people — payroll, HR, finance, and technology administrators. These are the accounts that can move money or change everything, and a physical key is the only method that defeats the attack described above. **Cost: roughly \$1,500–3,000, one time.**

Approval before apps can connect to district accounts. A common trick is a fake app that asks for permission to read your email. Once granted, it keeps reading even after you change your password. We'll approve apps centrally, with a **10-school-day turnaround** for teacher requests.

Proving our own email is genuinely ours. We're publishing internet records so that messages faking our domain are rejected before they arrive anywhere. **This takes about three months and must be done carefully** — rushing it would stop legitimate messages to parents.

Tighter settings on student accounts. Outside adults will not be able to send files to students or chat with them through school accounts.

Knowing quickly when something gets through. Alerts routed to a monitored address, and the ability to remove a bad message from every inbox in the district within minutes.

What it costs users

CHANGE	WHAT PEOPLE NOTICE
Stronger filtering	Occasionally an expected attachment is delayed. Call the help desk
Second sign-in step	About three minutes to set up. A quick check at sign-in
Security keys (~30 staff)	A physical key on the keyring for finance and IT staff
App approval	Teachers request new apps instead of connecting them directly
Student restrictions	Students ask a teacher to share work outside the district
Email authentication	Nothing, if we do it correctly

Our commitment: if any of this interferes with teaching, we roll it back the same day and find another way. That rule is written into the plan.

What it prevents

- A fake message from a district leader reaching every employee at once
- A staff paycheck being redirected without anyone noticing for a full pay cycle
- A six-figure payment sent to a criminal in a real vendor conversation
- A stolen password becoming access to student records and payroll
- A break-in continuing after we thought we had fixed it
- Outside adults contacting students through school-issued accounts

What this does not fix

We want to be straight about this rather than overstate it.

Three risks stay significant even after everything above, because no email setting can close them:

- 1. **Vendor invoice fraud.** When a real vendor's account is broken into, the message is genuinely from them. **The only reliable protection is a phone call to a number we had on file before the request.** That is a finance procedure, not a technology setting, and it needs the CFO's sign-off.
- 1. **QR codes.** A code on a flyer in a staff lounge never touches our email system at all. That is awareness, not configuration.
- 1. **Scams aimed at students directly** — particularly threats to share private images. These happen on apps we do not control, on personal phones, after hours. **What we can control is whether a frightened student believes they can tell an adult without getting in trouble.** That is a counseling and culture question, and it matters more than anything in this document.

Also outside this plan and needed separately: computer security software, network separation, and **tested offline backups** — the last of which is the only thing that reliably survives a ransomware attack.

What we need

- 1. **Endorsement of the plan**, so the technology department is not negotiating each change individually.
- 2. **Approval to purchase security keys** — roughly \$1,500–3,000, one time.
- 3. **A finance procedure requiring a phone callback** before any banking change, for payroll or vendors. **This single procedure prevents the most expensive incidents in this document, and it costs nothing.**
- 4. **Explicit permission for staff to slow down and verify** — including when the request appears to come from a district leader. This needs to be said out loud, by the superintendent, in writing. A payroll clerk who fears being criticized for questioning the superintendent will process the fraudulent change.
- 5. **Two 90-minute tabletop exercises per year** with the cabinet. Not technical — decisions. Who notifies parents, who talks to the press, when the board is told. Those are the questions that go badly in a real incident and they are free to practice.

Timeline

WHEN	WHAT	IMPACT
Weeks 1–2	Baseline, no changes	None
Weeks 3–5	Filtering, mass lists, admin accounts	Minimal — most of the benefit
Months 2–3	Second sign-in step, app approval	Noticeable, supported
Months 3–6	Email authentication	None if done carefully
Months 6–7	Student settings	Moderate, coordinated with instruction
Ongoing	Monitoring, training, exercises	—

The first month delivers most of the protection. Everything after that is either politically harder or technically slower, but the largest gains come early — and they start as soon as we have your endorsement.

Detail, sources, and step-by-step procedures: [this repository](#). Questions: [Technology Director](#).

00 — Threat Landscape: What Is Actually Hitting K-12 Right Now

Research date 2026-08-20. Every threat below maps to the specific controls in this repo that mitigate it. If a threat has no control, that is stated plainly rather than papered over.

Why the K-12 threat model is its own thing

Three structural facts make districts different from a same-sized business:

1. **The org chart is public.** Superintendent, principals, CFO, board members, their titles, their photos, often their direct email — all published on the district site by law or by convention. Attackers do not need reconnaissance; they need a browser.
2. **Guardians are external users who must stay reachable.** A business can block or heavily restrict external mail and sharing. A district cannot — that is the parent communication channel. Every control here is shaped by that constraint.
3. **Minors are account holders.** Students are targets for categories (sextortion, grooming, scholarship fraud) that have no enterprise analogue, and student accounts are a lateral-movement path into staff mailboxes.

Baseline volume: **82% of reporting K-12 organizations experienced cyber threat impacts** between July 2023 and December 2024, across more than 8,100 confirmed incidents ([CIS/MS-ISAC K-12 report, via K12 SIX](#)). In the first half of 2026 there were **34 ransomware attacks** against US K-12 and higher-ed institutions ([Sedara, 2026](#)).

T1 — AI-written leadership impersonation (gift card / wire / "are you at your desk")

How it runs. Attacker scrapes the district website for the superintendent's or a principal's name, title, and writing style, then sends from a free webmail account with the *display name* set to that person. Opening line is low-commitment — "Are you at your desk?", "I need a quick favor, I'm in a board meeting" — to elicit a reply before any ask. The ask follows: gift cards, a wire, a "confidential" purchase. Generative AI removed the grammatical tells that used to make these obvious, and lets the attacker match tone from published newsletters and board minutes.

Why it beats filters. There is no spoofed domain to catch. `principal.name@gmail.com` is a real, authenticated Gmail account that passes SPF, DKIM, and DMARC perfectly. The only anomaly is the display name.

Controls:

- **Protect against spoofing of employee names** → `Quarantine` for staff. The single highest-value setting in this repo — [docs/01-gmail.md §3](#)
- Display-name content compliance rule for cabinet/principal roles — [docs/01-gmail.md §7](#)
- Keyword tripwires: "gift card", "wire transfer", "are you at your desk" from external senders — [docs/01-gmail.md §7](#)
- Groups locked so one message can't reach all staff — [docs/04-groups.md](#)
- Out-of-band verification procedure — [playbooks/04-payroll-diversion-attempt.md](#)

T2 — Payroll / direct-deposit diversion

How it runs. Staff member receives a spoofed HR or self-service-portal message: "annual direct deposit verification", "your payroll profile needs re-confirmation". Credentials are harvested, the attacker signs into the SIS/ERP employee portal and changes the deposit routing number, usually to a prepaid debit account. Discovery happens on payday — one full cycle later. Frequently the mailbox is also configured with a filter that auto-archives anything containing "direct deposit" so the confirmation email is never seen.

Attackers move from stolen credentials to payroll changes as a routine escalation path ([SENKI payroll diversion analysis](#)).

Controls:

- Phishing-resistant 2SV (passkey/security key) required for Finance-HR — [docs/06-accounts-mfa-admins.md](#) §3
- "direct deposit" / "routing number" keyword tripwire — [docs/01-gmail.md](#) §7
- External forwarding disabled for Finance-HR — [docs/01-gmail.md](#) §5
- Filter/forwarding/delegate audit — `[audit/gam/02-forwarding-and-filters.sh]()`
- **Non-Workspace control that matters more than any of the above:** the payroll system must require out-of-band verification for any banking change. Documented as a hand-off in [playbooks/04-payroll-diversion-attempt.md](#).

T3 — Vendor email compromise / invoice fraud

How it runs. A real vendor's mailbox is compromised. The attacker reads the existing thread with district AP, then replies in **that thread** with updated remittance details. Everything authenticates because it genuinely is the vendor's account. This is the highest per-incident loss category in K-12 — phishing against accounts-payable staff has produced some of the largest direct financial losses districts have experienced ([K-12 Cybersecurity Resource Center](#)).

Why most controls fail here. SPF/DKIM/DMARC all pass. Display name is correct. Domain is correct. Thread history is real. **No email authentication control detects this.**

Controls:

- Banking-change keyword tripwire on external mail — [docs/01-gmail.md](#) §7
 - Finance-HR OU with tighter everything — [docs/01-gmail.md](#), [docs/06](#)
 - **Primary mitigation is a business process, not a setting:** callback verification to a vendor phone number *on file from before the request*, never a number in the email — [playbooks/05-vendor-invoice-fraud.md](#)
-

T4 — Credential phishing with AiTM proxy kits (MFA-defeating)

How it runs. Kits like **Tycoon 2FA** run a reverse proxy between the victim and the real Google sign-in page. The victim sees a genuine Google login (because it is one, proxied), enters a password, completes the 2SV challenge — and the kit captures the resulting **session cookie**. The attacker replays the cookie and is inside the account without ever needing the password or a second factor again.

Tycoon 2FA at peak accounted for roughly **62% of phishing attempts blocked by Microsoft**, reaching over 500,000 organizations monthly. A March 2026 takedown led by Microsoft and Europol seized 300+ domains, **but operators adapted and the technique persists** ([Group-IB](#), [Bridewell](#)). Google's own June 2026 advisory lists AiTM first among current threats ([Google](#)).

The load-bearing fact for this entire package: *SMS, TOTP, and push MFA are all proxyable. FIDO2 security keys and passkeys are the only methods immune to AiTM session theft* ([Proofpoint](#)). This is why docs/06 treats "we have MFA" as insufficient for admins and finance, and why "2SV enforced" is a Phase 2 milestone rather than the finish line.

Controls:

- Phishing-resistant 2SV for super admins, Finance-HR, payroll-touching roles — [docs/06-accounts-mfa-admins.md](#) §3
- Advanced Protection Program for super admins — [docs/06](#) §4
- Shorter session length for admins/finance (shrinks stolen-cookie value) — [docs/06](#) §7
- Context-Aware Access on Admin console — [docs/06](#) §8 **[Plus]**
- Link warning for untrusted domains — [docs/01-gmail.md](#) §4
- "Suspicious login" and "Leaked password" alerts — [docs/08](#) §2
- Token revocation is mandatory in compromise response — a password reset alone does **not** invalidate a stolen session — [playbooks/01-compromised-staff-account.md](#)

T5 — QR-code phishing (quishing), including physical flyers

How it runs. The malicious URL is rendered as an image, so URL-based filtering has nothing to scan. The victim scans with a **personal phone** — off the district network, outside district DNS filtering, off any managed browser policy. Physical variants exist: QR flyers taped in staff lounges, on parking notices, or over legitimate codes on book-fair and fundraiser posters.

Quishing rose 146% in Q1 2026, with ~18.7 million incidents in March alone; 12–12.4% of all phishing now uses image-based payloads. Small and midsize organizations — the district size band — see **up to 19× more QR attacks** than large enterprises ([Acronis](#), [AP via Watauga Democrat](#)).

Controls (partial — be honest about this one):

- **Scan linked images** [On](#) — [docs/01-gmail.md](#) §4
- Phishing-resistant 2SV makes a harvested credential far less useful — [docs/06](#) §3
- **No Workspace setting mitigates a QR code taped to a wall.** That is training and physical-space awareness — [checklists/rollout-phases.md](#) "Ongoing", plus the reporting culture in [docs/08](#) §7.

T6 — Calendar-invite phishing

How it runs. Attacker sends a Google Calendar invitation with a malicious link in the event body or location field. Historically Calendar **auto-added invitations from anyone**, so the malicious event appeared on the victim's calendar without any click — complete with a notification and a reminder. A variant *Cancels* the event, because cancellation notices also carry attacker-supplied text. Check Point observed one campaign hitting **300 brands with 4,000+ emails in four weeks**; the invites passed **DKIM, SPF, and DMARC** because they genuinely originated from Google ([BleepingComputer](#)). Google's June 2026 advisory documents fake renewal notices delivered directly as Calendar invites ([Google](#)).

What changed, and it is recent. On 2026-08-14 Google began rolling out admin-level control over invitation handling, settable per OU or group. It **defaults to "From everyone"** — the permissive behavior — so this does nothing until a district changes it ([Workspace Updates, 2026-08-14](#)).

Controls:

- Invitation control set to known-senders at admin level — [docs/02-calendar.md §2](#)
- External sharing limited to free/busy — [docs/02-calendar.md §3](#)
- Bulk cleanup of already-delivered calendar spam — [playbooks/06-mass-calendar-spam-cleanup.md](#)

T7 — Abuse of legitimate Google services to pass authentication

How it runs. The lure is hosted *on Google*. Google Forms, Google Drawings, Google Sites, Drive share notifications, Google Groups invitations, Google Tasks. The notification email is genuinely from Google, authenticates cleanly, and comes from trusted Google infrastructure — so domain reputation, SPF, DKIM, and DMARC are all working exactly as designed and all of them say "legitimate."

Documented chains: Calendar invite → Google Forms or Drawings → fake reCAPTCHA/support button → credential harvest ([Abnormal](#)). A late-2025 campaign abused **Google Tasks** to generate authentic Google notification emails that bypassed email security entirely ([Optery](#)). Google's June 2026 advisory names "reputation bypass" — hosting payloads on trusted cloud properties — as a current tactic, alongside ClickFix lures served from Google Sites.

Why this is structurally hard. You cannot block Google notifications inside Google Workspace without breaking Workspace. The mitigation is to shrink the *services* that can be abused and to catch the *destination*, not the sender.

Controls:

- Turn OFF unused Google services per OU — the service-hygiene sweep. AppSheet is the standard example: if the district doesn't use it, it is pure attack surface — [docs/05-other-services.md §7](#)
- Link warning for untrusted domains — [docs/01-gmail.md §4](#)
- Drive share-notification handling and external Drive warnings — [docs/03-drive.md](#)
- Calendar invitation control — [docs/02-calendar.md §2](#)
- Groups locked against external posting — [docs/04-groups.md](#)
- Post-delivery purge when one lands — [playbooks/03-post-delivery-phish-purge.md](#)

[**VERIFY**] — I did not find current reporting specifically documenting AppSheet abuse in phishing chains, despite it being named in the source brief. It is recommended here on **attack-surface-reduction grounds** (an unused service with data access and app-publishing capability), not because a campaign is documented. Do not cite an AppSheet campaign to leadership; cite the general reputation-bypass pattern instead.

T8 — Compromised trusted-partner accounts

How it runs. Another district, an ed-tech vendor, a state agency, a regional consortium — a mailbox there is compromised, and the phish arrives from a real, trusted, fully-authenticating account, often into an established thread. Districts trust each other by convention; a message from a neighboring district's technology director carries enormous implicit credibility.

Why authentication controls do nothing. SPF, DKIM, and DMARC all pass. They are supposed to. The sender is who they claim to be — they are just not in control of the account.

Controls:

- Security sandbox detonates attachments regardless of sender reputation — [docs/01-gmail.md](#) §6 [Standard/Plus]
 - Link warning for untrusted domains — [docs/01-gmail.md](#) §4
 - **The anti-control:** allowlisting partner districts or vendors to "stop the false positives" converts this from survivable to catastrophic. Explicitly forbidden — [docs/01-gmail.md](#) §8
 - Post-delivery purge — [playbooks/03-post-delivery-phish-purge.md](#)
-

T9 — Student account takeover and student-to-student phishing

How it runs. Two distinct patterns. **External:** a student credential is phished (often via a game, "free V-Bucks", or a fake Classroom notification) and the account becomes a foothold *inside* the domain — internal mail from a real student account bypasses every external-sender control the district has. **Internal:** students phish each other directly, for social reasons (impersonation, harassment) or to reach a teacher account and alter grades.

The internal case is under-modeled in most districts: every "external sender" warning, every content-compliance rule scoped to external mail, and the entire DMARC apparatus is blind to a message from one real student to another.

Controls:

- Student external forwarding and POP/IMAP off — [docs/01-gmail.md](#) §5
- Student Chat restricted to internal — [docs/05-other-services.md](#) §2
- Classroom membership restricted to domain — [docs/05](#) §4
- Self-service password recovery **disabled** for students (admin-mediated resets) — [docs/06-accounts-mfa-admins.md](#) §9
- Takeout off for students — [docs/05](#) §6

- Student Drive sharing domain-restricted — [docs/03-drive.md](#)
 - [playbooks/02-compromised-student-account.md](#)
-

T10 — Scams targeting students directly: sextortion and scholarship fraud

How it runs. Financially-motivated sextortion is the acute one. NCMEC received more than 50,000 reports in 2025 — ~137 per day, up from 36,000 in 2024. The FBI and NCAA issued a joint warning for student-athletes, who face compounded pressure from scholarship and sponsorship exposure. Critically, **complying with demands does not stop distribution — it reliably produces more demands** ([FBI](#), [IC3 PSA 260810](#)).

Scholarship and student-aid fraud: FinCEN issued alert **FIN-2026-Alert004 (2026-07-24)** on fraud rings using stolen identities to enroll and extract federal student aid ([FinCEN](#)). This lands on graduating seniors and their families.

Controls — and the honest limit. Almost none of this is a Workspace setting. Most sextortion contact happens on platforms the district does not control (Instagram, Discord, Snapchat, gaming voice chat), on personal devices, after hours.

What the district *can* do:

- Student Chat external off, Meet join controls — [docs/05 §2–3](#)
- A reporting path a 15-year-old will actually use — this is the control that matters. Reporting to [<ABUSE_ALIAS>](#) must be non-punitive and must not require telling a parent first. Documented in [docs/08 §7](#).
- Counselor and SRO escalation path, and the national reporting routes ([ncii.ic3.gov](#), [tips.fbi.gov](#), 1-800-CALL-FBI) — belongs in student services procedure, referenced from [docs/08 §7](#).

This is a student-safety issue that happens to touch IT. Do not let it sit only with IT.

T11 — Ransomware / data extortion, with phishing as initial access

How it runs. Phishing is the front door; the damage is everything after it. Credential theft → mailbox access → lateral movement → data staging → encryption and/or extortion publication. Ed-tech vendor breaches provide a parallel path: the district's student data is exfiltrated from a *vendor's* environment, and the district still owns the notification obligation and the reputational damage.

34 ransomware attacks hit US K-12 and higher-ed in the first half of 2026 alone ([Sedara](#)).

Controls in this package (initial access only): everything in T1–T9 — this package narrows the front door.

Where this package hands off — and these are not optional:

- Endpoint detection and response
- Network segmentation, especially SIS/finance away from instructional VLANs
- **Offline, tested, immutable backups** — the only control that reliably beats encryption
- Ed-tech vendor risk review and data processing agreements

- Cyber insurance requirements and their control preconditions
- Incident response retainer and district legal/comms plan
- Emergency operations planning integration — CISA and the Department of Education now treat K-12 cyber as part of EOP, not an IT-only concern ([CISA K-12 toolkit](#))

Response controls that are here: Vault retention supporting IR, BigQuery log export for long-retention forensics, investigation tool workflows — [docs/08-monitoring-response.md](#).

T12 — MFA fatigue and deepfake voice/video of leadership

MFA fatigue (push bombing): attacker with a valid password triggers repeated push prompts until the user approves one to make it stop. **Mitigated structurally** by phishing-resistant methods — a passkey has nothing to approve out of context ([docs/06 §3](#)). If the district uses push-based 2SV anywhere, this is live.

Deepfake voice/video: synthesized audio of the superintendent calling a finance staffer, or a video-call presence in a "quick approval" meeting. Google's June 2026 advisory documents adjacent "digital arrest" video-call fraud where attackers impersonate officials over live video ([Google](#)).

Controls — this one is almost entirely non-technical. No Workspace setting detects a synthesized voice.

- Meet join controls limit who reaches a district meeting — [docs/05 §3](#)
 - **The actual mitigation is a procedural rule:** financial authorization never completes on voice or video alone. A pre-agreed callback to a known number, or in-person confirmation, is required for any funds movement or banking change regardless of how convincing the requester is — [playbooks/04-payroll-diversion-attempt.md](#), [playbooks/05-vendor-invoice-fraud.md](#)
 - Tell staff explicitly that leadership will **never** ask for gift cards, wires, or banking changes by phone, video, or email. A pre-authorized "it's okay to say no to the superintendent" is a security control — [comms/]()
-

Coverage matrix

#	THREAT	PRIMARY CONTROL	DOC	RESIDUAL RISK
T1	Leadership impersonation	Employee-name spoofing → Quarantine	<u>01</u>	Low
T2	Payroll diversion	Phishing-resistant 2SV + keyword tripwire	<u>06</u> , <u>01</u>	Med — needs payroll process change
T3	Vendor invoice fraud	Keyword tripwire only	<u>01</u>	High — process control required
T4	AiTM credential phishing	Passkeys/security keys + APP	<u>06</u>	Low if phishing-resistant; High if OTP
T5	QR-code phishing	Scan linked images + 2SV	<u>01</u>	High — physical vector uncontrolled
T6	Calendar-invite phishing	2026-08-14 invitation control	<u>02</u>	Low once enforced
T7	Google-service abuse	Service hygiene + link warnings	<u>05</u>	Med — structural
T8	Trusted-partner compromise	Sandbox + link warnings	<u>01</u>	High — authenticates cleanly
T9	Student ATO / internal phish	Student OU restrictions	<u>01</u> , <u>05</u>	Med — internal mail unfiltered
T10	Sextortion / scholarship scams	Reporting path + Chat limits	<u>08</u>	High — mostly off-platform
T11	Ransomware initial access	All of T1–T9	all	Med — hands off to EDR/backup
T12	MFA fatigue / deepfakes	Passkeys + procedural rules	<u>06</u>	Med — procedure-dependent

Read the residual-risk column honestly. Four threats stay High after every control in this repo is applied. Three of those four (T3, T5, T10) are only closable by process and training, not configuration. Presenting this package to the cabinet as "we fixed phishing" would be false; presenting it as "we closed the configurable gaps and here are the three that need people" is accurate — see [docs/10-exec-summary.md](#).

01 — Gmail

The core document. Research date 2026-08-20.

All Gmail settings live under `Admin console > Apps > Google Workspace > Gmail` and require the **Gmail Settings** administrator privilege ([source](#)).

Read §8 before you touch anything else. It is the rule that prevents the most common self-inflicted K-12 email security failure.

1. Order of operations

Do these in order. §2–4 are no-user-impact and can ship the same day. §7 needs comms.

STEP	SECTION	USER IMPACT	PHASE
1	Turn on all Safety protections at default action	None (warnings only)	0
2	Escalate spoofing/auth to Quarantine (§3)	Quarantine review workload begins	1
3	Escalate attachments to Quarantine (§2)	Some legitimate attachments delayed	1
4	Links & images (§4)	Click-through warning appears	1
5	Security sandbox (§6)	Delivery delay on attachments	1
6	Quarantine operations stood up (§9)	Requires named reviewers + SLA	1
7	End-user access lockdown (§5)	Breaks POP/IMAP clients — check first	1–4
8	Content compliance rules (§7)	Banners appear on external mail	1

Do not enable quarantine actions before §9 exists. A quarantine nobody reviews is a mail outage with extra steps.

2. Safety — Attachments

Path: `Admin console > Apps > Google Workspace > Gmail > Safety > Attachments` **Edition:** All, including [Fundamentals] **Available actions:** `Keep in inbox + warning` (default) · `Move to spam` · `Quarantine` ([source](#))

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Protect against encrypted attachments from untrusted senders	Gmail > Safety > Attachments	Quarantine	Quarantine	Quarantine	Quarantine	All	Password-protected ZIPs held. Legitimate use is rare and almost always a vendor sending student data badly — which is its own problem	ref
Protect against attachment with scripts from untrusted senders	Gmail > Safety > Attachments	Quarantine	Quarantine	Quarantine	Quarantine	All	<code>.js</code> , <code>.vbs</code> , macro-bearing files held. No legitimate K-12 inbound use case	same
Protect against anomalous attachment types in emails	Gmail > Safety > Attachments	Quarantine	Quarantine	Quarantine	Keep in inbox + warning	All	Uncommon extensions held. Admins set to warning so IT can still receive vendor diagnostic files without a self-inflicted quarantine loop	same
Apply future recommended settings automatically	Gmail > Safety > Attachments	On	On	On	On	All	Google enables new attachment protections as shipped. Accepts a small change-management risk in exchange for not falling behind	same

Allowlisting file types. The console permits allowlisting uncommon extensions (entered without periods, comma-separated). Use this only for a **specific extension a specific business system needs** — e.g. a `.dat` export from the SIS. Never allowlist an extension to silence a category of alerts.

Impact + comms: Staff will occasionally find an expected attachment missing. The comms line is "attachments can now be held for review — if you're expecting one and it doesn't arrive, contact the help desk, don't ask the sender to resend it another way." That last clause matters: the natural workaround is a personal Gmail address, which is worse.

Rollback: Immediate. Change action back to `Keep in inbox + warning`. Already-quarantined messages remain in quarantine and must be released manually — rollback does not auto-release.

3. Safety — Spoofing & authentication

This section contains the single highest-value control in this repo.

Path: `Admin console > Apps > Google Workspace > Gmail > Safety > Spoofing and authentication` **Edition:** All, including [Fundamentals] **Available actions:** `Keep in inbox + warning (default) · Move to spam · Quarantine`
([source](#))

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Protect against spoofing of employee names	Gmail > Safety > Spoofing and authentication	Quarantine	Quarantine	Quarantine	Quarantine	All	The superintendent-impersonation killer. Catches Jane Superintendent <random@gmail1.com> — display name matches a directory user, sender doesn't. Expect a small volume of legitimate hits from staff mailing from personal accounts; that behavior should stop anyway	ref
Protect against inbound emails spoofing your domain	same	Quarantine	Quarantine	Quarantine	Quarantine	All	Inbound mail claiming to be <PRIMARY_DOMAIN> that isn't. Blast radius warning: this is the one that catches misconfigured SIS/copier/relay senders — see the flag below	same
Protect Groups from inbound emails spoofing your domain	same	Quarantine	Quarantine	Quarantine	Quarantine	All	Same protection applied to Groups, which the per-user setting does not cover. Set scope to all groups, not private-only. Frequently missed; a spoofed message to all-staff@ is the worst-case delivery	same
Protect against domain spoofing based on similar domain names	same	Quarantine	Quarantine	Quarantine	Quarantine	All	Catches lookalike domains (in for m, .net for .org, added hyphens). Pairs with playbooks/07	same

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Protect against any unauthenticated emails	same	Keep in inbox + warning	Move to spam	Keep in inbox + warning	Keep in inbox + warning	All	Deliberately not quarantined for staff. Small vendors, PTA/booster lists, individual parents on niche providers, and youth-sports organizers routinely send unauthenticated mail. Quarantining this for staff generates enormous review volume and buries real detections	same
Apply future recommended settings automatically	same	On	On	On	On	All	Future spoofing protections auto-enable	same

⚠ Blast radius: "inbound emails spoofing your domain"

Flag this before it enters a rollout phase. This setting quarantines anything claiming to be from `<PRIMARY_DOMAIN>` that does not authenticate as such. That includes:

- Copier / MFP **scan-to-email** sending as the walk-up user's address
- SIS notifications sending as `noreply@<PRIMARY_DOMAIN>`
- SMTP relay users — alarm panels, HVAC, bell systems, scripts
- Any third-party product configured with a district From: address but no DKIM

Sequence it correctly: run §11's inventory and docs/09-dmarc-spf-dkim.md §2 *first*, confirm each sender is authenticating, then escalate this setting. If you escalate first you will find out which systems were misconfigured by way of the help desk queue.

Legitimate senders are fixed by making them authenticate (SPF include + DKIM), **not by allowlisting them** (§8).

Why employee-name spoofing is the highest-value setting

T1 in docs/00-threat-landscape.md has no other technical control. The attacker's account is real, the domain is real, SPF/DKIM/DMARC all pass legitimately. The *only* anomaly available to a filter is that the display name matches a person in your directory while the address does not. This setting is the only thing in Workspace that looks at that.

Rollback: Immediate, per-setting. Note that quarantined mail stays quarantined.

4. Safety — Links & external images

Path: Admin console > Apps > Google Workspace > Gmail > Safety > Links and external images **Edition:** All, including [Fundamentals] **These are toggles — there is no quarantine action available in this section** ([source](#)).

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Identify links behind shortened URLs	Gmail > Safety > Links and external images	On	On	On	On	All	bit.ly-style links resolved and scanned. No visible impact	ref
Scan linked images	same	On	On	On	On	All	Images fetched and scanned. Partial QR-code mitigation (T5) — a scanned image can be assessed, though a code photographed off a wall never touches Gmail	same
Show warning prompt for any click on links to untrusted domains	same	On	On	On	On	All	Interstitial warning on click. Does not work in IMAP/POP clients — which is an independent argument for §5	same
Apply future recommended settings automatically	same	On	On	On	On	All	—	same

The IMAP/POP interaction is the point. This protection is unavailable to users on third-party mail clients. Every staff member left on Outlook-via-IMAP is a user for whom this control silently does not exist. §5 and this section reinforce each other.

Impact + comms: Users see an "are you sure?" page on some links. Low friction, high recognition value. Comms line: "if you see this warning, it means the destination isn't one we recognize — that's your cue to slow down, not to click through faster."

Rollback: Immediate toggle.

5. End-user access

Path: [Admin console](#) > [Apps](#) > [Google Workspace](#) > [Gmail](#) > [End User Access](#) ([source](#))

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
POP and IMAP access	Gmail > End User Access > POP and IMAP access	Off (<i>see note</i>)	Off	Off	Off	All	Removes the blind spot where link warnings don't apply. Check for legitimate users first — see below	ref
Automatic forwarding	Gmail > End User Access > Automatic forwarding	Off	Off	Off	Off	All	On by default. Off removes the forwarding option from Gmail settings entirely. The #1 attacker persistence mechanism — survives a password reset	ref
Comprehensive mail storage	Gmail > End User Access > Comprehensive mail storage	On	On	On	On	All	Ensures all messages land in Gmail mailboxes, including SMTP-relay and non-Gmail-mailbox traffic. Required for the investigation tool and Vault to see everything — without it, IR has gaps	ref
Warn for external recipients	Gmail > End User Access > Warn for external recipients	On	On	On	On	All	Warns when composing to an external address. Reduces accidental student-data disclosure; costs nothing	ref

Automatic forwarding — why this is not optional

When an account is compromised, the attacker's first move is persistence. A forwarding rule to an external address survives the password reset, survives the "we've secured the account" email, and keeps delivering the CFO's mail for months. Turning the feature off at the OU level means it cannot be set.

If the district cannot turn forwarding off for all staff, the **minimum** is Finance-HR and Students, and the fallback is Gmail's setting to restrict automatic forwarding to a list of approved domains rather than allowing arbitrary external addresses. Either way, [audit/gam/02-forwarding-and-filters.sh]() runs monthly regardless — the setting prevents *new* rules; it does not remove existing ones.

⚠ **Blast radius: POP/IMAP**

Before turning POP/IMAP off, run [audit/gam/README.md](#) → the IMAP usage check, and look for:

- Staff using Outlook or Apple Mail against Gmail (common with long-tenured staff)
- **Copier / MFP scan-to-email** configured with an SMTP account
- Legacy scripts and applications polling a mailbox via IMAP
- Alarm/HVAC/bell systems with a mailbox
- Third-party archiving or e-signature tools reading a shared mailbox

Recommended sequencing: Students off first (Phase 4 — near-zero legitimate use), then Finance-HR, then general staff last with a 30-day notice and a migration path to the Gmail web/mobile client. **Service accounts get their own OU with POP/IMAP left on**, scoped to exactly the accounts that need it, rather than leaving it on district-wide.

Impact + comms: Real. This is the setting most likely to generate tickets. Template in [comms/]().

Rollback: Immediate per-OU toggle. Client reconfiguration is not needed on rollback.

6. Security sandbox

Path: [Admin console > Apps > Google Workspace > Gmail > Spam, Phishing and Malware](#) → scroll to **Security sandbox / Security sandbox rules** ([source](#))

Attachments are detonated in an isolated VM to catch malware that signature-based scanning misses — including zero-day and targeted payloads. This is the control that helps against **T8 (compromised trusted partner)**, where the sender's reputation is genuinely good.

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Enable virtual execution of attachments in a sandbox	Gmail > Spam, Phishing and Malware > Security sandbox	On	On	On	On	[Standard]/[PI us]	Delivery delay of up to a few minutes on attachment-bearing mail	ref
Security sandbox rules	same section > Security sandbox rules > Configure	See below	—	See below	—	[Standard]/[PI us]	Scopes sandboxing to specific senders/recipients rather than everything	ref

Deployment recommendation: enable **blanket sandboxing** (leave "Enable virtual execution of attachments in a sandbox" checked) rather than rule-scoping. Rule-scoping exists to manage delivery latency; in a district the latency is acceptable and the coverage gap is not. If latency complaints arrive from a specific workflow, *then* clear

the blanket checkbox and write rules — attachments are sandboxed only if they match a rule once the blanket box is cleared, so **clearing it without writing rules disables sandboxing entirely**. That is an easy and silent mistake.

If you do rule-scope, prioritize: Finance-HR (all inbound), the superintendent's office, and anything inbound from outside `<PRIMARY_DOMAIN>` bearing Office documents.

[VERIFY] — edition eligibility. Google's Education edition comparison lists "Malware detection in email attachments (Security Sandbox)" under **Education Standard** ([source](#)), but the Security Sandbox article's own supported-editions list enumerates Frontline Plus, Business Standard/Plus, and Enterprise Standard/Plus **without naming Education editions explicitly** ([source](#)). These two Google pages disagree. Confirm in your own console before promising it to leadership: if the section is present and configurable, you have it.

[Fundamentals] fallback: none. Fundamentals gets standard attachment scanning plus the \$2 anomalous-attachment controls. If students are on Fundamentals, \$2 at [Quarantine](#) is doing the work.

Impact + comms: A few minutes of delay on attachments. Worth pre-announcing to Finance-HR only; general staff will not notice.

Rollback: Immediate. Uncheck; note the trap above about rules.

7. Content compliance — banners and tripwires

Path: `Admin console > Apps > Google Workspace > Gmail > Compliance > Content compliance` ([source](#))

Rules can reject, quarantine, or **modify** messages before delivery — including prepending body text and adding custom headers ([source](#)).

Rule 7.1 — Cabinet display-name warning banner

The highest-value custom rule. Complements \$3's employee-name protection with a visible, human-readable warning for the near-miss cases.

FIELD	VALUE
Name	<code>EXT – Cabinet display name impersonation warning</code>
Affects	Inbound
Match	Envelope sender is external AND <code>From:</code> header display name matches any cabinet/principal role name
Expression	Metadata match on <code>From</code> header, simple content match, one entry per name
Action	Prepend to message body: a high-contrast warning block
OU	All staff (Students not required — cabinet impersonation targets staff)

Suggested banner text:

⚠ CAUTION — EXTERNAL SENDER USING A DISTRICT LEADER'S NAME
This message came from OUTSIDE <DISTRICT_NAME> but the sender's display name matches a district leader. District leaders will NEVER ask you by email to buy gift cards, send a wire, change banking details, or share your password. Do not reply. Report it: <ABUSE_ALIAS>

PII discipline: the actual name list lives **only in the Admin console rule**. Do not commit it to this repo (see [CLAUDE.md]()). Track *roles* in config/district-profile.md.

Maintenance: this rule goes stale. It must be reviewed when leadership changes — added to the quarterly cadence in checklists/rollout-phases.md.

Rule 7.2 — Financial-request tripwire

FIELD	VALUE
Name	EXT — Financial request tripwire
Affects	Inbound
Match	Envelope sender external AND body/subject contains any of: gift card, giftcard, wire transfer, direct deposit, routing number, ACH change, bank change, update my payment, change my payroll, are you at your desk, are you available
Action — Staff	Prepend warning banner + add custom header X-District-FinTripwire: staff
Action — Finance-HR	Quarantine to a dedicated Finance-Tripwire quarantine
OU	Staff = banner; Finance-HR = quarantine

The split matters. Banner-only for general staff keeps volume manageable and preserves normal business. Quarantine for Finance-HR accepts review workload on the small population where the loss would be six figures.

The custom header is not decoration — it makes these messages findable in the investigation tool and email log search later, which is how you answer "has this campaign hit us before?" during an incident.

Tuning warning: direct deposit and are you available will hit legitimate mail — benefits open enrollment, scheduling. Expect to tune the Finance-HR quarantine over the first two weeks. Start with banner-only everywhere for one week, count the hits, *then* escalate Finance-HR to quarantine with real numbers in hand.

Rule 7.3 — Generic external-sender banner

Optional and **deliberately not recommended as the first move**. A banner on every external message trains staff to ignore banners, which then blunts 7.1 and 7.2. If the district already has one, keep it; if not, ship 7.1 and 7.2 first and evaluate after a term. The narrow banners are the ones people still read.

Impact + comms: Banners are visible on day one. Announce before enabling or the help desk absorbs the confusion. Template in [comms/]().

Rollback: Disable the rule; effect is immediate for new mail. Already-modified messages keep their banner — the body was rewritten at delivery and cannot be un-rewritten.

8. The allowlisting rule — read this one

Never create a broad IP, sender, or domain allowlist that bypasses spam classification.

This is the most common self-inflicted email security failure in K-12. It always starts reasonably: a vendor's legitimate mail lands in spam, the vendor says "just allowlist our IP range", and the district adds it. Six months later that vendor is compromised (T8) and their mail arrives **pre-authorized to skip classification entirely** — the district disabled its own filtering for exactly the sender most likely to be used against it.

Do not use, for the purpose of fixing false positives:

- [Gmail > Spam, Phishing and Malware > Email allowlist](#) (IP allowlist) — this bypasses spam classification, which is precisely the thing you want applied to a trusted partner
- Approved-senders lists scoped to whole domains
- Inbound gateway settings used to mark broad IP ranges as trusted

What to do instead

PROBLEM	CORRECT FIX
Vendor mail lands in spam	Get the vendor to fix SPF/DKIM. Most "we need allowlisting" requests are an unauthenticated sender.
Vendor genuinely can't authenticate	Narrow content compliance rule: specific envelope sender + specific expected subject/header → deliver. Not a classification bypass.
Internal system mail flagged	Authenticate it — docs/09 . This is the real fix and it's usually a 30-minute DNS change.
One-off legitimate quarantined message	Release it from quarantine. That is what quarantine is for.

Narrow exception process

When an exception is genuinely unavoidable:

1. **Written request** naming the business system, the exact sender address (not a domain, not a range), and why authentication cannot be fixed.
2. **Technology Director approval**, recorded.
3. **Narrowest possible scope** — single envelope sender address; add a subject or header match where the traffic is predictable.
4. **Expiry date, maximum 90 days**. No permanent exceptions.
5. **Logged** in an exceptions register with owner and review date.
6. **Quarterly review** — expired entries are removed, not renewed by default. Renewal requires a fresh request.

If an exception has been renewed twice, the answer is to replace the vendor or escalate to the vendor's leadership, not to renew a third time.

9. Admin quarantine operations

Path: [Admin console > Apps > Google Workspace > Gmail > Manage quarantines](#) ([source](#))

A quarantine without an owner and an SLA is an outage. Stand this up *before* setting any action to [Quarantine](#).

Quarantines to create

QUARANTINE	FED BY	REVIEWER	SLA
Spoofing-Auth	§3 spoofing/auth settings	Primary + backup admin	4 business hours
Attachments	§2 attachment settings	Primary + backup admin	4 business hours
Finance-Tripwire	§7.2 Finance-HR rule	Primary admin and Finance Director	2 business hours
Default	anything unrouted	Primary admin	1 business day

Operating rules

- **Two named reviewers minimum**, one primary. Single-reviewer quarantines fail during illness, leave, and summer.
- **Coverage during breaks.** Summer, winter break, and spring break are exactly when BEC campaigns run, precisely because review lapses. Assign explicit coverage or lower the quarantine actions to [Move to spam](#) for the break period — a documented, deliberate downgrade is far better than an unmonitored quarantine.
- **Release ≠ allowlist.** Releasing a message delivers that message. It does not, and must not, create a standing rule (§8).
- **Record every release:** date, message, why. This becomes the evidence base for whether a setting is mis-tuned.
- **Weekly metric:** quarantined count, released count, release rate. A release rate above ~20% for a given quarantine means the setting is mis-tuned — fix the tuning, do not abandon the control.

End-user quarantine access: Google supports giving users visibility into their own quarantined mail ([source](#)). **Not recommended for students.** For staff, consider it only after quarantine volumes are understood — self-release by users defeats the purpose for the exact category (convincing-looking impersonation) the quarantine exists to catch.

10. Hosted S/MIME

Path: [Admin console > Apps > Google Workspace > Gmail > User settings > S/MIME](#) **Edition:** Available for Education Fundamentals, Standard, and Plus ([source](#))

Recommendation: leave it. Hosted S/MIME provides message-level signing and encryption, which is genuinely strong, but it requires certificate issuance and lifecycle management for every participating user, and it only helps between parties who both have it deployed.

For a district, the realistic use case is a handful of Finance-HR or legal-adjacent staff exchanging sensitive material with a specific counterparty who already runs S/MIME. If that counterparty exists, deploy it for those users only. Otherwise the effort buys essentially nothing against the threats in [docs/00-threat-landscape.md](#) — none of T1-T12

is prevented by S/MIME.

Better use of the same effort: confidential mode for sensitive outbound, and docs/03-drive.md DLP for student data. Take-it-or-leave-it, genuinely.

11. Pre-flight inventory

Complete before Phase 1. This is the list that prevents §3's blast radius from landing on the help desk.

- ☐ Every system sending as `<PRIMARY_DOMAIN>` identified — config/district-profile.md
- ☐ Copier / MFP scan-to-email method documented (SMTP relay? user auth? which account?)
- ☐ SMTP relay users enumerated
- ☐ POP/IMAP users enumerated — `[audit/gam/]()`
- ☐ Existing external forwarding rules enumerated — `[audit/gam/02-forwarding-and-filters.sh]()`
- ☐ Existing allowlists and approved-sender lists documented **and justified**, or removed (§8)
- ☐ Existing content compliance rules reviewed for conflicts
- ☐ Quarantine reviewers named, backups named, break coverage assigned (§9)
- ☐ Third-party gateway present? If yes, ASSUMPTIONS.md §A4 applies and inbound gateway config must be verified first

Rollback summary

SECTION	ROLLBACK	SPEED	RESIDUE
§2 Attachments	Reset action to warning	Immediate	Quarantined mail stays quarantined
§3 Spoofing/auth	Reset action to warning	Immediate	Same
§4 Links/images	Toggle off	Immediate	None
§5 POP/IMAP	Toggle on per OU	Immediate	None — clients reconnect
§5 Forwarding	Toggle on per OU	Immediate	Existing rules unaffected either way
§6 Sandbox	Uncheck	Immediate	Trap: clearing the blanket box without rules disables sandboxing
§7 Compliance rules	Disable rule	Immediate for new mail	Delivered banners are permanent
§9 Quarantines	Lower actions first, then delete	Minutes	Release held mail <i>before</i> deleting a quarantine

02 — Calendar

Research date 2026-08-20. All paths under `Admin console > Apps > Google Workspace > Calendar`.

Calendar is a phishing delivery channel that most districts have never configured, because until six days ago the key control did not exist at the admin level.

1. Why Calendar is a delivery channel

A Calendar invitation carries attacker-controlled text and links, arrives with a notification, and — historically — **appeared on the victim's calendar without any user action**. It authenticates perfectly: SPF, DKIM, and DMARC all pass, because the message genuinely originates from Google.

Check Point documented a campaign hitting **300 brands with 4,000+ emails in four weeks** that passed all three authentication checks ([BleepingComputer](#)). Google's own June 2026 fraud advisory lists fake renewal notices delivered directly as Calendar invites among current AiTM tactics ([Google](#)).

Two variants worth knowing:

- **Cancellation abuse.** The attacker cancels the event; the cancellation notice also carries attacker text. Users who "deleted the spam invite" can still receive follow-ups.
- **Chained lures.** Invite → Google Forms or Google Drawings → fake reCAPTCHA or support button → credential harvest. Every hop is on a Google domain ([Abnormal](#)).

Maps to T6 in [docs/00-threat-landscape.md](#).

2. The invitation control — new as of 2026-08-14

This is the fix, it is brand new, and it does nothing until you change it.

Google began rolling out admin-level control over Calendar invitation handling on 2026-08-14, to both Rapid and Scheduled release domains, gradual over up to 15 days, **available to all Google Workspace customers** ([Workspace Updates, 2026-08-14](#)).

Path: `Admin console > Apps > Google Workspace > Calendar > Advanced settings` **Setting:** `Add invitations to Calendar` ([source](#))

The setting has **two independent values** — this is the part that's easy to get wrong:

SUB-SETTING	WHAT IT DOES
Least restrictive level available	The floor. Users cannot choose anything <i>less</i> restrictive than this. This is the enforcement control.
Default value	What users get initially. Users may still move to any option at or above the floor.

Both accept the same three values ([source](#)):

- `Invitations from everyone`
- `Invitations from known senders`
- `Invitations users have responded to via email`

Default out of the box is "From everyone" — the permissive, pre-2026 behavior ([Workspace Updates](#)). Doing nothing leaves the district exactly where it was.

Recommended values

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Add invitations to Calendar — Least restrictive level available	Calendar > Advanced settings	<code>Invitations from known senders</code>	<code>Invitations users have responded to via email</code>	<code>Invitations from known senders</code>	<code>Invitations from known senders</code>	All	Users cannot opt back down to "from everyone"	ref
Add invitations to Calendar — Default value	same	<code>Invitations from known senders</code>	<code>Invitations users have responded to via email</code>	<code>Invitations from known senders</code>	<code>Invitations from known senders</code>	All	Applies without user action	same

Why students get the strictest tier. Students have no legitimate need to receive auto-added invitations from unknown external senders. Requiring an email response first costs a student nothing — teachers and classmates are in-org and unaffected in practice — while removing the vector entirely.

Why staff get "known senders" rather than the strictest. Staff receive genuine external invitations from vendors, regional consortia, state agencies, and PD providers where there has been prior email contact. "Known sender" covers contacts, in-org senders, and **previously interacted-with** senders ([source](#)), which captures nearly all legitimate district use. The strictest tier would generate real friction for staff who schedule externally, and friction produces workarounds.

Behavior notes that will otherwise surprise you

- **Changes apply only to future invitations.** Existing spam already on calendars is not removed. Cleanup is \$5.
- Propagation can take **up to 24 hours**, usually faster ([source](#)).
- Configuration groups override OUs, if you use them.
- **Roll out gradually.** If your tenant hasn't received the feature yet, the setting will not be present. That is expected as of 2026-08-20 — the 15-day window from 2026-08-14 runs to roughly 2026-08-29. If absent, check back rather than concluding it doesn't exist.

Impact + comms: Low. Most users never notice. Staff who *do* schedule externally may see an invitation arrive as email rather than a calendar entry. Comms template in [comms/]() .

Rollback: Immediate. Raise the least-restrictive level back to `Invitations from everyone` . Note that user-level selections made under the stricter policy persist — rolling back the policy does not reset individual choices.

3. External sharing of primary calendars

Path: [Admin console > Apps > Google Workspace > Calendar > Sharing settings](#) → **External sharing options for primary calendars** ([source](#))

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
External sharing options for primary calendars	Calendar > Sharing settings	Only free/busy information (hide event details)	Only free/busy information	Only free/busy information	Only free/busy information	All	External parties see busy/free blocks, never titles, attendees, locations, or descriptions	ref
Internal sharing options for primary calendars	Calendar > Sharing settings	Free/busy + event details (district norm)	Only free/busy	Free/busy + event details	Free/busy + event details	All	Staff scheduling keeps working; students don't broadcast schedules to each other	same

Why free/busy externally is the right call for a district. Calendar event titles leak a startling amount: [IEP meeting – \[student\]](#), [Suspension hearing](#), [Grievance – \[staff\]](#), [Interview – CFO candidate](#). These are FERPA and personnel matters sitting in a field most people never think of as a document. Free/busy removes the exposure entirely while leaving external scheduling functional.

Enforcement is real: once external sharing is limited, users cannot exceed the limit on individual events — a calendar shared out shows only "busy" ([source](#)).

Impact + comms: Moderate for the small number of staff who deliberately share full calendars with external partners. Those cases should move to a **secondary shared calendar** (secondary calendars are governed separately from primary), not to relaxing the primary setting district-wide.

Rollback: Immediate per-OU.

4. External invitation warnings and related settings

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Allow external invitations / warn on external guests	Calendar > Sharing settings > External invitations	On, with warning	On, with warning	On, with warning	On, with warning	All	Users see a warning when an event includes guests outside <PRIMARY_DOMAIN> . Prevents accidental external exposure of internal meetings	ref

Do not turn external invitations off. It would block guardian conferences, vendor meetings, and interagency coordination. Warning is the correct setting; blocking breaks the link.

5. Appointment schedule exposure review

Appointment schedules (booking pages) are a genuine and commonly-missed exposure. A public booking page reveals a staff member's real availability pattern to anyone with the link, and the booking form itself collects a name and email from whoever books.

Review, per term:

- ☐ Which staff have published appointment schedules? Counselors and administrators are the common cases.
- ☐ Are any booking pages linked from the public district website? A booking page for a counselor, publicly linked, is a scheduling channel an outside adult can use to reach a specific staff member — treat that as a student-safety review item, not just an IT one.
- ☐ Do booking forms collect more than name and email? Anything beyond that is data the district is now holding.
- ☐ **Students should not publish appointment schedules.** Confirm the Calendar service configuration for student OUs and disable if available.

[VERIFY] — I could not confirm on 2026-08-20 whether a dedicated admin-console toggle exists to disable appointment schedule creation per OU, separate from turning off Calendar entirely. Check [Calendar > Sharing settings](#) and [Calendar > Advanced settings](#) in your console. If no such toggle exists, this is a policy-and-audit control, not a technical one — treat the term review above as the actual mitigation.

6. Cleaning up calendar spam already delivered

Policy changes apply only to **future** invitations. Anything already on calendars stays there. Full procedure: [playbooks/06-mass-calendar-spam-cleanup.md](#)

Short version:

1. Change the \$2 setting first — stop the inflow before cleaning.
 2. Identify scope via the investigation tool / email log search on the Calendar notification mail.
 3. Users delete via **"Report as spam"** in Calendar rather than plain delete — plain delete may notify the organizer that the address is live.
 4. For widespread cases, GAM-based bulk deletion — `[audit/gam/remediation/]()`.
 5. Confirm the \$2 setting propagated; re-check after 24 hours.
-

7. End-user guidance

Staff can set their own preference at **Calendar > Settings > Event settings > Add invitations to my calendar**, choosing **Only if the sender is known** ([source](#)).

Tell them anyway, even though §2 enforces it. Two reasons: the admin control is rolling out gradually and may not have reached your tenant yet, and users who understand *why* a setting exists report the invites that do get through. The user-facing explanation of "known sender" — in your contacts, in your organization, or someone you've interacted with before — is worth stating plainly, because users assume it means "someone I recognize", which is not the same thing.

Comms template: [comms/]().

Rollback summary

SECTION	ROLLBACK	SPEED	RESIDUE
§2 Invitation control	Raise least-restrictive level	Immediate (≤24h propagation)	User-level selections persist
§3 External sharing	Reset to previous level	Immediate	Previously-shared calendars re-expose details
§4 External invitations	Toggle warning off	Immediate	None
§6 Cleanup	Not reversible	—	Deleted events cannot be restored in bulk

03 — Drive & Docs

Research date 2026-08-20. All paths under `Admin console > Apps > Google Workspace > Drive and Docs`.

Drive matters here for two distinct reasons: **share notifications are a phishing delivery channel** (T7), and **over-broad sharing is how a single compromised account becomes a student-data breach** (T11).

1. The constraint that shapes this whole document

Parents are external users. Staff must be able to share a permission slip, a progress report, or a field-trip form with a guardian's personal Gmail address. **Any Drive policy that blocks staff external sharing breaks the district.**

So: **students are restricted, staff are warned.** That asymmetry runs through every table below and is not an oversight.

2. Sharing settings — the core table

Path: `Admin console > Apps > Google Workspace > Drive and Docs > Sharing settings > Sharing options`
([source](#), [source](#))

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Sharing outside of <PRIMARY_DOMAIN>	Drive and Docs > Sharing settings > Sharing options	On	Off, or allowlisted domains only	On	On	All	Students cannot share to personal Gmail / other districts. Staff↔guardian sharing preserved	ref
Warn when files are shared outside the organization	same	On	On (if sharing enabled)	On	On	All	Staff see a confirmation before external sharing. Cheap, effective, near-zero complaints	ref
Warn when sharing with allowlisted domains	same	On	On	On	On	All	Applies the same friction to allowlisted domains — the district isn't the only one who can be compromised	ref
Allow users to receive files from outside the organization	same	On	Off	On	On	All	Students can't be sent files by arbitrary external accounts. This is a grooming/lure vector, not only a phishing one	ref
Publish files to the web / "anyone with the link" visibility	same	Off	Off	Off	Off	All	Removes public-link publishing. Check for existing public files first — see §3	ref
Default link sharing for new items	same > <i>When users create items, default link sharing is:</i>	Restricted	Restricted	Restricted	Restricted	All	New files are private by default. Highest-value low-friction setting in this doc	ref
Distributing content outside the domain (who can)	same	Staff only	No one	Staff only	Staff only	All	—	ref

Why "Restricted" default link sharing earns its place

The default governs what happens when a user clicks Share and does nothing else thoughtful. With a permissive default, every new document silently becomes reachable by link — and links leak: pasted into Chat, forwarded in email, screenshotted, embedded in a Classroom post that later goes to a different section. Setting the default to **Restricted** means broad access becomes a deliberate act. It changes nothing about existing files and generates almost no tickets.

⚠ Blast radius: student external sharing

Flag before Phase 4. Turning off student external sharing breaks:

- Students sharing work with a **parent's personal address** — common for portfolios, senior projects, college applications
- **Dual-enrollment** students sharing with a community-college account on another domain
- **Scholarship and college application** submissions requiring a shared document
- **Competition and club** submissions (robotics, DECA, science fair, yearbook vendors)
- Students at a **different district domain** in a shared regional program

Recommended instead of a hard Off for high school: allowlisted domains — the community college, the regional consortium, known scholarship platforms. Reserve hard **Off** for elementary and middle. Document the decision per grade band in config/district-profile.md; the table above shows the strict end of the range, and moving off it is a legitimate call, not a failure.

Impact + comms: Real for high school. Announce a term ahead with the exception process.

Rollback: Immediate per-OU. Existing shares are unaffected by the change in either direction — turning sharing off does **not** revoke shares already granted.

3. Before you change anything: find what's already exposed

Do this first. The settings above govern *future* sharing. They do nothing about the document from 2019 that's been "anyone with the link" ever since.

1. **Investigation tool** (`Admin console > Security > Security center > Investigation tool`) → data source **Drive log events** → filter `Visibility = Public` or `Shared externally`. **[Standard]/[Plus]**
2. Sort by document owner OU. Expect concentrations in: former-employee accounts, student-teacher shared folders, and anything created for a since-ended grant program.
3. **Look specifically for:** files with SSNs, IEP documents, free/reduced lunch data, discipline records, medical/504 documentation, and staff evaluation files.
4. Remediate in bulk from the investigation tool — it can change file permissions across a result set. Full procedure in docs/08-monitoring-response.md §5.

[Fundamentals] fallback: no investigation tool. Use `[audit/gam/]()` to enumerate externally-shared files per OU. Slower, works.

Do this **before** flipping "publish to the web" off, so you know what you're about to break. Some public files are intentional — the district calendar PDF, a public board packet. Find those first and move them somewhere designed for it.

4. Shared drives

Path: Admin console > Apps > Google Workspace > Drive and Docs > Manage shared drives and > Sharing settings > Shared drive creation ([source](#))

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Allow users to create shared drives	Drive and Docs > Sharing settings > Shared drive creation	Off (IT-provisioned)	Off	Off	On	All	Prevents shadow shared drives with no owner and no lifecycle. Requires a request process — build it before flipping this	ref
Allow members outside the organization to be added	same	Off	Off	Off	Off	All	External members on a shared drive is a standing, persistent grant — much higher risk than a per-file share	ref
Allow people outside the org to access files	same	Off	Off	Off	Off	All	—	ref
Allow non-members to access files	same	Off	Off	Off	Off	All	—	ref

Why shared drives get stricter treatment than My Drive. A shared drive survives its creator. When a staff member leaves, their My Drive is handled by offboarding; a shared drive they created with an external member attached just keeps existing, with that external account still holding access. Districts routinely discover five-year-old shared drives with a departed vendor still a member.

Existing shared drives: audit membership at least annually. Look for external members, departed staff, and drives with **no active manager** — an unmanaged shared drive is un-offboardable.

Impact + comms: Turning off creation is felt by power users. **Stand up the request process first** — a form, a 2-business-day SLA, and a naming convention. Without it, staff work around you by reverting to My Drive folders, which is worse.

Rollback: Immediate.

5. Trust rules [Standard]/[Plus]

Path: [Admin console > Apps > Google Workspace > Drive and Docs > Sharing settings > Manage trust rules](#) ([source](#))

Trust rules replace the blunt sharing-settings toggles with granular control over who can share with whom, **inside and outside** the organization. Actions available on trigger: **Allow**, **Allow with warning**, or **Block** ([source](#)).

Default trust rules are permissive — they allow broad sharing both inside and outside the organization ([source](#)). Enabling trust rules without writing any is not a security improvement.

Recommended rule set, in evaluation order:

#	RULE	SOURCE	TARGET	ACTION
1	Students → external	/Students/*	Any external	Block (elementary/middle) / Allow with warning to allowlisted domains (high school)
2	Students → staff	/Students/*	/Staff	Allow
3	Students → students	/Students/*	/Students/*	Allow
4	Finance-HR → external	/Staff/Finance-HR	Any external	Allow with warning
5	Staff → external	/Staff	Any external	Allow with warning
6	Anyone → known-bad domains	any	lookalike domains from playbooks/07	Block

Rule 6 is the one people forget and it is genuinely useful: when a lookalike domain is discovered, blocking Drive sharing to it is a same-day containment action alongside the email-side response.

[Fundamentals] fallback: the §2 sharing-settings toggles plus allowlisted domains. Coarser — you get per-OU on/off and an allowlist, not per-source-target rules — but the student-external and staff-warned outcomes are both achievable.

Impact + comms: Depends entirely on the rules written. Test each rule against one OU before applying broadly; a mis-scoped Block rule looks exactly like an outage to users.

Rollback: Disable individual rules. Rules evaluate in order — check the order after any change, because inserting a rule can silently shadow a later one.

6. DLP for Drive [Standard]/[Plus]

Path: [Admin console > Security > Access and data control > Data protection](#) ([source](#))

Google provides predefined detectors for common sensitive data types, usable in both Drive DLP and Gmail content compliance ([source](#)).

Recommended starting rules — **all in audit-only mode for the first 30 days:**

#	RULE	DETECTS	SCOPE	ACTION (AFTER TUNING)
1	SSN external sharing	US SSN	All OUs, external share	Block + alert
2	Student ID bulk	Custom regex for district student ID format	All OUs, external share	Warn + alert
3	Financial account data	Bank account / routing numbers	/Staff/Finance-HR	Warn + alert
4	Credential-looking content	Predefined detector	All OUs	Alert only
5	Health/medical terms	Custom keyword list	All OUs, external share	Warn + alert

Run in audit mode first. This is not optional caution. DLP rules in a K-12 tenant generate large volumes of unexpected true-positives — a nurse's spreadsheet, an SRO incident log, a special-education caseload file. You need to see the shape of the data before you start blocking, or you will block a special-education coordinator's daily work on day one and lose the political capital to run DLP at all.

Edition note: the Education comparison lists basic DLP for Gmail and Drive under **Fundamentals**, with full DLP capability at Standard/Plus ([source](#)). Confirm which detectors and actions your edition exposes before designing rules against capabilities you may not have.

Impact + comms: In blocking mode, significant. Warn staff who handle student records specifically — they are the population that will hit these rules legitimately and they need to know what to do when they do.

Rollback: Set rule to audit-only, or disable. Immediate.

7. Third-party Drive app access

Path: Admin console > Apps > Google Workspace > Drive and Docs > Features and Applications

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Allow users to install Google Drive apps	Drive and Docs > Features and Applications	Off	Off	Off	Off	All	Third-party apps can no longer be attached to Drive ad hoc	ref
Drive SDK / allow users to access Drive with the Drive SDK API	same	Off	Off	Off	Off	All	Blocks API-level third-party Drive access outside approved apps	ref

This overlaps deliberately with docs/07-oauth-app-control.md. The API controls in doc 07 are the authoritative layer — these Drive-specific toggles are defense in depth. **Configure both**; an app blocked by API controls but allowed here is blocked, since API controls override ([source](#)).

8. Malicious files in Drive

Drive scans for malware, but the useful posture is response, not prevention:

1. **Alert center** surfaces malicious-file detections — route them ([docs/08 §2](#)).
2. **Investigation tool** locates every copy and every share of a given file — a malicious file shared into a shared drive may have been copied many times.
3. **Remediate in bulk**: remove access, transfer ownership, or delete across the result set.
4. **Then check the account** that introduced it — a malicious file in Drive is usually a symptom of [playbooks/01](#), not a standalone event.

Share-notification phishing (T7): an attacker shares a document with a victim; Google sends a legitimate share notification carrying the attacker's message. It authenticates because it is genuinely from Google. [Allow users to receive files from outside the organization](#) = **Off** for students removes this vector for them entirely. For staff it cannot be removed without breaking guardian communication — accept it, and cover it with link warnings ([docs/01-gmail.md §4](#)) and reporting culture ([docs/08 §7](#)).

Rollback summary

SECTION	ROLLBACK	SPEED	RESIDUE
§2 Sharing settings	Reset per-OU toggles	Immediate	Existing shares are never revoked by a settings change
§4 Shared drives	Re-enable creation	Immediate	Drives created meanwhile persist
§5 Trust rules	Disable rule	Immediate	Check rule ordering after any change
§6 DLP	Set to audit-only	Immediate	Blocked actions are not retroactively allowed
§7 Third-party apps	Re-enable	Immediate	Previously-granted tokens survive — revoke separately (docs/07)

04 — Groups

Research date 2026-08-20. Paths under [Admin console > Apps > Google Workspace > Groups for Business](#) and [Admin console > Directory > Groups](#).

This is the single control that stops one spoofed email from hitting every employee in the district. It is also the most commonly neglected, because Groups are usually configured once during migration and never revisited.

1. Why this is the highest-leverage doc in the repo per hour of effort

Every control in [docs/01-gmail.md](#) reduces the *probability* a phishing message is delivered. This one reduces the *blast radius* when one is.

An open [all-staff@<PRIMARY_DOMAIN>](#) group means a single message — from anyone, anywhere — reaches every employee simultaneously. That is the difference between an incident where three people saw a phish and an incident where 1,200 people did, forty of them clicked, and the help desk is on fire for two days. The attacker doesn't need to guess addresses; the group name is on the district website.

The default posture in most migrated tenants is far too open, because Groups permissions were set to "make it work" during migration and inherited forward ever since.

Maps to T1 and T9 in [docs/00-threat-landscape.md](#).

2. Organization-wide Groups policy

Path: [Admin console > Apps > Google Workspace > Groups for Business > Sharing settings](#) ([source](#))

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Who can create groups	Groups for Business > Sharing settings > Creating groups	Admins only	Admins only	Admins only	Admins only	All	Users can't self-serve groups. Also structurally prevents external members and external posting — see below	ref
Default for "Who can view conversations"	same > Default for permissions	Group members	Group members	Group members	Group members	All	Other defaults derive from this one, so setting it correctly cascades	ref
Group owners can allow external members	same	Off	Off	Off	Off	All	No external accounts in district groups	ref
Group owners can allow incoming email from outside the organization	same	Off	Off	Off	Off	All	The core control. External senders cannot post to district groups at all	ref
Group owners can hide groups from the directory	same	Off	Off	Off	Off	All	Keeps IT's inventory of groups complete	ref

The compounding effect of "Admins only"

Restricting group creation to admins does more than prevent group sprawl: **if users are not allowed to create groups, group owners cannot add external members or allow external users to send messages to their groups** ([source](#)).

One setting, three outcomes. This is the highest-value single toggle in the document.

⚠ Blast radius: turning off group creation

Flag before Phase 1. Check for legitimate self-service group use:

- Teachers creating groups for a club, team, or grade-level PLC
- Committees and school-improvement teams forming ad hoc
- Departments using groups as informal collaboration spaces
- **Automated provisioning** — if the SIS, a sync tool, or a script creates groups, it must run as an account with group-creation rights, or provisioning silently breaks

That last one is the real trap: SIS-driven group provisioning failing is invisible for weeks, surfacing as "my class list is wrong" rather than "group creation is broken."

Mitigation: a group-request form with a 2-business-day SLA, plus verified exemption for service accounts. Build it before flipping the setting.

Impact + comms: Moderate. Announce with the request process, not before it exists.

Rollback: Immediate.

3. Audit existing groups — do this before anything else

Changing the org-wide default does not change existing groups. Every group created under the old policy keeps its old permissions. This audit is the actual work of this document; §2 just stops the bleeding.

Path: Admin console > Directory > Groups → select group → Access settings

Script: [audit/gam/06-group-settings.sh]()

Triage in this order

Tier 1 — District-wide distribution lists. all-staff@, all-teachers@, all-employees@, everyone@. Highest blast radius in the domain.

SETTING	REQUIRED VALUE
Who can post	Only managers/owners (or a named authorized-senders group)
Who can join	Only invited / admin-added
Allow external members	Off
Allow posting from outside the organization	Off
Message moderation	Moderate all messages from non-owners
Who can view members	Group members / managers

Tier 2 — School-wide lists. staff-<school>@, teachers-<school>@. Same settings. A single school's staff list is still hundreds of people.

Tier 3 — Role and department lists. principals@, finance@, admins@, sped@. Internal-only posting; moderation optional. principals@ and finance@ deserve Tier 1 treatment — they are precisely the lists an attacker most wants.

Tier 4 — Everything else. Team, club, committee, project groups. Confirm no external members, no external posting. Bulk-fixable via GAM.

Findings to expect

Real audits routinely surface, in roughly this frequency order:

- Groups where "Anyone on the web can post" — set during migration, never revisited
- Groups with external members from a long-finished grant, pilot, or vendor engagement
- Groups owned by departed staff — orphaned, no one can change the settings
- Groups whose address is published on the district website, open to external posting

- **Nested groups** where a locked-down parent contains a wide-open child — the child's permissions govern what reaches the child's members, so a hardened `all-staff@` can still be fed by an open sub-group

Nested groups are the one that gets missed. Check membership *of* groups, not just members *in* them.

4. Locking down all-staff — the authorized-senders pattern

The failure mode of "only owners can post" is that the list becomes unusable: HR needs to send benefits notices, the superintendent's office sends board updates, transportation sends weather closures at 5am. If posting is too hard, someone opens it back up.

Pattern that survives contact with reality:

1. Create `all-staff-senders@<PRIMARY_DOMAIN>` — a small group of accounts genuinely authorized to reach every employee. Typically: superintendent's office, HR director, communications, technology director, transportation/operations, safety.
2. On `all-staff@`, set **Who can post** to that group.
3. Set **message moderation** to moderate anything from outside that group, so a legitimate sender who isn't on the list gets a delay, not a bounce.
4. Name **two moderators**, not one, with explicit coverage for breaks.
5. Review the sender list each semester — people change roles.

Emergency path matters. Weather closures and safety notices cannot wait on moderation. Either include those roles in the sender group directly, or use the mass-notification system (which is the right tool for that traffic anyway) and reserve `all-staff@` for non-urgent communication. Decide this explicitly rather than discovering it during a snow event.

5. Directory visibility

Path: `Admin console > Directory > Directory settings > Sharing settings > Contact sharing`

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Contact sharing / directory visibility	Directory > Directory settings > Sharing settings	On (internal)	Limited — students should not browse a full staff+student directory	On (internal)	On (internal)	All	Reduces reconnaissance value and student-to-student targeting	[VERIFY path]
Group visibility in directory	Groups for Business > Sharing settings	Internal only	Internal only	Internal only	Internal only	All	Group addresses aren't externally enumerable	ref

[VERIFY] — I did not confirm the exact current navigation for contact-sharing and directory-visibility controls on 2026-08-20; Google has moved directory settings between [Directory > Directory settings](#) and the older [Apps > Google Workspace > Directory](#) location historically. Confirm in your console. The *recommendation* stands regardless of where the toggle now lives.

A realistic note on directory restriction. It has limited security value against T1 — the superintendent's name and title are on the district website, and that's all the attacker needs. Its real value is against T9 (**student-to-student**), where browsing a full student directory makes targeting trivial. Prioritize it for student OUs; treat it as low-priority for staff.

6. Groups spoofing protection

Set in Gmail, not Groups: **Protect Groups from inbound emails spoofing your domain** → [Quarantine](#), scoped to **all groups** rather than private-only.

Full detail: [docs/01-gmail.md](#) §3.

Why it needs saying twice. The per-user spoofing protections do not cover mail addressed to groups. A district can have employee-name spoofing perfectly configured and still deliver a spoofed message to [all-staff@](#), because that is a different code path and a separate setting. It is genuinely easy to miss.

7. Ongoing cadence

TASK	FREQUENCY
Tier 1 + Tier 2 group settings verified	Monthly
all-staff-senders@ membership reviewed	Each semester
Full group audit — external members, external posting, orphans	Quarterly
Orphaned groups (departed owner) reassigned or deleted	Quarterly
Nested group membership reviewed	Quarterly
New groups reviewed against the tier model	At creation

Script: `[audit/gam/06-group-settings.sh]()` — run it as part of the quarterly audit and diff against the last run. The diff is more useful than the report; it shows what someone changed.

Rollback summary

SECTION	ROLLBACK	SPEED	RESIDUE
§2 Org-wide policy	Reset toggles	Immediate	Existing groups keep their own settings either way
§3 Per-group settings	Restore from audit output	Minutes	Keep pre-change GAM output — it <i>is</i> your restore point
§4 Authorized senders	Widen posting permission	Immediate	Moderated messages stay in the queue
§5 Directory visibility	Re-enable	Immediate	None

Before the quarterly bulk fix, run [audit/gam/06-group-settings.sh]() and **keep the output**. It is the only rollback you have for a bulk permission change.

05 — Chat, Meet, Classroom, Gemini, Takeout & Service Hygiene

Research date 2026-08-20.

Two goals: close the non-Gmail communication channels students can be reached through, and **shrink the number of Google services an attacker can abuse to send an authenticated lure (T7).**

1. Age-based access — set this first

Path: `Admin console > Directory > Users` (age designation) and the age-based access settings ([source](#))

Google applies different default protections to users designated **under 18**, and the under-18 designation is what drives the third-party app restrictions in [docs/07-oauth-app-control.md](#) §4.

Verify before anything else in this doc: that every student OU is correctly age-designated. Districts commonly find high school students designated 18+ because of a bulk import default, which silently removes protections from ~4,000 minors. This is a five-minute check with large consequences.

2. Google Chat

Path: `Admin console > Apps > Google Workspace > Google Chat > External chat settings` ([source](#))

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
External chat	Chat > External chat settings	Restricted to allowlisted domains	Off	Restricted to allowlisted domains	Restricted to allowlisted domains	All	Students cannot be contacted by any external account via Chat	ref
External spaces & group DMs	same	Off	Off	Off	Off	All	No external multi-party spaces	same
Chat history	Chat > Chat settings > History for spaces	On (default on)	On, admin-controlled	On	On	All	History must be retained for investigation and for student-safety review	[VERIFY exact path]
Chat apps / bots	Chat > Chat apps	Admin-approved only	Off	Admin-approved only	Admin-approved only	All	Chat bots are an under-reviewed third-party access path — treat as OAuth apps (docs/07)	[VERIFY exact path]

Why external Chat off for students is non-negotiable. It is a direct, private, real-time channel from an arbitrary external adult to a minor, inside a district-issued account. That is a student-safety control before it is a phishing control. The phishing benefit (removing a lure channel that bypasses every email control) is a bonus.

Chat history on, admin-controlled, for students matters for a reason that isn't security: when a bullying or safety incident is investigated, history is the evidence. If students can turn history off, that evidence doesn't exist.

Impact + comms: Low for students — most don't use Chat with external parties. Moderate for staff if the district collaborates with external partners over Chat; the allowlist handles known partners.

Rollback: Immediate per-OU.

3. Google Meet

Path: Admin console > Apps > Google Workspace > Google Meet > Meet safety settings

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Who can join meetings created by this OU	Meet > Meet safety settings > Joining	Anyone (guardians must join)	Only users signed in to <PRIMARY_DOMAIN>	Anyone	Anyone	All	External adults cannot join student-created meetings	[VERIFY exact path]
Which meetings users in this OU can join	same	Any	Only <PRIMARY_DOMAIN> meetings	Any	Any	All	Students cannot join arbitrary external meetings from a district account	[VERIFY]
Who can host / start meetings	same	All staff	Off — students cannot create	All staff	All staff	All	Removes student-hosted unmoderated meetings. Check first — some instructional models rely on student-led breakouts	[VERIFY]
Host management / knocking	same	On	On	On	On	All	Host approval required for external joiners	[VERIFY]

[VERIFY] — Meet safety settings have been reorganized more than once. The recommendations are stable; confirm the current sub-page names in your console.

⚠ **Blast radius: students cannot create meetings.** Breaks student-led breakout rooms, peer tutoring, club meetings, and some project-based learning models. **Check with instructional technology before applying** — this is exactly the kind of restriction the "student-facing restrictions must not break instruction" rule exists to catch. If it conflicts, keep student meeting creation but enforce domain-only joining, which retains most of the benefit.

Rollback: Immediate per-OU.

4. Google Classroom

Path: [Admin console](#) > [Apps](#) > [Additional Google services](#) > [Google Classroom](#) > [Class settings](#)

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Who can join classes in your domain	Classroom > Class settings	Only users in your domain	Only users in your domain	—	—	All	External accounts cannot join district classes	[VERIFY exact path]
Which classes users in your domain can join	same	Only classes in your domain	Only classes in your domain	—	—	All	Students cannot join an external Classroom from a district account — closes a real lure ("Join my class for free tutoring")	[VERIFY]
Who can create classes	same	Verified teachers only	Off	—	—	All	Students cannot create classes and impersonate a teacher. Requires the verified-teachers group to be maintained	[VERIFY]
Guardian email summaries	same	Per district policy	—	—	—	All	Legitimate guardian channel — keep, and verify guardian addresses through the SIS, not by self-service	[VERIFY]

Classroom-notification phishing is common and effective. A fake "you've been invited to a class" or "new assignment posted" email is highly credible to a student. Domain-restricted class membership means the real notifications only ever come from inside the district, which makes the fake ones distinguishable — but only if students are told that. Put it in the student comms.

"Verified teachers only" needs maintenance. New hires can't create classes until they're in the group. Wire this into onboarding or the first week of school produces a support queue.

5. Gemini and generative AI

Path: `Admin console > Apps > Google Workspace > Gemini / Generative AI` — service-level access is managed per OU or configuration group ([source](#))

Gemini in Classroom is ON by default for users of all ages ([source](#)) — so this is another "default is permissive, doing nothing is a decision" case.

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Gemini app	Gemini > Gemini app settings	On	Per district AI policy — Off if none exists	On	On	Varies	Don't enable district-wide generative AI for minors without a written policy and guardian communication	ref
Gemini in Workspace services (Gmail, Docs, Drive)	Gemini > Manage access to Gemini features	On	Per policy	Review — see below	On	Varies	—	ref
Gemini in Classroom	Gemini > Gemini in Classroom	Per policy	Per policy	—	—	Varies	ON by default for all ages — an affirmative decision either way	ref
Ask Gemini in Meet	Meet > Ask Gemini	Per policy	Off	Per policy	Per policy	Varies	Meeting transcription/s ummarization has its own records and consent implications	ref

The prompt-injection angle

An AI assistant that reads email on a user's behalf will read **attacker-controlled text**, because that is what inbound email is. Instructions embedded in a message body — including in white-on-white text, tiny fonts, or an attachment — are input to the model, and a summarize-my-inbox feature processes them the same as any other content.

Practical implications for a district:

- **Treat AI-generated summaries as untrusted for action.** A summary saying "the CFO needs a wire transfer approved" carries no more authority than the email it summarized. Say this explicitly in Finance-HR training — it is a new failure mode and staff will not intuit it.
- **Do not let convenience erode verification.** The out-of-band callback rule in [playbooks/04](#) and [playbooks/05](#) applies regardless of what any assistant reports.
- Google's June 2026 advisory documents attackers hiding malicious instructions in cloud documents to evade filtering — "invisible pages" ([Google](#)). The same technique targets anything that reads documents on a user's behalf.

[VERIFY] — I found no Google admin control specifically governing prompt-injection resistance or restricting what Gemini may act on within email as of 2026-08-20. This is currently a **training and process control**, not a configuration one. Do not tell leadership there's a setting for it.

Edition note: Gemini availability varies by edition and add-on and has changed repeatedly. Confirm what your licensing actually includes before designing policy around it.

6. Google Takeout

Path: Admin console > Apps > Additional Google services → Takeout service, or Admin console > Account > Account settings > Takeout — [VERIFY] which applies in your console; Google has moved this control.

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Google Takeout for Workspace services	see path note	On (offboarding, records requests)	Off	On	On	All	Students cannot bulk-export their account data	[VERIFY]

Why off for students. A compromised student account with Takeout enabled is a bulk data exfiltration tool — one export, everything at once. Students also have no legitimate need to mass-export a district-owned account; graduation data transfer, where the district offers it, should be an administered process, not self-service.

Consider the graduation exception explicitly. Some districts allow seniors a Takeout window before accounts are deprovisioned. If yours does, make it a time-boxed OU move (/Students/Graduating-Export) for a defined window, not a standing permission.

7. Service hygiene — turn off what you don't use

Path: Admin console > Apps > Additional Google services (and > Google Workspace for core services), per OU

This is the T7 mitigation. Every enabled Google service is a service an attacker can use to generate an authentically-signed, perfectly-authenticated notification email to your users. You cannot stop Google notifications from being trustworthy — you can reduce how many kinds of them exist in your tenant.

Sweep procedure

1. Enumerate every service, per OU: [audit/gam/08-ou-service-state.sh]()
2. For each **On** service, answer: *does an identified group of users use this for instruction or operations?* Not "might someone" — is there a known use.
3. If no → turn **Off** for all OUs.
4. If yes for some → turn Off for OUs that don't need it, starting with students.
5. Re-run quarterly. New Google services **arrive enabled by default** in many cases, so this sweep is a recurring task, not a one-time project.

Common candidates

SERVICE	TYPICAL DISTRICT REALITY	RECOMMENDATION
AppSheet	Almost never used	Off for all OUs unless a named owner exists. App-building + data access is meaningful surface
Google Ads / Merchant Center	Never	Off
Blogger	Legacy, rarely current	Off unless actively used
Google Groups (consumer, not Workspace Groups)	Rarely	Off — distinct from Groups for Business
Google+ / legacy social	Gone or vestigial	Off
Third-party / unlisted "Additional services"	Long tail nobody reviewed	Off by default; enable on request
Google Photos	Sometimes instructional	Off for students unless there's a use
YouTube	Instructional, needs restricted-mode config	Configure, don't disable
Google Sites	Sometimes instructional	Keep if used; note it's a documented ClickFix lure host

On AppSheet specifically: I did not find current reporting documenting AppSheet abuse in phishing chains, despite it being named in the source brief. Turning it off is justified as **attack-surface reduction for an unused service** — a defensible, honest rationale. Don't claim a campaign that isn't documented; the surface-reduction argument stands on its own.

Impact + comms: Usually zero, occasionally sharp. The failure mode is turning off a service one teacher built a whole unit around. **Announce the sweep list two weeks ahead with a "tell us if you use this" reply path.** That two-week window is the entire difference between a clean sweep and an angry email from a department chair.

Rollback: Immediate per-service, per-OU. Data is retained while a service is off; turning it back on restores access.

8. Quick reference — student OU target state

SERVICE	STUDENT SETTING
Chat — external	Off
Chat — external spaces/DMs	Off
Chat — history	On, admin-controlled
Meet — join scope	Domain only, both directions
Classroom — membership	Domain only, both directions
Classroom — create classes	Off
Gemini	Per written AI policy; Off absent one
Takeout	Off
AppSheet	Off
Drive external sharing	Off / allowlisted (docs/03)
POP/IMAP	Off (docs/01)
External forwarding	Off (docs/01)
Self-service password recovery	Off (docs/06)

06 — Accounts, MFA & Admin Hardening

Research date 2026-08-20. Paths under `Admin console > Security` and `Admin console > Directory`.

1. The premise this document is built on

"We have MFA" is no longer a sufficient statement.

AiTM phishing kits proxy the entire sign-in — the victim sees a real Google login page, enters a real password, completes a real 2SV challenge, and the kit captures the resulting **session cookie**. The attacker replays the cookie and never needs the password or the second factor again.

SMS, TOTP, and push are all proxyable. FIDO2 security keys and passkeys are not ([Proofpoint](#), [Group-IB](#)). Passkeys and security keys carry the same level of phishing protection, because passkeys use the same public-key cryptography that underpins physical keys ([Google](#)).

The practical consequence, and the thing to say to leadership:

Turning on 2SV for all staff is necessary and it is not the finish line. For the ~30 accounts that can move money or change everything — super admins, Finance-HR, payroll — **only phishing-resistant methods actually stop the current attack.**

Maps to T4 and T12 in [docs/00-threat-landscape.md](#).

2. 2SV enforcement for all staff

Path: `Admin console > Security > Authentication > 2-step verification` ([source](#))

Google is already enforcing 2SV for **administrator accounts**, and that enforcement covers organizations with Workspace for Education ([source](#)). Admin 2SV is not a choice you're making; it's a deadline you're meeting.

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Allow users to turn on 2SV	Security > Authentication > 2-step verification	On	On	On	On	All	Prerequisite for everything below	ref
Enforcement	same	On , after enrollment window	Off (<i>see §10</i>)	On	On	All	Users without 2SV cannot sign in after the deadline	same
Enrollment period for new users	same	1 week	—	1 day	1 day	All	New hires must enroll quickly; a long grace window on a finance account is a gap	same
Allowed methods — general staff	same	Any except SMS/voice if achievable	—	—	—	All	SMS is the weakest method and SIM-swap-attackable	same
Allowed methods — Finance-HR & Admins	same	—	—	Only security key / passkey	Only security key / passkey	All	§3	same
Frequency: allow "don't ask again on this device"	same	On	—	Off	Off	All	Trusted-device suppression is a stolen-cookie multiplier for high-value accounts	same

Rollout sequence that actually lands

1. **Weeks 1–2:** enable 2SV, communicate, **do not enforce**. Publish a how-to and hold drop-in sessions.
2. **Weeks 3–4:** targeted outreach to non-enrolled users. Expect ~60% voluntary enrollment.
3. **Week 5:** enforce for **IT staff first** — dogfood the support burden before it hits the district.
4. **Week 6:** enforce for Finance-HR (phishing-resistant only, §3).
5. **Weeks 7–8:** enforce for all staff, in school-sized waves rather than district-wide.

Do not enforce district-wide on a single day. The help desk cannot absorb 1,200 users discovering simultaneously that their backup codes are in a drawer at home. Wave by school.

⚠ Blast radius

- **Shared/kiosk accounts** — library, lab, and cart logins in [/Shared Devices](#) cannot reasonably do per-user 2SV. Deal with this by removing shared accounts, not by exempting a broad OU. If they must persist, isolate them in their own OU with the tightest possible service set and no mail access.
- **Service accounts** — must not be caught by user enforcement. Confirm [/Service Accounts](#) is excluded.
- **Substitute teachers and seasonal staff** — high-churn, low-tech-contact populations that surface at the worst moment. Plan for them explicitly.

- **If SSO fronts Google** (ASSUMPTIONS.md §A10), Google's 2SV policy **does not apply** to SSO-authenticated sessions. The phishing-resistant requirement must then be enforced at the identity provider instead. Verify which applies before promising this control to anyone.

Impact + comms: The largest user-facing change in this package. Templates in [comms/]()).

Rollback: Disable enforcement — immediate. Enrolled users stay enrolled, which is fine.

3. Phishing-resistant methods for high-risk roles

Required for: super admins, all delegated admins, Finance-HR, anyone who can change payroll banking, anyone with SIS write access to financial records.

Path: Admin console > Security > Authentication > 2-step verification → allowed methods → **Only security key** (passkeys included)

ROLE	METHOD	BACKUP	RATIONALE
Super admins	2× hardware security keys	Second physical key, stored separately	Cannot be proxied. Two keys because losing the only one locks out the domain
Delegated admins	Hardware key or passkey	Second factor enrolled	Same attack surface, smaller scope
Finance-HR	Passkey (platform) or hardware key	Second passkey on a second device	T2/T3 loss magnitude justifies the friction
Payroll-touching	Passkey or hardware key	Second passkey	same
General staff	Any non-SMS method	Backup codes	Cost/benefit; escalate over time

Budget note for the cabinet. Hardware keys are roughly \$25–50 each. Two keys for ~30 high-risk accounts is **\$1,500–3,000, one time**. Put that number next to the district's last BEC loss, or the sector's typical one. It is the cheapest line item in any security proposal you will make this year, and it is the one that stops the attack that's actually running.

Passkeys vs. hardware keys. Same phishing resistance (source). Passkeys are cheaper and more convenient (device biometric); hardware keys are portable across devices and survive device loss/replacement cleanly. **Recommendation:** hardware keys for super admins (portability and break-glass matter most there), passkeys for Finance-HR (lower friction, better adoption, adoption is the real constraint).

Google also supports allowing users to **skip passwords at sign-in** where passkeys are deployed (source) — worth evaluating once passkeys are established, since a password that is never typed is a password that cannot be phished.

Impact + comms: Real friction for ~30 people. Brief them individually, in person. This is a small enough population that a group email is the wrong tool.

Rollback: Widen allowed methods — immediate. **Don't**, without an explicit decision recorded; this is the control that matters most.

4. Advanced Protection Program for super admins

Path: [Admin console](#) > [Security](#) > [Authentication](#) > [Advanced Protection Program](#) ([source](#))

APP is Google's strongest account protection tier. It:

- Enforces security keys or passkeys for sign-in
- Enables enhanced pre-delivery scanning of incoming email for phishing
- Applies stricter app-access and download protections
- Takes precedence over 2SV policy settings where both are configured ([source](#))

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Advanced Protection Program enrollment	Security > Authentication > Advanced Protection Program	Optional	Off	Recommended	Required	All	Strictest tier; some third-party apps will be blocked from these accounts	ref

Enhanced pre-delivery scanning is available across editions and is enabled for APP users ([source](#)) — an extra deep scan before delivery for the accounts most likely to be targeted.

⚠ **Before enrolling:** APP restricts third-party app access. If a super admin's daily workflow depends on a third-party tool, it may break. This is a strong argument for \$5 — super admin accounts should not have daily workflows at all.

Rollback: Un-enroll — immediate.

5. Super admin hygiene

The highest-blast-radius accounts in the district. A compromised super admin is not an incident, it is the whole domain.

Rules

#	RULE	WHY
1	2–4 dedicated super admin accounts. Not more, not one.	Two is the minimum for break-glass. More than four and nobody knows who has what
2	Never a daily driver. Named accounts (<code>admin-firstname@</code>) used only for admin work	A super admin account that reads email is a super admin account that can be phished
3	Every admin has a separate normal account for mail, Drive, meetings	The actual mechanism for rule 2
4	Hardware security key required , two per account	§3
5	APP enrolled	§4
6	No third-party app grants , ever	Highest-value token in the domain
7	Recovery locked down — recovery phone/email are district-controlled, never personal	Account recovery is an attack path. A personal recovery address outlives employment
8	One break-glass account , credentials in a physical safe, key in the safe, monitored for use, never used routinely	For when everything else fails or the admin is unavailable
9	Quarterly review of who holds super admin	Roles change; grants don't expire on their own
10	Alert on every super admin sign-in	~30 sign-ins/month is a reviewable volume. An unexpected one is a real signal (docs/08)

Delegated admin roles — use them

Most people with super admin do not need it. Google's predefined and custom roles cover the realistic cases ([source](#)):

FUNCTION	ROLE INSTEAD OF SUPER ADMIN
Password resets, user creation	User Management Admin
Gmail settings	Custom role: Gmail settings only
Chromebook/device management	Services Admin (device scope)
Help desk tier 1	Custom: reset password, view users, no OU or security changes
Reporting/audit access	Custom: reports + audit read-only

Audit: `[audit/gam/07-admin-roles.sh]()`. Run it now. The common finding is 8–15 super admins in a district that needs 3, usually accumulated from past migrations and vendor engagements. **Vendor super admin accounts from a completed project are the single most common orphan** — check for those specifically.

Super admin password recovery

Google provides a specific mechanism for super admin self-recovery ([source](#)). **Recommendation: leave it off** and rely on the break-glass account plus a second super admin. Self-recovery for the highest-privilege account in the domain is an attack surface that the break-glass procedure already covers more safely.

6. Login challenges

Path: [Admin console > Security > Authentication > Login challenges](#) ([source](#))

Google presents additional challenges — employee ID, recovery address — when a sign-in looks risky.

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Employee ID challenge	Security > Authentication > Login challenges	On	On	On	On	All	Requires employee ID on suspicious sign-in. Requires the employee ID field to be populated in the directory — usually via SIS/HR sync	ref

Populate the employee ID field first, or the challenge cannot be presented and the control is decorative. This is a directory-sync task, not a security-console task.

Operational note for the help desk: if a login challenge is blocking a user, **changing their password does not fix it** — the challenge must be disabled for that user first ([source](#)). Put that sentence in the help desk runbook; it saves a recurring twenty-minute confusion.

7. Session length

Path: [Admin console > Security > Access and data control > Google Session control](#) → **Web session duration** ([source](#))

Why this is an anti-AiTM control. A stolen session cookie is valuable exactly as long as the session lives. Shortening the session shortens the attacker's window.

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Web session duration	Security > Access and data control > Google Session control	14 days	14 days	8 hours	8 hours	[Plus] for session control	High-risk roles re-authenticate daily; passkeys make that ~2 seconds	ref

The Admin console is already 1 hour and cannot be changed ([source](#)). Google made that decision for you; it's the right one.

Why 8 hours and not 1 for Finance-HR. One hour would mean re-authenticating repeatedly through a workday, and the predictable result is staff finding workarounds. Eight hours means one sign-in per day, and with a passkey that is a fingerprint touch. Friction people accept is worth more than friction they route around.

Edition note: session-length control is a [Plus] capability ([source](#)). **[Fundamentals] fallback:** none directly — rely on phishing-resistant 2SV (\$3) plus prompt token revocation during incident response ([playbooks/01](#)).

Rollback: Immediate. Users are not signed out when the duration is lengthened.

8. Context-Aware Access [Plus]

Path: Admin console > Security > Access and data control > Context-Aware Access ([source](#))

CAA gates access on device and network context — not just "who are you" but "from where, on what." **Supported in Education Plus.**

ACCESS LEVEL	APPLIES TO	CONDITION	RATIONALE
admin-console-restricted	Super + delegated admins	District network or managed device, from US	The Admin console should never be reachable from an arbitrary device (source)
finance-restricted	/Staff/Finance-HR	Managed device required	Payroll/AP from a personal laptop is the T2/T3 path
student-basic	/Students/*	Optional geographic restriction	Consider carefully — see below

Deploy in monitor mode first. CAA can lock people out — including you — and the way that usually happens is a legitimate condition nobody modeled. Run in monitor, review who *would* have been blocked, then enforce.

⚠ Blast radius

- **Locking yourself out.** Always keep one super admin **exempt** from CAA, credentials in the safe, until the policy is proven. This is not optional.
- **Legitimate remote work** — snow days, after-hours, summer administration, staff travelling for PD. A network-only rule breaks all of it. Prefer *managed device* over *district network* as the primary condition.
- **Student geographic restrictions** — will break students travelling, military families, and any legitimate out-of-area access. Usually **not worth it**; the false-positive cost lands on families with the least ability to resolve it.
- **1:1 device programs** — if student devices aren't enrolled as managed, a managed-device condition blocks everyone.

[Fundamentals]/[Standard] fallback: CAA appears at **Standard** in the Education comparison ([source](#)). For Fundamentals there is no equivalent — rely on §3 and §7.

Rollback: Set the access level to monitor, or unassign it. Immediate. **Verify you can still reach the Admin console before you close the browser tab** — this is the single most common way an admin locks themselves out of their own tenant.

9. Password policy and recovery

Path: Admin console > Security > Authentication > Password management and > Account recovery ([source](#))

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Minimum length	Security > Authentication > Password management	12	8 (age-appropriate)	14	14	All	Length beats complexity	[VERIFY]
Enforce strong password	same	On	On	On	On	All	—	[VERIFY]
Expiration	same	Never	Never	Never	Never	All	Forced rotation produces Spring2026! → Summer2026! . NIST moved off it years ago; so should the district	[VERIFY]
Reuse	same	Off (no reuse)	Off	Off	Off	All	—	[VERIFY]
Enforce at next sign-in	same	On (at policy change)	On	On	On	All	—	[VERIFY]
Non-admin password recovery	Security > Authentication > Account recovery	On	Off	On	—	All	Students: admin-mediated resets only	ref
Super admin recovery	same	—	—	—	Off	All	§5	ref

Why self-service recovery is off for students

Self-service recovery requires a recovery phone or email ([source](#)). For minors, that recovery address is typically a **personal account the district does not control** — often shared with a sibling, sometimes compromised, frequently forgotten. It becomes an account-takeover path into the district domain that bypasses every other control here.

Admin-mediated resets cost help desk time. **Budget for it explicitly** — this generates real volume at the start of each school year, and the way it fails is that an overwhelmed help desk quietly turns self-service back on in October.

Rollback: Immediate.

10. Student 2SV — deliberately not enforced

Students are the one population where this package does **not** recommend 2SV enforcement.

Reasoning: many students, especially younger ones, have no second device. Enforcement would put a phone requirement between a child and their schoolwork, which is both an equity problem and an instructional one. It would also generate a lockout volume no district help desk can absorb.

Instead, for students: admin-mediated recovery (§9), no external forwarding, no POP/IMAP ([docs/01](#)), Takeout off ([docs/05](#)), and prompt detection via the alert center ([docs/08](#)).

Reconsider for high school seniors if the district issues devices with a platform authenticator — passkeys on a district Chromebook remove the second-device problem entirely. That is a genuinely good option worth piloting.

Rollback summary

SECTION	ROLLBACK	SPEED	RESIDUE
§2 2SV enforcement	Disable enforcement	Immediate	Enrolled users stay enrolled
§3 Method restriction	Widen allowed methods	Immediate	None
§4 APP	Un-enroll	Immediate	None
§5 Admin roles	Re-grant	Immediate	Keep pre-change GAM output as the restore point
§7 Session length	Lengthen	Immediate	Users not signed out
§8 CAA	Set to monitor / unassign	Immediate	Verify Admin console access before closing the tab
§9 Password policy	Revert	Immediate	Changed passwords stay changed

07 — OAuth & Third-Party App Control

Research date 2026-08-20. Paths under [Admin console > Security > Access and data control > API controls](#) and [Admin console > Apps > Google Workspace Marketplace apps](#).

1. Why this document exists

Phishing gets an attacker one account. **An OAuth grant gets them persistent, password- independent, MFA-independent access to data** — and it survives every remediation step in [playbooks/01](#) *except* explicit token revocation.

The consent-phishing pattern: the victim is shown a real Google consent screen for an app named something plausible ("Classroom Sync Helper", "District Docs Backup"), clicks Allow, and the attacker holds a refresh token with whatever scopes were requested. **The password reset doesn't matter. The 2SV doesn't matter. The token still works.**

Two district-specific amplifiers:

- **Teachers install things.** The ed-tech ecosystem runs on "click here to connect your Google account", and teachers are trained by every legitimate vendor to do exactly what a consent phish asks.
 - **Domain-wide delegation is the largest blast radius in the tenant** — a single compromised delegated service account can impersonate *every user in the domain* simultaneously. There is nothing else in Workspace with that reach.
-

2. App access control — the core setting

Path: [Admin console > Security > Access and data control > API controls > App access control](#) ([source](#))

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Unconfigured third-party apps — access to restricted scopes	Security > Access and data control > API controls > App access control	Blocked	Blocked	Blocked	Blocked	All	Apps must be explicitly trusted before touching Gmail/Drive/Calendar data. This is the control	ref
Unconfigured third-party apps — all other scopes	same	Blocked	Blocked	Blocked	Blocked	All	Sign-in-only scopes included. Blocking here is stricter but avoids a long tail of unreviewed grants	same
Internal apps (same-domain)	same	Trusted	Trusted	Trusted	Trusted	All	District-built Apps Script and internal tooling keeps working	same
Google services access	same	Reviewed per service	Restricted	Reviewed	Reviewed	All	Overlaps docs/05 §7	same

What "restricted scopes" means and why it's the line

Google classifies the highest-sensitivity scopes — Gmail read/send, full Drive access, Calendar, contacts — as **restricted**. These are exactly the scopes a consent phish wants, and exactly the scopes a legitimate ed-tech tool sometimes genuinely needs.

Blocking unconfigured apps from restricted scopes means: **a user clicking Allow on an unknown app gets nothing**. The consent screen may appear; the grant fails. That single setting neutralizes the consent-phishing class.

⚠ Blast radius — this one is big, plan for it

Turning this on **will break currently-working integrations**. Before enabling:

1. **Inventory every app with an existing grant:** `[audit/gam/04-oauth-tokens.sh]()`, or [API controls > App access control > Manage Google Services / third-party apps](#).
2. Sort by **number of users** and by **scopes requested**. An app with 400 teachers and Drive scope is a Tier 1 review; an app with 1 user and profile scope is not.
3. For each, decide: **Trusted** (district-approved, contract in place, DPA signed), **Limited**, or **Blocked**.
4. **Trust the approved list before flipping the default to Blocked**. In that order. Doing it the other way round takes down instruction on a school day.
5. Announce with the request workflow (§5) already live.

Expect to find: grade-book integrations, Chrome extensions with Drive access, e-signature tools, PDF converters, "free" classroom utilities that teachers found themselves, and at least one app nobody can identify. That last category is the point of the exercise.

Impact + comms: High if sequenced wrong, low if sequenced right. Two-week notice with the app request form live. Template in [comms/]()).

Rollback: Set unconfigured apps back to allowed — immediate. **Grants made while blocked are not retroactively created**, so nothing is restored automatically; users re-consent.

3. Marketplace allowlist mode

Path: Admin console > Apps > Google Workspace Marketplace apps > Settings and > Apps list (requires Google Workspace Marketplace admin privilege) ([source](#))

SETTING	PATH	STAFF	STUDENTS	FINANCE-HR	ADMINS	EDITION	IMPACT	SOURCE
Manage access to apps	Marketplace apps > Settings	Allow users to install and run allowlisted apps	Don't allow users to install any apps	Allowlisted only	Allowlisted only	All	Staff install from a curated list; students install nothing	ref
Allowlist contents	Marketplace apps > Apps list	Reviewed, contracted, DPA'd apps only	—	—	—	All	The allowlist <i>is</i> the district's approved ed-tech list	same

Important interaction: the allowlist only affects users set to "Allow users to install and run allowlisted apps." It has **no effect** on users allowed to install anything, or on users blocked from installing entirely ([source](#)). Setting an allowlist while users are on "install anything" accomplishes nothing — a genuinely easy misconfiguration.

And: API controls override the allowlist. An app allowlisted here but blocked in §2 is **blocked** ([source](#)). Configure both; §2 wins.

4. Under-18 users and the confirmed-apps requirement

Path: Admin console > Security > Access and data control > API controls > App access control → Apps pending review ([source](#), [source](#))

Google applies additional protections to users designated **under 18**: they are **blocked from unconfigured third-party apps**, and see a message offering to **request access** ([source](#)). Requests appear in the **Apps pending review** list on the App access control page, where an admin allows or dismisses each one ([source](#)).

This is Education-editions only and depends entirely on correct age designation — see [docs/05-other-services.md](#) §1. If students are mis-designated as 18+, **none of this applies to them**. Verify first.

Parental consent

Your organization is responsible for obtaining parental consent, if required by applicable law, before allowing under-18 users to access third-party apps ([source](#)).

This is a district legal obligation, not an IT preference. Loop in whoever owns COPPA and FERPA compliance. The approval workflow in §5 should have a consent checkpoint, and the answer to "do we have consent for this app" needs an owner who is not the technology department.

5. Teacher app-request workflow

Google supports educators requesting access to third-party apps **on behalf of their students** ([Workspace Updates, 2024-11](#)).

Build the process before you turn on the restrictions. Without it, blocking apps looks like IT saying no, and teachers route around it with personal accounts — which is worse than where you started.

Recommended workflow

STEP	OWNER	SLA
1. Teacher submits request (app name, URL, instructional purpose, grade levels, data collected)	Teacher	—
2. Triage — already reviewed? already blocked?	Tech dept	1 business day
3. Privacy review — DPA in place? student PII collected? COPPA/FERPA posture?	Data privacy owner	5 business days
4. Security review — scopes requested vs. scopes needed	Tech dept	3 business days
5. Instructional review — does it duplicate something already approved?	Curriculum	5 business days
6. Decision → allowlist + API controls trusted, or denied with reason	Tech dept	1 business day
7. Published to the approved-apps list	Tech dept	—

Target: 10 business days end to end. Publish that number. A predictable two weeks is something a teacher can plan a unit around; an unpredictable process is one they bypass.

Scope review is where the security value is. A flashcard app requesting full Drive access is asking for far more than it needs. "What does it need vs. what does it ask for" is the single highest-signal question in the whole workflow, and it's usually answerable in five minutes.

Fast path: pre-approve a standing list of major platforms the district already has contracts with, so the queue holds genuinely new requests rather than re-litigating Canvas.

6. Domain-wide delegation — highest blast radius in the domain

Path: Admin console > Security > Access and data control > API controls > Manage Domain Wide Delegation
Requires super admin ([source](#))

DWD lets a service account **impersonate any user in the domain** for the granted scopes. No user consent. No user awareness. No 2SV. If a DWD client with Gmail scope is compromised, the attacker reads every mailbox in the district.

Audit — do this now, not in Phase 2

For each entry:

CHECK	QUESTION
Identify	What is this Client ID? If nobody can say, that alone is the finding
Owner	Named person and named system. "Probably the SIS" is not an owner
Scopes	Read-only where read-only suffices? <code>gmail.readonly</code> not <code>mail.google.com</code> ?
Necessity	Is the integration still in use? Vendors change; grants don't
Provenance	Who created it, when, under what project?
Key hygiene	Where does the service account key live? Rotated when? Who has a copy?

Common findings, in order of frequency:

- Grants from **vendors no longer under contract** — the integration ended, the grant didn't
- **Over-scoped** grants: full `mail.google.com` where `gmail.readonly` would do
- **Unidentifiable** Client IDs from a migration years ago
- **Service account keys** sitting in a shared drive, a git repo, or a former admin's Downloads
- Grants created by a **departed administrator** with no documentation

Remove anything you cannot positively identify and justify. The recovery path — a broken integration and a support ticket — is bounded and obvious. The alternative is an unmonitored key with domain-wide mailbox access held by someone unknown.

Best practice per Google: grant the **narrowest possible scopes** ([source](#)).

⚠ **Before removing:** notify the integration owner, and schedule for a **low-impact window** — not during grade reporting, state testing, or the first week of school. A removed DWD grant breaks the integration immediately and completely.

Script: `[audit/gam/04-oauth-tokens.sh]()` covers user tokens. **DWD must be reviewed in the console** — GAM's visibility here is limited and the console is authoritative.

7. Quarterly token review

TASK	FREQUENCY	WHERE
Review granted OAuth tokens by app, sorted by user count	Quarterly	API controls > App access control
Review new apps appearing since last review	Quarterly	same
Review Marketplace allowlist for departed/unrenewed vendors	Quarterly	Marketplace apps > Apps list
Domain-wide delegation full audit	Quarterly	API controls > Manage Domain Wide Delegation
Apps pending review queue	Weekly	App access control > Apps pending review
Revoke tokens for departed staff	At offboarding	[audit/gam/remediation/]()

Offboarding is the leak. Suspending an account does not revoke its OAuth grants in every case. Explicit token revocation belongs in the offboarding checklist — [audit/gam/remediation/revoke-tokens.sh]().

Weekly, not quarterly, for pending review. A teacher waiting three months for an app decision has already worked around you.

8. Incident interaction

When an account is compromised, **token revocation is mandatory and it is not optional cleanup** — it is the step that determines whether the attacker still has access tomorrow. Password reset, sign-out-everywhere, and 2SV re-enrollment **do not invalidate an OAuth refresh token**.

Order matters — see [playbooks/01-compromised-staff-account.md](#):

1. Suspend / reset password
2. Sign out all sessions
3. **Revoke all OAuth tokens** ← this one
4. Remove app-specific passwords
5. Check filters, forwarding, delegates, send-as

Steps 3–5 are the persistence mechanisms. Skipping them means doing the whole incident again in a week, which is a thing that genuinely happens.

Rollback summary

SECTION	ROLLBACK	SPEED	RESIDUE
§2 App access control	Set unconfigured apps to allowed	Immediate	Users must re-consent; grants aren't restored
§3 Marketplace	Widen install permission	Immediate	Uninstalled apps must be reinstalled
§4 Under-18	Tied to age designation	Immediate	—
§6 DWD removal	Re-create the grant	Minutes — if you recorded the Client ID and scopes first	Record before removing. There is no undo button.

08 — Monitoring & Response

Research date 2026-08-20. Paths under `Admin console > Security` and `Admin console > Reporting`.

Every control in docs 01–07 will eventually be bypassed by something. This document is how you find out, and how fast you can undo it.

1. What "good" looks like

METRIC	TARGET
Time to know a phish was delivered	< 1 hour during school hours
Time to purge a phish from all inboxes	< 30 minutes from decision
Time to contain a compromised account	< 15 minutes from detection
% of phish first reported by users, not tooling	> 50% — a healthy sign, not a failure
Alert center backlog	Zero unreviewed > 24h

That fourth metric is deliberately counter-intuitive. Users reporting first means the reporting culture works. Tooling catching everything first usually means users have stopped looking.

2. Alert center

Path: `Admin console > Security > Alert center` ([source](#))

Routing — do this first

Route to `<SECURITY_ALIAS>`, a monitored Google Group, never an individual. Personal routing dies with leave, illness, and resignation, and it dies silently.

Configure notification recipients per alert type. For high-severity alerts also configure a **webhook** to whatever the district actually watches — ticketing system, Chat space, or SIEM. An alert nobody sees on a Saturday is not a control.

High-value alerts to enable and route

ALERT	WHY	ROUTE	SLA
Government-backed attack warning	Google believes a state actor is targeting this user. Rare, extremely high signal	Immediate — page someone	1 hour
Leaked password	Credential appeared in a breach corpus	Immediate	4 hours
Suspicious login	Anomalous location/device	Immediate	4 hours
Phishing message detected post-delivery	Google reclassified after delivery — the single most actionable alert here	Immediate	1 hour
User-reported phishing	A human flagged it	Immediate	4 hours
Malware message detected post-delivery	Same as above, malware	Immediate	1 hour
Suspicious device activity	Device compromise indicator	Daily review	1 business day
Account suspension warning	Google auto-suspended for suspicious activity	Immediate	1 hour
App outage / service disruption	Operational, not security	Daily	—
Drive settings changed / Gmail settings changed	Detects an attacker weakening your controls — or an admin doing it undocumented	Immediate	4 hours

That last row matters more than it looks. An attacker with admin access turns off the protections in doc 01 before doing anything else. Alerting on your own settings changing is how you notice.

Recommended actions

Some alerts support direct action from the alert center: **Mark as phishing**, **Delete message**, **Quarantine message** ([source](#)).

For a single message this is faster than the investigation tool. **For anything that hit more than one user, go to the investigation tool (\$5)** — the alert-center action addresses the message that triggered the alert, not the campaign around it.

3. Activity rules [Standard]/[Plus]

Path: Admin console > Security > Security center > Activity rules ([source](#))

An activity rule is a set of conditions and actions; if the conditions are met, the rule triggers and the actions execute automatically. Rules can be built from **any investigation tool search**, and can alert or act ([source](#)).

Recommended rules

#	RULE	TRIGGER	ACTION	NOTES
1	External forwarding created	Gmail settings change: forwarding to external address	Alert + investigate	The #1 persistence mechanism. Highest-value rule here
2	Mail delegate added	Delegate added	Alert	Quiet, persistent mailbox access
3	Send-as alias added	Send-as added and verified	Alert	Enables sending as another identity
4	Super admin role granted	Admin role change	Alert immediately	Should be ~never. Any hit is worth a phone call
5	Mass file sharing	> N files shared externally in a short window	Alert	Exfiltration indicator
6	Mass download	> N files downloaded in a short window	Alert	Same
7	Login from anomalous location for admin accounts	Admin sign-in outside expected geography	Alert	Small population, so low noise
8	Finance-HR tripwire header	Message with X-District-FinTripwire (docs/01 §7.2)	Alert	Ties the content rule into monitoring

Auto-remediation: available, and **use it sparingly**. An auto-remediation rule that misfires during state testing is its own incident. Recommended posture: **auto-remediate nothing initially**. After 90 days of clean alerting, consider auto-action for the narrowest and highest-confidence rules only — rule 1 (external forwarding) is the strongest candidate, because a legitimate false positive costs one user one setting.

[Fundamentals] fallback: no activity rules. Substitute the monthly GAM audits in [audit/gam/]() — slower detection (days, not minutes) but the same findings. Increase to weekly for forwarding and delegates if on Fundamentals.

4. Security dashboard and health page

Security dashboard: [Admin console > Security > Security center > Dashboard](#) **[Standard]/[Plus]** ([source](#))

Security health page: [Admin console > Security > Security center > Security health](#) ([source](#))

The health page compares current settings against Google's recommendations and flags gaps. **Use it as a change-detection tool, not a scorecard** — the valuable signal is a setting that *used to* be green and now isn't. That means someone changed something.

REVIEW	FREQUENCY	OWNER	OUTPUT
Security health page — full pass	Monthly	Tech director	Deviations documented and justified or fixed
Security dashboard — spam/phishing trend	Weekly	Security admin	Volume anomalies
Dashboard — external sharing trend	Monthly	Security admin	Spikes investigated
Dashboard — OAuth grant activity	Monthly	Security admin	Feeds docs/07 §7
Dashboard — user report volume	Monthly	Security admin	Health of reporting culture

Capture a baseline snapshot in Phase 0 ([checklists/rollout-phases.md](#)). Without a before, you cannot show an after — and the after is what funds next year's work.

[Fundamentals] fallback: health page availability is limited; use the GAM audits as the monthly configuration-drift check.

5. Investigation tool — the workflow that matters

Path: [Admin console > Security > Security center > Investigation tool](#) [Standard]/[Plus] ([source](#))

Bulk post-delivery purge

This is the capability that turns a district-wide phish from a two-day incident into a twenty-minute one. Full procedure: [playbooks/03-post-delivery-phish-purge.md](#)

Summary:

1. **Search** Gmail log events by message ID, subject, or sender to find every recipient ([source](#)).
2. **Verify scope** — confirm the result set is the campaign and nothing else. Over-broad deletion is its own incident.
3. **Actions > Delete messages**, enter a justification (e.g. "Suspected malicious emails"), confirm ([source](#)).
4. Other available actions: mark as spam, **mark as phishing**, send to inbox.
5. **Prefer "mark as phishing" over plain delete** where you want Google's classifier to learn from the sample and where you want the message preserved for investigation. Delete removes evidence.

Justification text is not a formality — it is the audit record of an administrator reaching into user mailboxes. Write it as though it will be read by counsel, because it may be.

Other investigation workflows

GOAL	DATA SOURCE	FILTER
Who else got this phish?	Gmail log events	Subject / sender / message ID
What did a compromised account send?	Gmail log events	Sender = account, date range
What did they access?	Drive log events	Actor = account
What was shared externally?	Drive log events	Visibility = external / public
Where did they sign in from?	Login audit / User log events	Actor = account
Which accounts share this login IP?	Login audit	IP address — finds the rest of the campaign
What settings did they change?	Admin audit / User log events	Actor = account

That IP pivot is the highest-value one. If one account is compromised, the same attacker infrastructure usually touched others, and the login IP is how you find them before they're used.

[Fundamentals] fallback: no investigation tool. **Email log search** (\$6) locates messages but **cannot bulk-delete**. Purge then means per-user action or GAM scripting — materially slower. If the district is on Fundamentals for any population, know this gap before an incident, not during one.

6. Email log search and long retention

Email log search

Path: Admin console > Reporting > Email log search

Retains Gmail data for **30 days** ([source](#)). Best for basic queries against predefined reports. Answers: was it delivered, where did it go, was it quarantined, what did the receiving server say.

The 30-day limit is the operative constraint. BEC investigations routinely reach back further — a payroll diversion discovered on payday may have started six weeks earlier. If the district's only log source is email log search, that investigation cannot be completed.

BigQuery log export [Standard]/[Plus]

Path: Admin console > Reporting > BigQuery export ([source](#))

Supported editions include **Education Standard** and **Education Plus** ([source](#)).

CONSIDERATION	DETAIL
Why	Admin console keeps Gmail data 30 days; BigQuery keeps it as long as you want
Cost	BigQuery storage + query. Modest at district scale, but it is a real GCP bill — get it approved, don't surprise finance
Retention	13 months minimum recommended; 24 preferred (covers a full cycle plus comparison)
Access	Restrict the dataset. It contains metadata about every message in the district
Value	Historical BEC investigation, campaign correlation, "has this sender ever contacted us?"

Recommendation: enable it. It is optional right up until the day it isn't, and it cannot be enabled retroactively — the data you didn't export doesn't exist.

[Fundamentals] fallback: none. 30 days is the ceiling. Compensate with a documented procedure to **export email log search results monthly** to district storage. Manual and imperfect, and far better than nothing.

Vault

Path: vault.google.com ([source](#))

Retention rules govern how long data is kept and purge it when no longer needed. Vault retains data users deleted where it's subject to a hold or retention rule.

USE	SETTING
Mail retention	Per district records-retention policy — coordinate with the records officer, not IT alone
Litigation/IR hold	Place a hold on a compromised account before remediation
Coverage	Requires Vault licenses; verify coverage for all relevant users

The IR-relevant instruction: place a Vault hold on a compromised account **before** you start remediation. Remediation deletes evidence — that is what remediation is. A hold preserves it. This is step 2 in [playbooks/01](#) for exactly that reason.

Comprehensive mail storage ([docs/01 §5](#)) must be **On** for Vault and the investigation tool to see SMTP-relay and non-Gmail-mailbox traffic. Without it there are silent gaps in what you can investigate.

7. Build the reporting culture

The highest-value detection capability in the district is 1,200 people who report things. No configuration in this repo beats it, and it is the cheapest thing here.

Mechanics

- Gmail's "Report phishing" is built in. Use it — it feeds Google's classifier and the user-reported-phishing alert. Teach it as the default action.

- **<ABUSE_ALIAS>** for forwarding anything that doesn't fit, including QR flyers and text messages. Accept photos; a picture of a suspicious flyer is a legitimate report.
- **Acknowledge every report.** An auto-reply within seconds and a human note within a day for anything real. Silence trains people to stop.
- **Close the loop publicly.** "Fourteen of you reported the fake HR message this morning — we removed it from 340 inboxes in eleven minutes." That single sentence generates more future reports than any training module.

Culture rules

RULE	WHY
Never punish a click. Ever.	Punishment produces silence, and silence is how a 20-minute incident becomes a 3-day one
Thank every report, including wrong ones.	False positives are the cost of a working sensor network. A user who reports 10 legitimate newsletters is a user who will report the real one
Report first, delete second.	Deleted mail is harder to investigate
Make it one click.	Any friction and reporting stops
Report on personal devices too.	QR codes, SMS, and voice all arrive off-platform

Students specifically

For T10 (sextortion, scholarship scams) the reporting path must be **usable by a frightened 15-year-old**:

- **Non-punitive, explicitly.** A student who sent an image needs to believe they will not be disciplined for reporting. If they don't believe it, they pay the extortion instead.
- **No parent-notification precondition to reporting.** Parents get involved through the proper channel; requiring it *before* a report is a barrier at the worst possible moment.
- Counselors and the SRO in the loop by design, with a documented escalation path.
- Publicize the national routes: ncii.ic3.gov for non-consensual imagery, tips.fbi.gov, 1-800-CALL-FBI ([FBI](#)).
- Teach the one fact that changes outcomes: **complying with demands does not stop distribution — it reliably produces more demands** ([IC3 PSA 260810](#)).

This procedure belongs to student services with IT support, not to IT with student services consulted. Get that ownership right on paper before you need it.

8. Monitoring cadence

TASK	FREQUENCY	OWNER
Alert center triage	Daily, school days	Security admin
Quarantine review (docs/01 §9)	Daily, per SLA	Named reviewers
Apps pending review (docs/07)	Weekly	Tech dept
Security dashboard — spam/phishing trend	Weekly	Security admin
Security health page — full pass	Monthly	Tech director
GAM audit suite	Monthly	Security admin
External sharing / OAuth trend review	Monthly	Security admin
OAuth token + DWD audit	Quarterly	Tech director
Group settings audit (docs/04)	Quarterly	Security admin
Admin role review	Quarterly	Tech director
Cabinet name-rule refresh (docs/01 §7.1)	Quarterly	Security admin
Phishing simulation	Quarterly	Tech dept + HR
Tabletop exercise	2× per year	Cabinet + IT
Full package review against current Google docs	Annually	Tech director

Break coverage is a named assignment. Summer, winter, and spring break are when BEC campaigns run, precisely because review lapses. Assign it or explicitly lower quarantine actions for the period — both are defensible; an unmonitored quarantine is not.

09 — SPF, DKIM & DMARC

Research date 2026-08-20.

⚠ Read this before touching DNS

Enforcing DMARC before every third-party sender is aligned will break parent communication district-wide. Not degrade — break. Mass-notification messages, SIS alerts, lunch-balance notices, and attendance calls will be rejected by receiving servers, silently, at scale, and the district will find out from parents.

The inventory in `config/district-profile.md` is not paperwork. It is the gate. **Do not pass \$5 until it is complete.**

1. What each record does

	ANSWERS	FAILS WHEN
SPF	Which servers may send for this domain?	Sender IP isn't listed
DKIM	Was this message signed by the domain and unmodified?	Signature missing or invalid
DMARC	What should a receiver do when SPF <i>and</i> DKIM both fail to align?	Neither aligns

Alignment is the concept people miss. DMARC doesn't just need SPF or DKIM to *pass* — it needs the passing domain to *match the From: header domain*. A vendor whose SPF passes for `vendor-mailer.com` while sending as `<PRIMARY_DOMAIN>` fails DMARC alignment, even though SPF technically passed. This is precisely how bulk senders break at enforcement, and why the inventory matters more than the DNS syntax.

DKIM is what makes forwarded mail survive. SPF breaks on forwarding (the forwarding server isn't in the SPF record); DKIM survives it. In a district — where staff forward to each other constantly and parents forward to co-parents — DKIM alignment is the one that actually carries the load.

2. Step 1 — Inventory (the gate)

Complete `config/district-profile.md` → "Bulk senders" before proceeding. `ASSUMPTIONS.md` §A5 has the starting list.

Finding senders you don't know about

You will not remember them all. Find them:

1. **DMARC `rua` reports at `p=none` (\$5, Stage 1).** The authoritative method — every source sending as your domain shows up, including the ones nobody documented. **This is why Stage 1 runs for two full weeks minimum.**
2. **Email log search / BigQuery** ([docs/08 §6](#)) for outbound from non-Google IPs.
3. **Ask finance for the vendor list.** Anything that emails parents or staff is a sender. The AP ledger is a surprisingly good asset inventory.
4. **Walk the buildings.** Copiers, alarm panels, HVAC controllers, bell systems, marquee signs, gym scoreboards. Anything with an SMTP config is a sender, and none of it is in any inventory.
5. **Check the SMTP relay service settings** for who is authorized to use it.

Per sender, record

FIELD	WHY
Envelope-From and Header-From domains	Alignment depends on Header-From
SPF mechanism needed	<code>include:</code> , <code>ip4:</code> , <code>a:</code>
DKIM available?	If no, the vendor is a DMARC blocker — escalate now, not in month three
Selector and key length	2048 preferred
Business owner	Who calls the vendor
Criticality	Determines whether you delay enforcement or accept breakage

Vendors who cannot do DKIM are the critical path. Identify them in week one. The options are: get them to implement it, move them to a subdomain (§6), or replace them. All three take months. Starting that conversation late is what makes DMARC projects stall for a year.

3. Step 2 — SPF

Path (Google's record): `Admin console > Apps > Google Workspace > Gmail > Authenticate email` ([source](#))

The 10-lookup limit

SPF permits a maximum of **10 DNS lookups** during evaluation ([RFC 7208 §4.6.4](#)). Exceeding it produces `permerror`, which most receivers treat as **fail**. Every `include:`, `a`, `mx`, `ptr`, and `exists` counts — and a vendor's `include:` can contain its own nested includes that count against your budget.

Districts blow this limit routinely, because every vendor asks for one more `include:` and nobody counts. Then SPF silently fails for everything, and because DKIM usually still works, nobody notices until DMARC enforcement.

Target record

```
<PRIMARY_DOMAIN>. IN TXT "v=spf1 include:_spf.google.com include:_spf.<sis-vendor> include:<notification-vendor> ip4:<relay-ip> -all"
```

Rules:

- **Count your lookups before publishing.** Use an SPF flattening/validation checker.
- `-all` (hard fail), not `~all` (soft fail), **once you're confident the record is complete.** Start at `~all` during rollout.
- **One SPF record per domain.** Two TXT records both starting `v=spf1` is a `permerror` — a common and completely silent failure.
- Prefer `ip4:` for a fixed relay over an `include:` — costs zero lookups.
- **Every secondary domain needs its own record**, including parked ones. An unused domain with no SPF is a free spoofing asset.

Consolidation when over 10

1. Remove vendors no longer in use — always the first win, usually 2–3 lookups.
2. Replace `include:` with `ip4:` where the vendor publishes stable IPs.
3. Move a vendor to a **subdomain** (\$6) — that vendor's SPF then lives on the subdomain's record and costs nothing on the primary.
4. Use an SPF-flattening service **only as a last resort** — it introduces a dependency that silently breaks when a vendor changes IPs and you don't re-flatten.

Rollback: revert the DNS TXT record. Propagation per your TTL — **lower TTL to 300s before any change**, raise it after you're confident.

4. Step 3 — DKIM

Path: `Admin console > Apps > Google Workspace > Gmail > Authenticate email` → generate key → publish TXT → **Start authentication** ([source](#))

Google's DKIM

ITEM	VALUE
Key length	2048-bit. Google recommends 2048 where the DNS provider supports it; 1024 is the minimum for sending to personal Gmail (source)
Selector	Default <code>google</code> , or a custom one
Every domain	Generate and publish for each domain and alias domain separately
Verify	Confirm "Authenticating email" in the console after publishing

2048-bit keys exceed the 255-character limit of a single DNS string. Most providers split them automatically; some don't, and the record silently fails. If DKIM doesn't validate after publishing a 2048-bit key, this is the cause about 80% of the time.

Third-party sender DKIM — the actual work

Every bulk sender in the \$2 inventory needs its own DKIM, typically a CNAME the vendor provides pointing at their signing infrastructure.

SENDER	TYPICAL METHOD	NOTES
SIS	CNAME selectors	Usually supported
Mass notification	CNAME selectors	Usually supported; verify alignment , some sign as their own domain
Food service	Varies	Frequent blocker
Copiers via relay	Signed by the relay	Verify the relay signs as <code><PRIMARY_DOMAIN></code>
SMTP relay users	Signed by relay	Same
Small/legacy vendors	Often none	The critical path

Verify alignment, not just presence. A vendor signing with `d=vendor.com` while sending `From: notices@<PRIMARY_DOMAIN>` gives you a valid DKIM signature that **does not align** and therefore does not satisfy DMARC. Check `d=` against the From: domain for every sender. This is the single most common false "we're ready" in a DMARC project.

Google requires DKIM and SPF to be authenticating for at least 48 hours before DMARC is configured ([source](#)).

5. Step 4 — DMARC ramp (60–90 days)

Path: DNS TXT at `_dmarc.<PRIMARY_DOMAIN>` ([source](#))

Google's guidance: start at `p=none`, monitor, then move to quarantine for a small percentage, then increase, then reject ([source](#)).

The ramp

STAGE	DURATION	RECORD	EXIT CRITERIA
1. Monitor	14+ days (don't shorten)	<code>v=DMARC1; p=none; rua=mailto:dmarc@<PRIMARY_DOMAIN>; ruf=mailto:dmarc@<PRIMARY_DOMAIN>; fo=1; adkim=r; aspf=r</code>	Every source in reports identified and classified
2. Remediate	14–30 days	unchanged	100% of legitimate sources aligned. No exceptions, no "we'll fix it later"
3. Quarantine 10%	7 days	<code>p=quarantine; pct=10</code>	No legitimate mail in spam; no complaints
4. Quarantine 50%	7 days	<code>pct=50</code>	Same
5. Quarantine 100%	14 days	<code>p=quarantine; pct=100</code>	Two clean weeks. Include a payroll cycle and a mass-notification send
6. Reject 10%	7 days	<code>p=reject; pct=10</code>	Clean
7. Reject 50%	7 days	<code>pct=50</code>	Clean
8. Reject 100%	permanent	<code>v=DMARC1; p=reject; rua=...; fo=1; adkim=s; aspf=s</code>	Steady state

Ramp rules

- **Never skip Stage 2.** Every failed DMARC project skipped Stage 2.
- **Do not advance during:** the first two weeks of school, state testing, grade reporting, open enrollment, or a payroll week. If something breaks, it breaks then.
- **Advance on Tuesdays**, never Fridays. You want two business days of daylight.
- **Stage 5 must include a full mass-notification send and a payroll cycle.** Those are the flows that break, and they're periodic — a "clean" two weeks that missed both proves nothing.
- Tighten `adkim`/`aspf` from relaxed (`r`) to strict (`s`) only at Stage 8, and only if no sender depends on subdomain relaxation.
- `ruf` (forensic reports) may contain message content. Some receivers include headers and subjects — potentially student or staff information. Send `ruf` to a district-controlled mailbox, **never to a third-party hosted analyzer**, and apply the same PII discipline as everywhere else in this repo. `rua` (aggregate) contains no message content and is safe to process externally.

Secondary domains

Every domain that exists needs a DMARC record, including domains that never send mail:

```
_dmarc.<PARKED_DOMAIN>. IN TXT "v=DMARC1; p=reject; rua=mailto:dmarc@<PRIMARY_DOMAIN>;"
```

A non-sending domain can go straight to `p=reject` — there's no legitimate mail to break. Pair with `v=spf1 -all` and a null MX. **Do this on day one for parked domains**; it's free and it's the district's old domain from the last rebrand that gets used against it.

Rollback at any stage: lower `p=` or reduce `pct=`. Effective within DNS TTL — keep the `_dmarc` TTL at **300 seconds** through the entire ramp. Raise it only at Stage 8.

6. Subdomain strategy for stubborn senders

When a vendor genuinely cannot do aligned DKIM, don't hold the whole ramp for them.

Move them to a subdomain — `notices.<PRIMARY_DOMAIN>` — with its own SPF, its own DKIM, and its own DMARC policy that can lag the parent:

```
_dmarc.notices.<PRIMARY_DOMAIN>. IN TXT "v=DMARC1; p=none; rua=mailto:dmarc@<PRIMARY_DOMAIN>;"
```

The parent domain reaches `p=reject` on schedule while the problem sender sits at `p=none` on a subdomain with a visible deadline.

Two things to get right:

- The parent's policy applies to subdomains **unless** `sp=` is set. If you want the parent at reject and a subdomain at none, you need the subdomain's own `_dmarc` record — which is what the example above does.
- **This is a bridge, not a destination.** A subdomain at `p=none` is still spoofable and still carries the district's name. Set a hard deadline, and treat "the vendor still can't do DKIM" as a procurement finding for the next contract

cycle.

7. DMARC report analysis

[rua](#) reports are gzipped XML from every major receiver. Reading them by hand is not viable past week one.

Self-hosted: parsedmarc

Assumes a Docker host ([ASSUMPTIONS.md](#) §A7).

```
# compose.yaml - parsedmarc + OpenSearch + Dashboards
# Place beside a .env holding OPENSEARCH_INITIAL_ADMIN_PASSWORD and IMAP credentials.
# .env is gitignored. Do not commit credentials.
services:
  opensearch:
    image: opensearchproject/opensearch:2
    container_name: parsedmarc-opensearch
    environment:
      - discovery.type=single-node
      - bootstrap.memory_lock=true
      - "OPENSEARCH_JAVA_OPTS=-Xms1g -Xmx1g"
      - OPENSEARCH_INITIAL_ADMIN_PASSWORD=${OPENSEARCH_INITIAL_ADMIN_PASSWORD}
    ulimits:
      memlock: { soft: -1, hard: -1 }
      nofile: { soft: 65536, hard: 65536 }
    volumes:
      - opensearch-data:/usr/share/opensearch/data
    restart: unless-stopped

  dashboards:
    image: opensearchproject/opensearch-dashboards:2
    container_name: parsedmarc-dashboards
    environment:
      - OPENSEARCH_HOSTS=["https://opensearch:9200"]
    ports:
      - "127.0.0.1:5601:5601" # bind to loopback; front with Traefik + Tailscale
    depends_on: [opensearch]
    restart: unless-stopped

  parsedmarc:
    image: ghcr.io/domainaware/parsedmarc:latest
    container_name: parsedmarc
    volumes:
      - ./parsedmarc.ini:/etc/parsedmarc.ini:ro
    depends_on: [opensearch]
    restart: unless-stopped

volumes:
  opensearch-data:
```

```

; parsedmarc.ini
[general]
save_aggregate = True
save_forensic = True

[imap]
host = imap.gmail.com
port = 993
ssl = True
user = dmarc@<PRIMARY_DOMAIN>
; App password, or OAuth. Keep it out of this file in production - use env or a secret store.
password = ${IMAP_PASSWORD}

[mailbox]
watch = True
delete = False
archive_folder = Archive

[opensearch]
hosts = https://opensearch:9200
ssl = True

```

Operational notes:

- The `dmarc@` mailbox receives high volume — **exclude it from the §5 content compliance rules in [docs/01](#)**, or reports get banner-injected and parsing gets noisy.
- **Do not expose Dashboards to the internet.** Bound to loopback above; front it with Traefik behind Tailscale.
- Retain 13 months to cover a full school year plus year-over-year comparison.
- If DKIM app passwords are used for IMAP, note that app-specific passwords are themselves audited in `[audit/gam/05-app-passwords.sh]()` — document this one as a known, owned exception so it doesn't get revoked by a future audit sweep.

Hosted alternatives

Viable if there's no Docker host: Dmarcian, Valimail, EasyDMARC, Postmark's free DMARC digest, Cloudflare DMARC Management. **Send only `rua` to a hosted analyzer, never `ruf` (§5)** — forensic reports can carry message content.

8. Inbound DMARC

Everything above is about **outbound** — stopping others from spoofing the district. Inbound handling — what Gmail does with *others'* DMARC failures — is [docs/01-gmail.md](#) §3, specifically **Protect against any unauthenticated emails**.

Note the deliberate asymmetry: this document pushes the district to `p=reject`, while doc 01 keeps *inbound* unauthenticated mail at **warning** for staff. Not inconsistent — different risk calculus. Your own domain's alignment is under your control and worth enforcing hard. Every small vendor's and PTA volunteer's alignment is not, and quarantining all of it buries real detections.

If a third-party gateway fronts Google (ASSUMPTIONS.md §A4), inbound DMARC is evaluated at the gateway and Gmail sees the gateway's IP. Configure Gmail's inbound gateway settings so Google reads the **original** sender IP, or the doc 01 spoofing protections operate on the wrong data and quietly stop working.

9. Verification checklist

- ☐ Every sending system inventoried — [config/district-profile.md](#)
- ☐ SPF record present, single record, **under 10 lookups**, verified with a checker
- ☐ SPF published for **every** domain including parked ones
- ☐ Google DKIM generated at 2048-bit and **authenticating** for every domain
- ☐ Third-party DKIM configured **and alignment verified** (`d=` matches From: domain)
- ☐ 48+ hours of SPF/DKIM authentication before publishing DMARC
- ☐ `_dmarc` TTL at 300s for the ramp
- ☐ `p=none` with `rua` published; reports flowing to a district-controlled mailbox
- ☐ `ruf` going only to a district-controlled mailbox, never a third party
- ☐ parsedmarc (or alternative) ingesting and dashboards readable
- ☐ **Every source in reports identified** — no unknowns
- ☐ **100% of legitimate sources aligned** before Stage 3
- ☐ Stage 5 spanned a full mass-notification send and a payroll cycle
- ☐ Parked/secondary domains at `p=reject` with `v=spf1 -all` and null MX
- ☐ Advancement dates avoid start-of-year, testing, grade reporting, payroll weeks
- ☐ Rollback procedure and TTL confirmed before each advancement

Rollout Phases

Work these in order. Each phase has prerequisites, a change list, comms, success criteria, and a rollback trigger.

Total elapsed time: roughly one school year. That is not slow — Phase 1 delivers most of the risk reduction in the first month, and the remaining phases are gated on things that genuinely take time (2SV adoption, vendor DKIM, instructional coordination).

PHASE	FOCUS	DURATION	USER IMPACT
<u>0</u>	Baseline and inventory	1–2 weeks	None
<u>1</u>	Quick wins	2–3 weeks	Minimal
<u>2</u>	2SV + OAuth lockdown	6–8 weeks	High
<u>3</u>	DMARC ramp	8–12 weeks	None if done right, severe if rushed
<u>4</u>	Students, CAA, DLP	4–6 weeks	Moderate
Ongoing	Operations	Forever	—

Do not reorder. Phase 1 before Phase 0 means changing settings you haven't baselined and can't prove improved anything. Phase 3 before its inventory breaks parent communication. Phase 4 before Phase 2 tightens students while staff accounts — the higher-value targets — are still soft.

Phase 0 — Baseline

Duration: 1–2 weeks · User impact: none · Can start today

Prerequisites

- Super admin access
- GAM installed and authorized (optional — [audit/gam/README.md](#))
- Storage for audit output that is **not** this repo

Do

- ☐ Fill in [config/district-profile.md](#) — **the gate for everything else**
- ☐ Review and correct [ASSUMPTIONS.md](#)
- ☐ Run the full GAM audit suite: `audit/gam/run-all.sh`
- ☐ **Security health page snapshot** — screenshot every section ([docs/08 §4](#))
- ☐ Security dashboard snapshot — spam/phishing volume, external sharing, OAuth
- ☐ Export current Gmail Safety settings per OU (screenshots)
- ☐ Document current SPF, DKIM, DMARC records for **every** domain
- ☐ **Bulk-sender inventory** — the DMARC gate ([docs/09 §2](#))

- ☐ Enumerate POP/IMAP users, external forwarding, delegates
- ☐ Document existing allowlists — **and justify each or plan its removal** ([docs/01 §8](#))
- ☐ Name quarantine reviewers, backups, and break coverage
- ☐ Fill in the contact table in [playbooks/00-index.md](#)
- ☐ Confirm cyber insurance notification requirements and windows

Success criteria

- Every audit script has produced output that has been *read*, not just generated
- The bulk-sender inventory has no blanks
- You can state today's baseline numerically: N staff without 2SV, N external forwarding rules, N super admins, N open groups

Comms

None. Phase 0 is invisible.

Phase 1 — Quick wins

Duration: 2–3 weeks · **User impact:** minimal

This phase delivers the majority of the risk reduction in this package. If the project stalls after Phase 1, the district is still substantially better off.

Prerequisites

- Phase 0 complete
- Quarantine reviewers named, with an SLA and break coverage
- **Bulk senders confirmed authenticating** — required before the domain-spoofing setting ([docs/01 §3](#) blast radius)

Week 1 — no user impact

- ☐ **Alert center routing** to `<SECURITY_ALIAS>` + webhook ([docs/08 §2](#))
- ☐ Enable the high-value alerts, including **settings-changed** alerts
- ☐ Set up admin quarantines ([docs/01 §9](#))
- ☐ **Super admin hardening** — reduce to 2–4, hardware keys, APP, separate daily drivers ([docs/06 §5](#))
- ☐ **Calendar invitation control** ([docs/02 §2](#))
- ☐ Calendar external sharing → free/busy
- ☐ Enable security sandbox ([docs/01 §6](#))
- ☐ Links & external images all `On` ([docs/01 §4](#))
- ☐ Comprehensive mail storage `On`
- ☐ Default Drive link sharing → **Restricted** ([docs/03 §2](#))
- ☐ **Remove existing broad allowlists** ([docs/01 §8](#))

Week 2 — light user impact

- ☐ Gmail Safety attachments → Quarantine (docs/01 §2)
- ☐ Gmail Safety spoofing/auth → Quarantine, incl. **employee-name** and **Groups** (docs/01 §3)
- ☐ "Apply future recommended settings automatically" **On** everywhere
- ☐ **Groups org-wide policy** → admins-only creation, no external members/posting (docs/04 §2)
- ☐ **Tier 1 + Tier 2 group audit and lockdown** (docs/04 §3)
- ☐ **all-staff-senders@** created and applied (docs/04 §4)
- ☐ Warn for external recipients **On**

Week 3 — needs comms

- ☐ Content compliance: cabinet display-name banner (docs/01 §7.1)
- ☐ Content compliance: financial tripwire — **banner-only everywhere for one week**, then escalate Finance-HR to quarantine with real numbers (docs/01 §7.2)
- ☐ Service hygiene sweep — announce two weeks ahead (docs/05 §7)
- ☐ Drive: publish-to-web **Off** — **after** finding what's already public (docs/03 §3)

Comms

[comms/01-phase1-staff-notice.md]()

Success criteria

- Quarantine reviewed daily within SLA; release rate under 20% per quarantine
- Zero broad allowlists remain
- Super admins: 2–4, all on hardware keys, all APP-enrolled
- Tier 1 and Tier 2 groups: no external posting, no external members
- Calendar invitation control set (or confirmed not yet rolled out to your tenant)
- Alert center backlog: zero unreviewed over 24h

Rollback trigger

Quarantine release rate over 40% for a given setting → that setting is mis-tuned. Lower it to **Move to spam**, investigate, re-escalate. **Do not abandon the control.**

Phase 2 — 2SV and OAuth

Duration: 6–8 weeks · **User impact:** **high** — the hardest phase politically

Prerequisites

- Phase 1 complete and stable for two weeks
- **Superintendent-level sponsorship, in writing.** Without it this phase stalls at the first complaint
- Help desk staffed for the volume, with a documented reset procedure

- Hardware keys purchased and received for high-risk roles
- **App request workflow live** ([docs/07 §5](#))
- App inventory complete, approved apps already marked Trusted

Do

- ☐ Weeks 1–2: 2SV available, comms, drop-in sessions, **no enforcement**
- ☐ Week 3: targeted outreach to non-enrolled
- ☐ Week 4: **enforce for IT staff first** — dogfood the support burden
- ☐ Week 5: Finance-HR — **phishing-resistant methods only** ([docs/06 §3](#))
- ☐ Weeks 6–7: enforce for all staff, **in school-sized waves**
- ☐ Week 6: API controls — block unconfigured apps from restricted scopes ([docs/07 §2](#))
- ☐ Week 6: Marketplace → allowlist mode
- ☐ Week 7: **domain-wide delegation audit** — record Client IDs and scopes before removing anything ([docs/07 §6](#))
- ☐ Week 8: POP/IMAP off for staff — after the migration notice
- ☐ Week 8: external forwarding off for staff and Finance-HR
- ☐ Login challenges on — **after** the employee ID field is populated
- ☐ Session length shortened for admins and Finance-HR **[Plus]**

⚠ Do not

- Enforce district-wide on a single day
- Enforce during the first two weeks of school or state testing
- Turn on API controls before the approved-app list is marked Trusted
- Remove a DWD grant without recording the Client ID and scopes

Comms

[comms/02-phase2-2sv.md]() · [comms/03-phase2-apps.md]()

Success criteria

- 100% of active staff enrolled in 2SV
- 100% of admins and Finance-HR on **phishing-resistant** methods
- Zero unidentified DWD grants
- App request queue turning around within 10 business days
- No staff account with external forwarding

Rollback trigger

Help desk cannot keep up → pause the wave schedule, don't reverse completed waves. An instructional system broken by API controls → mark that specific app Trusted, don't disable app controls wholesale.

Phase 3 — DMARC ramp

Duration: 8–12 weeks · User impact: none if done right

This is the only phase that can break parent communication district-wide. Read [docs/09](#) in full before starting.

Prerequisites — all hard gates

- ☐ Bulk-sender inventory 100% complete — no blanks, no "probably"
- ☐ Every sender has a **named business owner**
- ☐ SPF under 10 lookups, single record, verified with a checker
- ☐ Google DKIM 2048-bit and authenticating on **every** domain
- ☐ **Every third-party sender DKIM-aligned** — `d=` verified against **From: domain**
- ☐ `dmARC@` mailbox created and **excluded from content compliance rules**
- ☐ `parsedmarc` (or alternative) running and readable
- ☐ `_dmARC` TTL lowered to 300s
- ☐ Vendors who cannot do DKIM identified and on a subdomain plan ([docs/09 §6](#))

Do

Work the eight-stage ramp in [docs/09 §5](#).

- ☐ Parked and secondary domains → `p=reject` + `v=spf1 -all` + null MX **on day one**
- ☐ Stage 1 `p=none` — **14 days minimum, do not shorten**
- ☐ Stage 2 remediate — **100% aligned before advancing**
- ☐ Stages 3–5 quarantine, staged pct
- ☐ Stages 6–8 reject, staged pct

Scheduling constraints

- **Advance on Tuesdays.** Never Fridays
- **Never during:** first two weeks of school, state testing, grade reporting, open enrollment, or a payroll week
- **Stage 5 must span a full mass-notification send and a payroll cycle** before advancing

Comms

Mostly internal. Notify each bulk-sender owner of the timeline and their alignment deadline. [[comms/04-phase3-vendor-notice.md](#)]()

Success criteria

- `p=reject` on all sending domains
- Zero legitimate sources failing in `rua` reports for 30 consecutive days
- Every parked domain at `p=reject`

- No increase in parent "I didn't get the notification" reports

Rollback trigger

Any legitimate mail flow breaking → drop `pct` or lower `p=` immediately. TTL is 300s, so recovery is five minutes. Then find the misaligned sender before re-advancing — do not simply retry.

Phase 4 — Student tightening, CAA, DLP

Duration: 4–6 weeks · **User impact:** moderate

Deliberately last. Staff accounts are the higher-value target; tightening students first optimizes the wrong thing. Also: student-facing changes need instructional coordination, which takes lead time.

Prerequisites

- Phases 1–2 complete
- **Instructional technology sign-off on every student-facing change**
- Guardian communication sent
- Help desk ready for student password volume

Do

- ☐ Age designation verified for all student OUs ([docs/05 §1](#))
- ☐ Student external Drive sharing restricted — **allowlisted domains for high school** ([docs/03 §2](#))
- ☐ Students: receive files from outside `Off`
- ☐ Student POP/IMAP and external forwarding `Off`
- ☐ Student Chat external `Off`; history admin-controlled
- ☐ Meet join scope domain-only
- ☐ Classroom membership domain-only both directions
- ☐ Takeout `Off` for students
- ☐ **Self-service password recovery `Off` for students** ([docs/06 §9](#))
- ☐ Calendar invitation control → strictest tier for students
- ☐ **DLP rules in audit mode for 30 days**, then tune, then enforce ([docs/03 §6](#)) **[Standard]/[Plus]**
- ☐ **Context-Aware Access in monitor mode**, then enforce — Admin console first ([docs/06 §8](#)) **[Plus]**
- ☐ Trust rules for Drive ([docs/03 §5](#)) **[Standard]/[Plus]**
- ☐ BigQuery log export enabled ([docs/08 §6](#))

⚠ Do not

- Enforce CAA without one super admin exempt and credentials in the safe
- Enforce DLP before 30 days of audit-mode data
- Apply student restrictions without instructional sign-off
- Apply geographic restrictions to students — the false-positive cost lands on the families least able to resolve it

Comms

[comms/05-phase4-students.md]() · [comms/06-phase4-guardians.md]()

Success criteria

- Student OU target state matches docs/05 §8
- DLP enforcing with a manageable false-positive rate
- CAA enforced on the Admin console with no lockouts
- **No instructional workflow broken** — measured by asking teachers, not by absence of tickets

Rollback trigger

Any instructional workflow broken → roll that setting back **same day**, then find a narrower way to achieve the goal. This is the rule in README.md and it is not negotiable.

Ongoing operations

Cadence

TASK	FREQUENCY	OWNER	REFERENCE
Alert center triage	Daily (school days)	Security admin	<u>08</u>
Quarantine review	Daily, per SLA	Named reviewers	<u>01 §9</u>
App requests	Weekly	Tech dept	<u>07 §5</u>
Spam/phishing trend	Weekly	Security admin	<u>08 §4</u>
Security health page	Monthly	Tech director	<u>08 §4</u>
GAM audit suite + diff vs last month	Monthly	Security admin	<u>audit/gam</u>
Forwarding/delegate audit	Monthly	Security admin	<u>audit/gam</u>
OAuth token + DWD audit	Quarterly	Tech director	<u>07 §7</u>
Group settings audit	Quarterly	Security admin	<u>04 §7</u>
Admin role review	Quarterly	Tech director	<u>06 §5</u>
Cabinet name-rule refresh	Quarterly	Security admin	<u>01 §7.1</u>
Allowlist exception review	Quarterly	Tech director	<u>01 §8</u>
Service hygiene sweep	Quarterly	Tech dept	<u>05 §7</u>
Appointment schedule review	Per term	Security admin	<u>02 §5</u>
Phishing simulation	Quarterly	Tech dept + HR	below
Tabletop exercise	2× per year	Cabinet + IT	below
Package review vs current Google docs	Annually	Tech director	—

Phishing simulation — rules

- **Never punitive.** No discipline, no naming, no leaderboards of failure. The moment a simulation has consequences, real reporting stops
- Report the **report rate**, not just the click rate. Report rate is the metric that predicts real-incident outcomes
- Rotate scenarios against [docs/00-threat-landscape.md](#): leadership impersonation, payroll, vendor invoice, QR code, Calendar invite
- Immediate, non-judgmental micro-training on click
- **Do not simulate sextortion or anything involving students.** Ever
- Coordinate with HR before each round — this touches employee relations

Training rhythm

AUDIENCE	FREQUENCY	FOCUS
All staff	Annually + at onboarding	Recognize, report, never punished
Finance-HR	Quarterly	Payroll diversion, invoice fraud, callback rule, AI-summary caution
Administrators	2× per year	Impersonation, deepfakes, authorization discipline
IT staff	Quarterly	Playbooks, tooling, drills
Students	Annually, age-appropriate	Phishing, sextortion reporting, scams
Guardians	Annually	District will never ask X by email; how to verify

Tabletop exercises

Two per year, cabinet-level, 90 minutes. Rotate scenarios:

1. Superintendent impersonation → \$40k gift card request nearly paid
2. Payroll diversion discovered on payday, 14 staff affected
3. Vendor invoice fraud, \$180k wire sent
4. Ransomware via phished staff credential, SIS encrypted
5. Student data breach via a compromised ed-tech vendor
6. Deepfake voice of the CFO authorizing a transfer

Test decisions and communication, not technical steps. Who decides to notify parents? Who talks to the press? Who calls the insurer? When does the board get told? Those are the questions that go badly in a real incident, and they are free to rehearse.

Annual review

- ☐ Re-verify every console path against current Google documentation — **paths move**
- ☐ Re-read [docs/00-threat-landscape.md](#) against current MS-ISAC, K12 SIX, CISA, and IC3 reporting
- ☐ Review Workspace Updates for the last 12 months
- ☐ Resolve outstanding [\[VERIFY\]](#) tags
- ☐ Update ASSUMPTIONS.md against reality
- ☐ Re-baseline metrics against the Phase 0 snapshot — **this is what funds next year**

Playbooks

Numbered, 2am-executable. Each step has a **verify** line. Do not skip verify lines — they are how you know the step worked when you are tired and being watched.

#	PLAYBOOK	TRIGGER	FIRST ACTION
<u>01</u>	Compromised staff account	Alert, user report, or anomalous activity	Suspend the account
<u>02</u>	Compromised student account	Same, student OU	Reset password
<u>03</u>	Post-delivery phish purge	Phish confirmed delivered to multiple users	Scope the campaign
<u>04</u>	Payroll diversion attempt	Banking-change request, tripwire hit, or payroll report	Freeze the change
<u>05</u>	Vendor invoice fraud	Remittance change on an invoice	Stop the payment
<u>06</u>	Mass calendar spam	Multiple users report unwanted events	Change the invitation setting
<u>07</u>	Lookalike domain	Domain-spoofing quarantine hit or report	Confirm and document

Before any incident

Fill these in now. Hunting for them mid-incident is how thirty-minute incidents become three-hour ones.

ROLE	NAME	MOBILE	BACKUP
Security admin (primary)			
Technology director			
Superintendent / designee			
CFO / finance director			
Communications			
District legal counsel			
Cyber insurance carrier — claims			
Google Workspace support (PIN/case)			
Law enforcement — local			
FBI field office / IC3	tips.fbi.gov	1-800-CALL-FBI	ic3.gov
MS-ISAC SOC			

Universal rules

1. **Contain before you investigate.** A running compromise gets worse while you read logs.
2. **Preserve before you remediate.** Vault hold first — remediation destroys evidence.
3. **Write down what you do, with timestamps.** You will be asked. Insurance and counsel both need it, and memory is not evidence.
4. **Never punish a reporter,** including the person who clicked.
5. **Assume more than one account.** Pivot on login IP.
6. **Escalate money early.** Any funds movement → CFO and superintendent immediately. Under 72 hours, a wire can sometimes be recalled. After that, rarely.
7. **No PII in tickets, chat, or notes.** Reference accounts by OU and role, not by name, wherever the record will persist.

Playbook 01 — Compromised Staff Account

Trigger: suspicious-login alert, leaked-password alert, user report, mail the user didn't send, or unexplained forwarding/filter/delegate changes.

Target: contained in 15 minutes.

The core fact for this playbook: a password reset does not invalidate an OAuth refresh token, an app-specific password, a forwarding rule, or a delegate grant. If you stop at step 3, the attacker still has the mailbox. Steps 5–9 are the incident.

Phase 1 — Contain (0–15 min)

1. Suspend the account

`Admin console > Directory > Users` → user → **Suspend user**

Faster and more complete than a password reset: it kills active sessions and blocks re-authentication in one action.

Verify: user shows `Suspended`. Attempt to load their Gmail in an incognito window with a known-good session — access denied.

2. Place a Vault hold — before remediating

`vault.google.com` → Matters → new matter → hold on this account, Gmail + Drive.

Do this before steps 5–9. Those steps delete the evidence you will need.

Verify: hold shows active, account listed.

3. Reset the password

`Admin console > Directory > Users` → user → **Reset password**. Require change at next sign-in. Deliver out of band — phone call or in person, never email or text.

Verify: reset confirmed in console.

4. Sign out all sessions

User page → Security → **Sign out user** (sign out of all sessions)

Verify: login audit shows session termination.

Phase 2 — Remove persistence (15–45 min)

This phase is the one that determines whether you're back here next week.

5. Revoke all OAuth tokens

Admin console > Directory > Users → user → Security → Connected applications → remove all.

```
gam user <account> show tokens
gam user <account> delete tokens
```

Verify: re-run `show tokens` — empty.

6. Delete app-specific passwords

User → Security → App passwords → revoke all.

```
gam user <account> show asps
gam user <account> delete asps all
```

Verify: `show asps` returns none.

7. Check and remove forwarding

```
gam user <account> show forward
gam user <account> show forwardingaddresses
gam user <account> print filters
```

Remove any forwarding to an external address. **Also check filters** — attackers use a filter that forwards *and* archives, so the user never sees the mail. A filter is easier to miss than a forwarding rule and does the same job.

Verify: no forwarding, no filters with external forward or delete actions.

8. Check delegates and send-as

```
gam user <account> show delegates
gam user <account> show sendas
```

Remove unrecognized delegates. Remove unverified or unfamiliar send-as aliases.

Verify: delegate and send-as lists match expectation.

9. Check recovery options

User → Security → recovery email/phone. Attackers change these to retain a path back in.

Verify: recovery details are district-controlled and expected.

10. Check for admin role changes

gam print admins

Verify: the account holds no admin role it shouldn't. If it does — treat as a domain-level incident, escalate to the technology director immediately, and check every other admin account.

Phase 3 — Assess blast radius (45–120 min)

11. What did it send?

[Security](#) > [Security center](#) > [Investigation tool](#) → **Gmail log events** → Sender = account, date range = suspected compromise window (default to 30 days, not "since the alert").

Verify: every outbound message in the window reviewed. Note recipients — internal and external.

12. Purge anything malicious it sent

→ [Playbook 03](#)

13. What did it access?

Investigation tool → **Drive log events** → Actor = account. Look for mass downloads, mass external sharing, access to student-records or finance folders.

Verify: file access reviewed; anything exfiltrated documented for step 20.

14. Where did they sign in from?

Investigation tool → **Login audit** → Actor = account. Record every IP and location.

Verify: unauthorized IPs identified and written down.

15. Pivot on the IP — find the rest

Investigation tool → **Login audit** → filter by the attacker IP across **all users**.

This step finds the accounts you don't know about yet. One compromised account is almost never one compromised account.

Verify: all accounts touching that IP identified. **Run this playbook for each.**

16. Did they reach finance or student data?

If the account had SIS access, finance system access, or student-records access: **escalate to the technology director and CFO now**, and check for a payroll change ([Playbook 04](#)).

Phase 4 — Restore (2–24 h)

17. Restore access

Unsuspend. Require 2SV enrollment if not already — [docs/06 §3](#).

If the user is Finance-HR or admin, enroll a passkey or security key before restoring access. This is the moment they will accept the friction.

Verify: user signs in successfully with 2SV.

18. Verify the settings stayed clean

Re-run steps 5–9. Attackers sometimes re-establish persistence between containment and restoration.

Verify: all clean.

19. Brief the user

Explain what happened, what was done, what to watch for. **Do not blame.** The next report depends on how this conversation goes.

Phase 5 — Close out (24–72 h)

20. Notification assessment

If student or staff PII was accessed or exfiltrated: **engage district legal counsel and the records officer.** FERPA and state breach-notification obligations may apply. **This determination is not IT's to make alone.**

21. Report externally

- Cyber insurance carrier — often required within a contractual window
- IC3 (ic3.gov) if there was financial loss or attempted loss
- MS-ISAC, if a member
- State education agency, per state requirement

22. Root cause

How did they get in? Phish (which one? is it still in other inboxes?), reused password, AiTM, OAuth grant? **Feed the answer back into the controls** — [docs/00-threat-landscape.md](#).

23. Timeline document

Timestamped, factual, no speculation. Store it with the Vault matter. Insurance and counsel will both ask for it.

GAM one-liner: full persistence check

```
for f in tokens asps forward forwardingaddresses delegates sendas filters; do
  echo "=== $f ==="
  gam user <account> show "$f" 2>/dev/null || gam user <account> print "$f" 2>/dev/null
done
```

Run at step 5 and again at step 18. **The second run is the one that catches re-establishment.**

Playbook 02 — Compromised Student Account

Trigger: alert, teacher report, student report, or a student account sending spam.

Same structure as [Playbook 01](#), four differences that matter:

1. **Student safety first.** If content suggests grooming, sextortion, self-harm, or threats → §6. That takes precedence over every containment step below.
 2. **Internal reach.** A student account is a trusted internal sender. Mail from it bypasses every external-sender control the district has.
 3. **Parent communication** may be required by policy.
 4. **Lower privilege, higher volume.** Frequently many accounts at once (shared/guessed passwords, a class that all clicked the same link).
-
-

1. Contain (0–10 min)

1.1 Reset the password

`Admin console > Directory > Users` → **Reset password**, require change at next sign-in.

Prefer reset over suspend for students — suspension blocks schoolwork, and the instructional cost is real. **Suspend instead if** the account is actively sending, or content indicates a safety concern.

Verify: reset confirmed.

1.2 Sign out all sessions

User → Security → Sign out user

Verify: login audit shows termination.

1.3 Remove persistence

```
gam user <account> delete tokens
gam user <account> delete asps all
gam user <account> show forward
gam user <account> print filters
gam user <account> show delegates
```

Verify: all clean. Forwarding and POP/IMAP should already be off per [docs/01](#) §5 — if you find them enabled, that is a **configuration finding**: check whether the OU policy is applied correctly.

2. Scope (10–30 min)

2.1 What did it send — internally?

Investigation tool → **Gmail log events** → Sender = account.

Check internal recipients first. Student-to-student and student-to-staff phishing is the main risk here, and it is invisible to every external-sender control.

Verify: all outbound reviewed.

2.2 Purge

→ Playbook 03

2.3 Pivot — how many students?

Investigation tool → **Login audit** → filter by attacker IP across all users.

Expect multiple accounts. Student credentials are commonly harvested in batches — one class, one game lure, one shared password pattern.

Verify: full list built. Bulk-reset if large: [audit/gam/remediation/]().

2.4 Check Drive

Investigation tool → **Drive log events** → Actor = account. Look for mass sharing or downloads.

3. Restore (30–60 min)

3.1 Deliver the new password

In person, through the school, not by email. Coordinate with the school's front office or media specialist.

Verify: student can sign in.

3.2 Brief the student

Age-appropriate, **non-punitive**. "This happens, you did the right thing telling us." A student who fears consequences tells no one next time, and next time may be \$6.

3.3 Notify the parent/guardian if policy requires

Coordinate with the school administration. **IT does not make this call alone.**

4. Configuration check

A compromised student account is often a symptom. Verify for the student OU:

- ☐ External forwarding **Off** — [docs/01](#) §5
- ☐ POP/IMAP **Off** — [docs/01](#) §5
- ☐ Self-service password recovery **Off** — [docs/06](#) §9
- ☐ Takeout **Off** — [docs/05](#) §6
- ☐ External Chat **Off** — [docs/05](#) §2
- ☐ Drive external sharing restricted — [docs/03](#) §2
- ☐ Third-party apps blocked — [docs/07](#) §2
- ☐ Age designation correct — [docs/05](#) §1

If several of these are wrong, the incident is the configuration, not the account.

5. Mass compromise (10+ accounts)

1. **Find the common factor** — same class? same lure? same weak password pattern from a bulk import?
 2. **Bulk reset** the affected set — [audit/gam/remediation/]().
 3. **Purge the lure** — [Playbook 03](#).
 4. **Notify schools** so front offices are ready for the password volume.
 5. **Notify guardians** per policy, with a short "what happened / what we did" note.
 6. **If a bulk-import default password pattern is the cause, fix the provisioning process.** Otherwise this recurs every August.
-

6. Safety escalation — takes precedence over everything above

If the compromise involves, or the mailbox contains, evidence of:

- Sextortion or solicitation of images
- Grooming by an adult
- Threats of violence, to self or others
- Sale or solicitation of drugs or weapons

Then, immediately:

1. **Preserve everything.** Vault hold. **Do not delete, do not purge** — you are now handling evidence.
2. **Notify the school principal and school counselor now.**
3. **Notify the SRO / law enforcement** per district policy.
4. **Notify the district's Title IX / student services lead** if applicable.

5. **Do not contact the external party. Do not investigate the external party.** That is law enforcement's role, and interference can compromise a case.
6. Report non-consensual intimate imagery at ncii.ic3.gov; FBI at tips.fbi.gov or 1-800-CALL-FBI ([FBI/NCAA advisory](#)).
7. If the student is the victim of sextortion, ensure they are told: **complying does not stop distribution — it produces more demands** ([IC3 PSA 260810](#)). Counselors deliver this, not IT.

Ownership: student services and school administration own this from step 2 onward. IT supports with technical preservation. Do not let it default to being IT's incident.

Playbook 03 — Post-Delivery Phish Purge

Trigger: a phishing message is confirmed delivered to multiple mailboxes.

Target: purged in 30 minutes from decision.

Requires: security investigation tool — [Standard]/[Plus]. Fundamentals fallback in §7.

1. Confirm it is malicious (0–5 min)

Do not skip this. A bulk deletion of legitimate mail is its own incident, and it is harder to explain.

- ☐ Message reviewed by a human — headers, links, and the actual ask
- ☐ Destination URL checked (**do not visit from a district machine**; use a sandbox or URL analysis service)
- ☐ Confirmed not a legitimate vendor, a district system, or a phishing simulation
- ☐ Second admin concurs — **required for any purge over 50 mailboxes**

Verify: written confirmation in the ticket, naming both reviewers.

2. Capture evidence before purging (5–10 min)

Deleting the campaign deletes your evidence.

1. Save the **full headers** of one copy.
2. Record: sender address, sender IP, subject line(s), message ID(s), destination URL(s), first-seen timestamp.
3. If any user entered credentials — **Vault hold on those accounts before purging**.
4. Save a copy of the message to the incident record.

Verify: artifacts saved outside the mailboxes being purged.

3. Scope the campaign (10–20 min)

Admin console > Security > Security center > Investigation tool → Gmail log events ([source](#))

Search in this order, broadening each time:

SEARCH	CATCHES
Message ID	The exact message
Sender address	Same-sender variants
Sender domain	Multiple sender addresses, one domain
Subject line	Same subject, rotated senders
Subject fragment	Slightly varied subjects

Attackers rotate. A campaign is rarely one sender and one subject — searching only by message ID typically finds a third of it.

- ☐ Total recipients identified
- ☐ Date range covers the full campaign, not just today
- ☐ Result set reviewed — **no legitimate mail caught in the filter**

Verify: recipient count recorded. Spot-check 5 results manually before acting.

4. Purge (20–30 min)

Investigation tool → select results → **Actions**

Choose the action deliberately:

ACTION	USE WHEN
Mark as phishing	Default choice. Feeds Google's classifier, preserves the message for investigation, removes it from the inbox
Delete messages	Malware attachments, or content that must not persist (explicit imagery, doxxing)
Mark as spam	Low-confidence bulk nuisance
Send to inbox	Reversing a false positive

Enter a **justification** — e.g. `Suspected malicious emails – INC-2026-0042` ([source](#)).

The justification is the audit record for an administrator reaching into user mailboxes. Include the incident number. Write it for counsel.

Verify: action reports success. Re-run the §3 search — results should now show the messages actioned.

5. Find who interacted (30–60 min)

Purging removes the message. It does not undo a click.

1. **Who clicked?** If the URL is known and the district has web-filter or DNS logs, query for the destination domain across the same window. Not available inside Workspace — this needs the network side.
2. **Who replied?** Investigation tool → Gmail log events → recipient = the phishing sender. **A reply means engagement, and engagement means treat as compromised.**
3. **Who authenticated?** Check login audit for anomalous sign-ins across recipients in the window following delivery.

For anyone who clicked *and* entered credentials, or replied: → [Playbook 01](#) / [Playbook 02](#)

Verify: interaction list built; each name has a follow-up action.

6. Prevent recurrence (same day)

- ☐ **Block the sender domain** via content compliance — [docs/01 §7](#) — narrowly, by envelope sender or domain, with an expiry date
 - ☐ If it's a lookalike domain → [Playbook 07](#)
 - ☐ **Why did this get through?** Which doc 01 setting should have caught it? If a setting is at warning that should be at quarantine, **that is the finding** — change it
 - ☐ If it exploited a Google service (Calendar, Forms, Drive share) → [docs/05 §7](#)
 - ☐ Report the sample to Google via **Report phishing** so the classifier learns
-

7. Fundamentals fallback (no investigation tool)

1. **Email log search** ([Reporting > Email log search](#)) to identify recipients — **it cannot delete**.
2. Export the recipient list.
3. GAM per-user deletion: `bash gam user <account> delete messages query "rfc822msgid:<message-id>" doit`
Loop over the recipient list. **Test on one mailbox first, without `doit`, and read the output.**
4. Materially slower — plan on hours, not minutes.

Know this gap before an incident. If any population is on Fundamentals, the 30-minute target in this playbook does not apply to them, and leadership should know that in advance rather than during.

8. Communicate (same day)

Short, factual, no blame — and close the loop publicly:

This morning several of you reported a message claiming to be from [role] asking you to [action]. It was not legitimate. We removed it from [N] inboxes within [N] **minutes. Thank you to everyone who reported it — that's exactly why we caught it quickly.** If you clicked the link or entered your password, contact the help desk now. **You will not be in trouble.**

That last sentence is a security control. Template in [comms/]()).

Playbook 04 — Payroll / Direct-Deposit Diversion

Trigger: a request to change direct-deposit details, a Finance-HR tripwire hit ([docs/01 §7.2](#)), or an employee reporting a missing paycheck.

Money is moving. Speed matters more than tidiness.

If a payroll run has already executed with changed banking details, go to §4 first, then come back. Recovery windows are measured in hours.

1. Freeze (0–15 min)

1.1 Stop the change

Contact payroll **by phone**. Do not email — if the mailbox is compromised, you are talking to the attacker.

- Has the banking change been entered? → **revert it now**
- Is a payroll run pending? → **hold it**
- Has the run executed? → §4, immediately

Verify: payroll confirms verbally that the change is reverted or blocked.

1.2 Verify out of band

Call the employee on a number **from the HR system**, not one in the email or the request.

Ask directly: *"Did you request a direct deposit change on [date]?"*

Verify: employee confirms or denies, by voice.

If they confirm they made the request: it may still be fraud — they may have been phished into making it themselves. Ask what prompted it. A "your payroll profile needs re-verification" email is the tell.

1.3 If not legitimate — contain the account

→ [Playbook 01](#), starting at step 1.

Also contain any **payroll or HR staff account** that processed the change.

2. Assess (15–60 min)

2.1 How did the change arrive?

PATH	THEN
Email request to payroll	The requester's mailbox is likely compromised → Playbook 01
Self-service portal	The portal credential is compromised — reset there too, not just Google
Phone request	Possible voice impersonation (T12) — note it, it changes the training story
Paper form	Check the signature and the delivery path

Verify: origin documented with timestamps.

2.2 Is this one employee or many?

Query the payroll system for **all banking changes in the last 60 days**. Payroll diversion campaigns hit many staff at once, and one detected change usually means several undetected ones.

Verify: every change in the window reviewed and confirmed with the employee by phone.

Do this even when the first one turns out to be legitimate. The query costs ten minutes.

2.3 Was there a phishing campaign?

Investigation tool → search for the lure across all mailboxes → [Playbook 03](#).

2.4 Check for mailbox persistence

On any affected mailbox, check filters specifically for rules matching `direct deposit`, `payroll`, or `paycheck` that archive or delete. Attackers set these so the confirmation email is never seen.

```
gam user <account> print filters
```

Verify: no suppression filters present.

3. Escalate (within 1 hour)

Notify, in this order:

1. **CFO / Finance Director** — funds at risk
2. **Superintendent** — district-level exposure
3. **Technology Director**
4. **District legal counsel** — if funds moved or PII was exposed
5. **Cyber insurance carrier** — often a contractual notification window

6. HR Director — employee impact

Verify: notifications logged with timestamps.

4. If money already moved

Time-critical. The first 72 hours matter; the first 24 matter most.

1. **Call the district's bank immediately.** Request a recall / reversal. Have the transaction details ready before you dial.
2. **File an IC3 complaint at ic3.gov immediately** — the FBI's Recovery Asset Team can attempt to freeze funds at the receiving institution, but only while they're still there. **Do not wait for internal review to file.**
3. Contact **local law enforcement** for a report number — insurance will require it.
4. Notify the **cyber insurance carrier** — many policies require notification within a defined window and will deny late claims.
5. **Make the affected employee whole** per district policy — the employee did not lose their own money through their own fault, and treating them as though they did guarantees the next incident goes unreported.

Verify: IC3 complaint number recorded. Bank case number recorded. Police report number recorded.

5. Close the process gap

This is the part that actually prevents recurrence. Technical controls did not fail here — a process did.

The rule to implement

No banking change is processed on an emailed request alone. Ever.

Every direct-deposit change requires **out-of-band verification**: a callback to the number in the HR system, or in-person confirmation with ID. Not a number in the email. Not a reply to the email. Not a text to a number the requester supplied.

Implement

- ☐ Written procedure, signed off by the CFO
- ☐ Payroll staff trained, with the callback script on the desk
- ☐ **Waiting period** — 24–48 hours between request and effective change
- ☐ **Confirmation to the employee's known-good address and phone** when a change is made, so the employee finds out even if the mailbox is compromised
- ☐ Self-service portal requires **step-up authentication** for banking changes
- ☐ Phishing-resistant 2SV for Finance-HR — [docs/06 §3](#)
- ☐ Tripwire rule active — [docs/01 §7.2](#)

- ☐ **Explicit permission for staff to refuse and verify**, regardless of who is asking or how urgent they say it is. Say this out loud, from the superintendent, in writing.

That last item is the one that gets skipped and the one that works. A payroll clerk who believes they will be criticized for slowing down the superintendent will process the change.

6. Communicate

To staff, after resolution — **without naming the affected employee**:

We recently identified an attempt to redirect an employee's direct deposit through a fraudulent request. It was caught and no funds were lost. **HR will never process a banking change from an email alone** — every change is verified by phone. If you receive a message asking you to update payroll or banking details, forward it to [<ABUSE_ALIAS>](#). If you're ever unsure, slow down and call. **You will never be criticized for verifying.**

Template in [comms/]() .

Playbook 05 — Vendor Invoice Fraud

Trigger: a vendor requests a change to remittance/banking details, an unexpected invoice arrives, or an existing invoice is "corrected" with new payment information.

Highest per-incident loss category in K-12. Losses are typically five to six figures, occasionally seven.

Why your email controls will not catch this. The message frequently comes from the **vendor's real, compromised mailbox**, inside a real thread, with correct branding and history. SPF, DKIM, and DMARC all pass — correctly. There is no authentication signal to detect. **The control is the callback in §2.**

1. Stop the payment (0–15 min)

1.1 Hold it

Contact AP **by phone**.

- Payment not yet sent → **hold**
- Payment in a batch → **pull it from the batch**
- Payment sent → \$5, immediately

Verify: AP confirms verbally that the payment is held.

1.2 Freeze the vendor record

Do not update the vendor master with the new details. If already updated, **revert it and note who made the change and when**.

Verify: vendor record shows original banking details.

2. Verify out of band (15–45 min)

The only control that reliably works.

2.1 Call the vendor

Use a phone number **from the signed contract or the vendor master record as it existed before this request** — never:

- a number in the email
- a number in the new invoice
- a number on a website you reached from a link in the email
- a number the requester provides when asked

Ask: *"Did you request a change to your remittance details on [date]?"*

Verify: confirmed or denied by a known vendor contact, by voice.

2.2 If the vendor denies it

Their mailbox is compromised.

1. **Tell them, clearly** — they may not know, and they have other customers being targeted right now.
2. Ask which of their staff are affected.
3. **Treat all recent correspondence from that vendor as suspect**, including messages that predate this one.
4. Check whether the district sent anything sensitive into that thread.

2.3 If the vendor confirms it

Still verify independently — confirm the new banking details against a document the vendor sends through a **different channel** (portal, signed letter on letterhead, a second known contact). A compromised mailbox can also answer the phone number listed in that mailbox's signature.

3. Assess exposure (45–120 min)

3.1 Any other payments to this vendor?

Query AP for all payments to this vendor in the last 90 days. Verify each against the original banking details.

Verify: all recent payments confirmed as going to the correct account.

3.2 Other vendors targeted?

Query AP for **all remittance changes in the last 90 days**, across every vendor. Verify each by callback.

Verify: every change in the window confirmed.

This step routinely finds a second one. Do it even when the first is resolved.

3.3 Is the district compromised too?

If the thread includes district staff, check whether any district mailbox is compromised — an attacker inside the district mailbox can read the thread and time the request perfectly.

→ [Playbook 01](#)

Verify: finance staff mailboxes checked for forwarding, filters, delegates.

3.4 Purge related mail

→ [Playbook 03](#)

4. Escalate (within 1 hour)

1. CFO / Finance Director
 2. Superintendent
 3. Technology Director
 4. District legal counsel — contract and liability implications
 5. Cyber insurance carrier
 6. Purchasing — if the vendor relationship is affected
-

5. If money already moved

Same as [Playbook 04 §4](#), and just as time-critical:

1. Bank — request recall immediately. Have transaction details in hand before dialing.
2. IC3 at ic3.gov immediately — the Recovery Asset Team can attempt a freeze while funds remain at the receiving institution. **File before internal review completes.**
3. Local law enforcement — report number for insurance.
4. Cyber insurance carrier.
5. **Notify the vendor** — they need to know, both to secure their environment and because the invoice is still legitimately owed.

Verify: IC3 number, bank case number, police report number all recorded.

6. Close the process gap

The rule

No remittance change is processed without out-of-band verification to a phone number on file from before the request. No exceptions for urgency. No exceptions for a familiar name. No exceptions because the thread looks real — the thread being real is exactly the attack.

Implement

- ☐ Written AP procedure, CFO sign-off
- ☐ Callback contact recorded in the vendor master at onboarding, and treated as change-controlled — a vendor master where the phone number can be edited by the same request that changes the banking details provides no protection at all
- ☐ Dual approval for any remittance change
- ☐ Waiting period — 48 hours before a changed account is used
- ☐ Threshold requiring a second approver above a set amount

- ☐ Tripwire rule active — [docs/01 §7.2](#)
 - ☐ Phishing-resistant 2SV for AP staff — [docs/06 §3](#)
 - ☐ Annual re-verification of banking details for the top N vendors by spend
 - ☐ **Explicit authorization for AP staff to delay a payment to verify**, from the CFO, in writing
-
-

7. Vendor relationship

Compromised vendors are victims too, and the district will keep doing business with them. Handle it as a partnership:

- Tell them plainly what happened and what you observed
- Ask them to confirm remediation before normal processing resumes
- Ask what they're doing to prevent recurrence
- **Consider requiring vendors to notify the district of a mailbox compromise** as a contract term at the next renewal — that is a procurement action worth taking to the CFO once, and it protects every future engagement

Playbook 06 — Mass Calendar Spam Cleanup

Trigger: multiple users report unwanted events appearing on their calendars.

Stop the inflow before cleaning, or you will clean the same calendars twice.

1. Stop the inflow (0–15 min)

1.1 Set the invitation control

Admin console > Apps > Google Workspace > Calendar > Advanced settings → Add invitations to Calendar

Set **Least restrictive level available** to **Invitations from known senders** (students: **Invitations users have responded to via email**).

Full detail: [docs/02-calendar.md](#) §2

Verify: setting saved. **Propagation takes up to 24 hours** ([source](#)) — plan the rest of this playbook accordingly.

If the setting is not present in your console: the control began rolling out **2026-08-14** and rollout is gradual (up to 15 days) ([Workspace Updates](#)). Proceed with §2 onward and set it as soon as it appears. In the interim, push the user-side setting via comms (§5).

1.2 Block the sender

Content compliance rule ([docs/01](#) §7) rejecting Calendar notification mail from the offending sender domain. Narrow — envelope sender or domain only — with an expiry date.

Verify: rule active; test with a subsequent message if one arrives.

2. Scope (15–30 min)

Calendar invitations arrive as email, so email tooling finds them.

Security > Security center > Investigation tool → Gmail log events

Search by: sender address, sender domain, subject fragment (typically **Invitation:**, **Updated invitation:**, or **Cancelled event:**).

- ☐ Recipient count
- ☐ Date range — check whether this has been running quietly for weeks
- ☐ All sender variants identified — **campaigns rotate sender addresses**
- ☐ Event title(s) and any embedded URLs recorded

Verify: scope documented before any deletion.

3. Purge the notification mail (30–45 min)

Investigation tool → select → **Actions** → **Mark as phishing**

Prefer mark-as-phishing over delete: it feeds Google's classifier and preserves the sample.

Justification: `Calendar invitation phishing campaign – INC-<number>`

Verify: re-run the §2 search; messages show actioned.

This removes the email. It does not remove the calendar event. Those are separate objects — §4.

4. Remove the events

4.1 Small scale — user self-service

Instruct users to use **"Report as spam"** in Google Calendar rather than plain **Delete**.

Why this matters: plain delete can send a response to the organizer, confirming the mailbox is live and monitored. Report-as-spam does not, and it feeds Google's abuse signals.

Verify: spot-check with a few reporting users.

4.2 Large scale — bulk removal

For hundreds of affected calendars, per-user cleanup is not viable.

```
# Identify first - ALWAYS dry-run before deleting.
gam all users print events matchfield summary "<event title fragment>" \
  > audit/gam/out/calendar-spam-scope.csv

# Review the CSV. Confirm every row is spam. Then:
gam all users delete events matchfield summary "<event title fragment>" doit
```

Rules:

- Always run the `print` form first and read the output. Bulk-deleting calendar events is irreversible and there is no restore.
- Match on the most specific string available. A short or common fragment will match legitimate events.
- Test against a single user before running against `all users`.

Verify: re-run the `print` form — zero results. Spot-check three user calendars manually.

4.3 Watch for cancellation follow-ups

Attackers cancel events to deliver a second message, since cancellation notices also carry attacker text ([BleepingComputer](#)). Monitor for **Cancelled event:** notifications from the same sender for the next week.

5. Communicate

Some of you have seen unexpected events appear on your Google Calendar. These are spam and in some cases phishing. **Do not click links inside them.**

To remove one: open the event and choose **Report as spam** — not Delete. Delete can tell the sender your address is active.

We have changed a district setting so invitations from unknown senders will no longer be added to your calendar automatically. You can also check this yourself: **Calendar > Settings > Event settings > "Add invitations to my calendar" > "Only if the sender is known."**

Template in [comms/]() .

6. Verify and close

- ☐ Invitation control set and **propagated** (re-check after 24h)
- ☐ Sender blocked, with an expiry date on the rule
- ☐ Notification mail purged
- ☐ Events removed — verified by spot-check on at least three calendars
- ☐ No new events for 48 hours
- ☐ Anyone who clicked a link identified → [Playbook 01](#)
- ☐ Cancellation follow-ups monitored for one week
- ☐ Calendar external sharing reviewed while you're in there — [docs/02](#) §3

Playbook 07 — Lookalike Domain Response

Trigger: a domain-spoofing quarantine hit ([docs/01 §3](#)), a user report, or a routine domain-monitoring alert.

Examples of what you're looking for: `<district>-schools.org` vs `<district>schools.org`, `.net` for `.org`, `rn` for `m`, `l` for `i`, added or removed hyphens, a plural, or an added word like `-hr` or `-payroll`.

1. Confirm and document (0–30 min)

1.1 Verify it's hostile

Not every similar domain is an attack. Check for: a legitimate business with a similar name, a district vendor, a parked domain with no mail, or a domain the district itself registered years ago and forgot.

Verify: classification recorded with reasoning.

1.2 Capture evidence — before it disappears

```
whois <lookalike-domain>
dig <lookalike-domain> ANY +noall +answer
dig MX <lookalike-domain> +short
dig TXT <lookalike-domain> +short
```

Record: registrar, registration date, name servers, MX records, SPF/DKIM/DMARC presence, hosting IP, and any registrant details not behind privacy.

Screenshot any website, with timestamp. **Do not visit from a district machine** — use an isolated system or a URL analysis service.

Verify: artifacts saved to the incident record.

Registration date is the highest-signal field. A domain registered in the last 72 hours with MX records configured is an active campaign in its setup phase, and you may be ahead of the first message.

2. Contain (30–60 min)

2.1 Block inbound

Content compliance rule ([docs/01 §7](#)): reject or quarantine all inbound from the domain **and its subdomains**.

Verify: rule active and scoped to all OUs.

2.2 Block Drive sharing to it

Trust rule ([docs/03 §5](#), rule 6): **Block sharing to the domain.** [Standard]/[Plus]

Verify: rule active.

2.3 Block at the network layer

DNS filtering / web filter / firewall — block the domain district-wide. This covers the QR-code and SMS vectors that never touch email.

Verify: blocked from a test client on the district network.

2.4 Check whether it already sent

Investigation tool → **Gmail log events** → sender domain = lookalike, widest available date range.

If mail was delivered → [Playbook 03](#).

Verify: delivery history checked; purge completed if needed.

3. Take it down (1–5 business days)

3.1 Registrar abuse report

Find the registrar from [whois](#); submit to their abuse contact. Include:

- The lookalike domain and the district's real domain
- Evidence of impersonation (screenshots, message samples, headers)
- A statement that it is being used to impersonate a public school district
- Any evidence of active phishing

Verify: ticket/case number recorded.

3.2 Hosting provider abuse report

If a website is hosted, report separately — hosting and registration are usually different companies, and hosting takedowns are often faster.

Verify: case number recorded.

3.3 Google Safe Browsing

Report at safebrowsing.google.com/safebrowsing/report_phish/. Gets it flagged in Chrome and Gmail broadly, often within hours — frequently the fastest real-world mitigation.

Verify: submitted.

3.4 Law enforcement

- IC3 at ic3.gov — always, even with no loss. It builds the pattern record.
- Local law enforcement if there's a loss or a credible threat.
- MS-ISAC, if a member — they can escalate and may already be tracking the actor.

Verify: IC3 complaint number recorded.

3.5 If it's impersonating for financial fraud

Notify the district's bank so they can flag payments to accounts connected to this campaign.

4. Notify

4.1 Staff

We've identified a fraudulent domain, [<lookalike>](#), being used to impersonate the district. Legitimate district email always comes from [@<PRIMARY_DOMAIN>](#). **Check the sender address carefully**, especially on anything about payments, payroll, or passwords. Forward anything suspicious to [<ABUSE_ALIAS>](#).

4.2 Parents/guardians — if they're being targeted

Coordinate with communications. Post on the district site and push through the mass-notification system. **Parents are often the target** — fake fundraiser, fake lunch balance, fake registration.

4.3 Vendors and partner districts

If the domain is being used against them in the district's name, tell them directly. They will do the same for you.

4.4 Cyber insurance

Notify per policy.

5. Monitor

- ☐ Watch for **additional lookalikes** — actors register in batches, and the second one is usually already registered
 - ☐ Re-check registration/MX weekly until taken down
 - ☐ Watch for the campaign shifting to a new domain after takedown — **the takedown usually moves the actor rather than stopping them**
 - ☐ Keep the content compliance and trust rules in place after takedown; domains get re-registered
-

6. Prevent

6.1 Defensive registration

Register the obvious variants of the district domain: common TLDs ([.net](#), [.com](#), [.us](#)), common typos, hyphenated forms. ~\$15/year each. For 10 variants that's \$150/year against an incident class that costs six figures. Take that ratio to the CFO once; it is an easy yes.

Point them at the district website, and give each `v=spf1 -all`, a null MX, and `p=reject` — see [docs/09](#) §5.

6.2 Domain monitoring

Set up alerting for newly-registered domains similar to `<PRIMARY_DOMAIN>`. Free and commercial options exist; DMARC `rua` reports also surface some of this ([docs/09](#) §7).

6.3 Controls that must already be on

- Protect against domain spoofing based on similar domain names → [Quarantine](#) ([docs/01](#) §3)
- DMARC at `p=reject` ([docs/09](#)) — stops the *exact* domain being spoofed, though **not** a lookalike, which is a different domain entirely and can publish its own perfectly valid SPF and DKIM

That distinction is worth stating to leadership: DMARC does not stop lookalike domains. People assume it does. The control for lookalikes is the §3 similar-domain setting plus defensive registration.

GAM Audit Scripts

Read-only audit scripts for a Google Workspace for Education tenant. Every script writes CSV to `audit/gam/out/`, which is `.gitignore`d.

⚠ Output contains PII

These scripts export staff and student email addresses, forwarding destinations, and delegate relationships. `audit/gam/out/` is `gitignored` — **keep it that way**. Do not commit output, do not paste it into a ticket, do not email it. Store on district-managed storage with access controls, and delete when the audit is closed. See [CLAUDE.md]().

If GAM is not installed

These scripts are still useful as documentation. Every script header names the Admin console equivalent for the same check. Work the console paths manually — slower, same findings.

To install: [GAM7](#) or [GAMADV-XTD3](#). Requires a super admin to authorize a project. The GAM service account itself becomes a high-value credential — see §Safety.

Requirements

- GAM7 or GAMADV-XTD3, authorized with super admin
- `bash`, `jq` (optional, for a couple of summaries)
- Run from the repo root or from `audit/gam/`

Verify before first run:

```
gam version
gam info domain
```

Scripts — all read-only

SCRIPT	FINDS	ADMIN CONSOLE EQUIVALENT
[01-users-without-2sv.sh]()	Accounts not enrolled/enforced in 2SV	Directory > Users, add 2SV column
[02-forwarding-and-filters.sh]()	External forwarding, forwarding addresses, suspicious filters	Not fully available in console — this is the gap GAM fills
[03-delegates.sh]()	Mailbox delegates and send-as aliases	Not available in console at scale
[04-oauth-tokens.sh]()	OAuth grants per user and per app	Security > API controls > App access control
[05-app-passwords.sh]()	App-specific passwords	Per user only, in console
[06-group-settings.sh]()	Group posting/join/external-member settings	Directory > Groups, one at a time
[07-admin-roles.sh]()	Admin role assignments	Account > Admin roles
[08-ou-service-state.sh]()	Service on/off state per OU	Apps > (each service), one at a time
[run-all.sh]()	Runs all of the above	—

Scripts 02, 03, and 06 are the ones that justify GAM. Those checks are impractical at district scale through the console, and they are where compromises hide.

Cadence

SCRIPT	FREQUENCY	WHY
01 — 2SV	Monthly	Enforcement drift, new hires
02 — forwarding/filters	Monthly (weekly on Fundamentals)	#1 attacker persistence mechanism
03 — delegates	Monthly	Quiet persistent access
04 — OAuth tokens	Quarterly	docs/07 §7
05 — app passwords	Quarterly	Bypass 2SV by design
06 — group settings	Quarterly	docs/04 §7
07 — admin roles	Quarterly	Privilege creep
08 — OU service state	Quarterly	New services arrive enabled

Diff against the previous run. The diff is more valuable than the report — it shows what someone changed since last time.

```
diff <(sort out/2026-07-01-forwarding.csv) <(sort out/2026-08-01-forwarding.csv)
```

Interpreting output

01 — 2SV

Expected non-compliant: `/Service Accounts`, `/Shared Devices`, students (not enforced by design — [docs/06 §10](#)). Any staff account in the list is a finding.

02 — Forwarding and filters

Every external forwarding destination is a finding until proven otherwise. Common legitimate cases: a staff member forwarding to a district-owned alias, an approved integration. Everything else needs a conversation.

Filters matter as much as forwarding rules. Look specifically for filters that forward externally, or that delete/archive messages matching `payroll`, `invoice`, `direct deposit`, `password`, or `security` — that pattern is attacker suppression, not user preference.

03 — Delegates

Legitimate: an admin assistant delegated to an administrator's mailbox. Findings: delegates outside the expected relationship, delegates on Finance-HR mailboxes, delegates granted to accounts that are now suspended or departed.

04 — OAuth tokens

Sort by app, count users. High user counts on unrecognized apps are the priority. Check scopes against necessity — [docs/07 §5](#).

05 — App passwords

App-specific passwords bypass 2SV by design. Each one is a standing credential. If POP/IMAP is off per [docs/01 §5](#), most of these should not exist — their presence usually means a legacy client nobody migrated. Known exceptions (e.g. the parsedmarc IMAP account, [docs/09 §7](#)) should be **documented** so a future sweep doesn't revoke them blindly.

06 — Group settings

Findings: `whoCanPostMessage` allowing anyone or the public, `allowExternalMembers = true`, external posting enabled. Prioritize by member count — see the tier model in [docs/04 §3](#).

07 — Admin roles

Expect to find more super admins than the district needs. Vendor accounts from completed projects are the most common orphan. Target: 2–4 — [docs/06 §5](#).

08 — OU service state

Every `On` service is attack surface. Feed into [docs/05 §7](#).

Safety

- **Everything in this directory is read-only.** Write operations live in [remediation/](), separately, with warnings.
 - Scripts use `set -euo pipefail` and will stop on error rather than continue silently.
 - The GAM service account is a **super-admin-equivalent credential**. Protect `~/.gam/` accordingly: restricted filesystem permissions, on a managed workstation, never in a shared or synced folder. **A compromised GAM credential is a compromised domain.**
 - Run from a managed workstation, not a personal machine.
-

Verify before trusting output

Scripts were written against GAM7 / GAMADV-XTD3 syntax as documented on 2026-08-20 ([GAMADV-XTD3 wiki](#)). GAM syntax varies between GAM7 and GAMADV-XTD3 and changes across versions.

Run each script once and inspect the output before relying on it in an audit. An empty CSV may mean "no findings" or may mean the command silently returned nothing — those look identical in a report and lead to opposite conclusions. Each script prints a row count so you can tell.

⚠️ REMEDIATION SCRIPTS — THESE MAKE CHANGES

Everything in this directory modifies your tenant. The scripts in the parent directory are read-only; these are not.

Rules

1. **Run the corresponding read-only audit first.** Know what you are changing before you change it.
2. **Every script defaults to dry-run.** You must pass `--commit` to make changes. This is deliberate, and do not remove it.
3. **Keep the audit output.** It is your only rollback for a bulk change. There is no undo button in GAM.
4. **Test against one account first.** Every script accepts a single-account argument.
5. **Not during:** the first two weeks of school, state testing, grade reporting, or a payroll week.
6. **Log what you ran, when, and why.** Scripts append to `out/remediation-log.txt`.

Scripts

SCRIPT	DOES	REVERSIBLE?
<code>[revoke-tokens.sh]()</code>	Revokes OAuth tokens and app passwords for an account	No — users must re-consent
<code>[remove-forwarding.sh]()</code>	Removes forwarding, forwarding addresses, and matching filters	No — record them first
<code>[lockdown-group.sh]()</code>	Sets a group to internal-only, owner-post, moderated	Yes, if you saved prior settings
<code>[bulk-reset-passwords.sh]()</code>	Resets passwords for a list of accounts	No

When each is appropriate

revoke-tokens.sh — during [playbooks/01](#) step 5, and at staff offboarding. Suspending an account does not reliably revoke its OAuth grants; this does.

remove-forwarding.sh — during incident response, or as cleanup after [docs/01](#) §5 turns the feature off. **The setting prevents new rules; it does not remove existing ones.** Capture what you're removing first — some are legitimate and users will ask.

lockdown-group.sh — bulk application of the [docs/04](#) §3 tier model. Save `06-group-settings.sh` output first; it is the restore point.

bulk-reset-passwords.sh — mass student compromise, [playbooks/02](#) §5. **Coordinate with schools before running** — the front office absorbs the volume, and they need warning.

Rollback

There is no general undo. Rollback is reconstruction from audit output:

CHANGE	ROLLBACK
Tokens revoked	Users re-consent to legitimate apps individually
Forwarding removed	Re-create from the pre-change CSV — which is why you keep it
Group settings changed	Restore from <code>06-group-settings.sh</code> output
Passwords reset	Not reversible. Users get new credentials

If you did not keep the audit output, you do not have a rollback. Say that out loud before running anything here.

Communication Templates

Adapt before sending. Replace `<TOKENS>` — see [config/district-profile.md](#).

TEMPLATE	AUDIENCE	WHEN
[01]()	All staff	Before Phase 1 week 2
[02]()	All staff	Phase 2 week 1
[03]()	Teachers	Phase 2 week 5
[04]()	Vendors	Phase 3 start
[05]()	Students	Phase 4
[06]()	Guardians	Phase 4
[07]()	All staff	After a phish
[08]()	All staff	2 weeks before the sweep

Rules for all district security comms

1. **Lead with what changes for them**, not with why IT is doing it.
2. **Never imply blame**. Not for clicking, not for reporting late, not for asking.
3. **Give one action**, not five.
4. **Say who to contact**, with a real address.
5. **Include "you will not be in trouble"** on anything incident-related. It is a security control, not a courtesy — it is the difference between finding out in twenty minutes and finding out in three days.
6. **Send from a person**, not from "IT". A named sender gets read.
7. **Short**. Anything past ~200 words is skimmed, and the action gets missed.

District Profile — fill this in first

Every doc in this repo references the tokens below instead of hard-coded values. Fill this in, run the substitution snippet at the bottom, commit the result.

Identity

TOKEN	VALUE	NOTES
<DISTRICT_NAME>		e.g. "Example County Schools"
<PRIMARY_DOMAIN>		the domain in staff email addresses
<STUDENT_DOMAIN>		same as primary in most districts; separate in some
<SECONDARY_DOMAINS>		alias/legacy domains — each needs its own DMARC record
<SECURITY_ALIAS>		monitored group for alerts, e.g. <code>security@</code> — see note
<ABUSE_ALIAS>		where users forward suspected phish, e.g. <code>phishing@</code>

<SECURITY_ALIAS> must be a Google Group, not an individual. Alert center routing to a personal address dies when that person leaves or takes leave. Lock the group per `docs/04-groups.md` (internal posting only) or alert routing becomes an injection path.

Scale

TOKEN	VALUE
<STAFF_COUNT>	
<STUDENT_COUNT>	
<SCHOOL_COUNT>	

OU map

Record the real tree. The settings tables use four role archetypes — map each to a real OU path here:

ARCHETYPE (TABLE COLUMN)	REAL OU PATH(S)
Staff	
Students	
Finance-HR	
Admins	
Shared Devices	
Service Accounts	

Mail flow

- MX points at: ☐ Google direct ☐ third-party gateway → name: _____
- Inbound gateway configured in Gmail (required if a gateway fronts Google): ☐ Y ☐ N
- SMTP relay service in use for copiers/scripts: ☐ Y ☐ N

Bulk senders sending AS <PRIMARY_DOMAIN>

This table gates DMARC enforcement. Do not move past `p=none` until every row is filled and every row is DKIM-aligned. Start from the assumed list in `ASSUMPTIONS.md` §A5.

SYSTEM	VENDOR	SENDS AS	SPF MECHANISM	DKIM SELECTOR	ALIGNED?	OWNER
SIS					☐	
Mass notification					☐	
LMS					☐	
Food service					☐	
Transportation					☐	
Copiers / scan-to-email					☐	
Helpdesk / ticketing					☐	
Survey tools					☐	
SMTP relay users					☐	

Tooling

- GAM7 / GAMADV-XTD3 with super admin: ☐ Y ☐ N
- Docker host for parsedmarc: ☐ Y ☐ N
- Existing SIEM / log destination: _____

Cabinet & high-risk name list

Names used by the display-name warning rule in [docs/01-gmail.md](#) §7 and the employee-name spoofing control. **Roles, not a roster** — keep the actual names in the Admin console rule only, never committed here (FERPA discipline; see [CLAUDE.md](#)).

ROLE	IN CABINET NAME RULE?	IN FINANCE-HR OU?
Superintendent	☐	☐
Deputy/Assistant Superintendent(s)	☐	☐
CFO / Finance Director	☐	☐
HR Director	☐	☐
Payroll Supervisor	☐	☐
Accounts Payable	☐	☐
Technology Director	☐	☐
Principals (each school)	☐	☐
Board Chair	☐	☐

Substitution

Once filled in, replace tokens across the repo:

```
grep -rl '<PRIMARY_DOMAIN>' --include='*.md' --include='*.sh' . \
| xargs sed -i '' \
-e 's/<DISTRICT_NAME>/Example County Schools/g' \
-e 's/<PRIMARY_DOMAIN>/example.k12.st.us/g' \
-e 's/<SECURITY_ALIAS>/security@example.k12.st.us/g'
```

Review the diff before committing — the token list above is not exhaustive for every doc.

ASSUMPTIONS

The source prompt left the Context block unfilled. Per instruction, no questions were asked — every gap below was filled with a reasonable assumption and logged here. **Anything in this file is a guess until the district confirms it.** Correct `config/district-profile.md` first; these docs reference tokens, not hard-coded values.

A1 — District identity is tokenized, not invented

Assumption: Rather than invent a domain name, every doc uses replaceable tokens (`<PRIMARY_DOMAIN>`, `<DISTRICT_NAME>`, `<SECONDARY_DOMAINS>`, `<SECURITY_ALIAS>`). **Why:** Guessing a live district's mail domain and then publishing DNS records against it is worse than a placeholder — a wrong `_dmarc` host silently does nothing, and a *right-looking but wrong* one is worse still. **Action required:** Fill in `config/district-profile.md` and run the substitution snippet at the bottom of that file.

A2 — Scale: ~1,200 staff / ~12,000 students

Assumption: A mid-size public district. Drives only two things in this repo: quarantine-review staffing (assumed 2 reviewers, one primary) and the 2SV enrollment window length (assumed 30 days). **Impact if wrong:** low — adjust the SLA table in `docs/01-gmail.md` and the Phase 2 window in `checklists/rollout-phases.md`.

A3 — OU structure

Assumed the structure suggested in the prompt:

```

/                                     (root - most restrictive defaults inherit down)
├── /Staff
│   ├── /Staff/Finance-HR           ← payroll, AP, benefits, purchasing
│   └── /Staff/Admins               ← IT + super admin daily-driver accounts
├── /Students
│   ├── /Students/Elementary
│   ├── /Students/Middle
│   └── /Students/High
├── /Shared Devices                 ← library/lab/kiosk, cart logins
└── /Service Accounts               ← SIS, relay, integrations (no interactive humans)

```

Why it matters: Every settings table in this repo has Staff / Students / Finance-HR / Admins columns. If the real tree differs, the *columns* still map — they are role archetypes, not literal OU paths. `/Shared Devices` and `/Service Accounts` are called out individually where a setting would break them.

A4 — Mail flow: Gmail direct MX, no third-party gateway

Assumption: MX points at Google; no Proofpoint/Mimecast/Barracuda in front. **If a gateway exists this changes real things:** SPF must authorize the gateway, inbound DMARC evaluation happens at the gateway not Gmail, and Gmail's spoofing protections see the gateway as the sending IP — which usually means you must configure an inbound gateway in Gmail so Google reads the *original* sender IP. Flagged inline in [docs/01-gmail.md](#) and [docs/09-dmarc-spf-dkim.md](#).

A5 — Bulk senders that send as the district domain

The prompt calls this "critical for DMARC work" and it was blank. Assumed the typical K-12 set, as a **starting inventory to verify, not a finished one**:

SENDER CLASS	TYPICAL PRODUCT	ALIGNED BY
SIS	PowerSchool / Infinite Campus	SPF include + DKIM CNAME
Mass notification	SchoolMessenger / ParentSquare / Blackboard	SPF include + DKIM
LMS	Canvas / Schoology / Classroom	usually sends as vendor domain
Food service	Titan / LINQ / Nutrikids	often SPF-only — DMARC risk
Transportation	Zonar / Versatrans	often SPF-only
Copiers / MFP scan-to-email	Ricoh / Konica / Xerox	SMTP relay, no DKIM
Ticketing / helpdesk	Incident IQ / Freshservice	SPF include
Survey / forms	Qualtrics / Panorama	SPF include
SMTP relay users	scripts, alarm panels, HVAC, bells	relay, no DKIM

Why this is the single highest-risk assumption in the repo: publishing `p=reject` before this list is complete and aligned is the documented way to cut off parent communication district-wide. [docs/09-dmarc-spf-dkim.md](#) gates enforcement on completing this inventory.

A6 — GAM7 configured with a super admin: assumed YES

Scripts in [audit/gam/](#) are written to run as-is. If GAM is not deployed they remain valid documentation of *what to look at* — every script header names the Admin console equivalent. Marked optional in [audit/gam/README.md](#).

A7 — Self-hosted Docker host available: assumed YES

[docs/09-dmarc-spf-dkim.md](#) ships a parsedmarc `compose.yaml`. Hosted alternatives are listed for districts without a Docker host.

A8 — Edition: Education Plus, district-wide

Assumption: Plus licensing covers *all* staff and students, not a subset. **Common reality:** many districts license Plus for staff and Fundamentals/Standard for students. Where a control needs Plus, this repo labels it and gives the Fundamentals-tier fallback, so a split-license district can still execute.

A9 — Parents/guardians are external users

Explicit in the prompt and treated as a hard constraint. No staff-side control in this repo blocks external mail, external Drive sharing, or external Calendar invites outright — staff settings warn, student settings restrict.

A10 — No third-party MDM/identity layer assumed

Assumed Google as the IdP (no Okta/Entra SSO, no ClassLink/Clever as the auth source). **If SSO is in front of Google**, 2SV enforcement and Context-Aware Access behave differently — Google's 2SV policy does not apply to SSO-authenticated sessions, so the phishing-resistant requirement must be enforced at the IdP instead. Flagged in [docs/06-accounts-mfa-admins.md](#).

A11 — "Today" is 2026-08-20

All "as of" statements, the 12-month update window, and the Calendar control's rollout status are anchored to this date.